RÉPUBLIQUE TUNISIENNE

****

MINISTÈRE DE L'ENSEIGNEMENT SUPÉRIEUR ET DE LA RECHERCHE SCIENTIFIQUE

UNIVERSITÉ DE SFAX

FACULTÉ DES SCIENCES DE SFAX

****

DÉPARTEMENT D'INFORMATIQUE ET DES COMMUNICATIONS

Mémoire de Fin d'Études

présenté à

La Faculté des Sciences de Sfax

en vue de l'obtention du

Diplôme de Licence en Ingénierie des Systèmes Informatiques

par

Amal KARAOUD

Mahdi GHOZZI

« Conception et développement d'une plateforme de renseignement sur les cybermenaces (CTI) avec surveillance automatisée du Dark Web »

---

soutenu le 18 Juin 2026, devant le jury composé de :

Mme.	**Rahma BOUAZIZ**	*Présidente*
Mme.	**Wiem EL BEKRI**	*Examinatrice*
Mme	**Emna CHARFI EP HAMMAMI**	*Encadrante académique*
M.	**Yassine MASMOUDI**	*Encadrant professionnel*

Stage réalisé à « IRS Technologie »

DÉDICACES

Dédicace de Amal KARAOUD :

À moi-même, avant tout,

À mon esprit qui a traversé les tempêtes et à mon âme qui a su surmonter les nuits les plus arides. Je me remercie de n'avoir jamais abdiqué et d'avoir puisé en moi la force de me relever. Que cette œuvre soit le triomphe de ma résilience.

À mes vénérés grands-parents,

Racines de mon être et gardiens d'une tendresse intemporelle. Que cet accomplissement soit le reflet de la lumière que vous avez insufflée dans notre lignée.

À mes très chers parents,

Phares de mon destin et architectes de mon avenir. Votre amour inconditionnel et votre foi en moi furent la sève de mes plus belles victoires. Je dépose ce labeur entre vos mains comme une offrande face à l'immensité de votre dévouement. Ce triomphe est éternellement le vôtre.

À mon cher binôme, Mahdi,

Pour ta collaboration élégante et la rigueur de ton esprit. Ta patience et ton professionnalisme ont fait de ce projet une œuvre partagée d'une rare noblesse.

À ma famille et mes précieux amis,

Gardiens de mon équilibre et refuges de mes incertitudes. Merci pour votre présence rassurante et votre soutien indéfectible tout au long de ce voyage.

Dédicace de Mahdi GHOZZI :

À mes parents et ma soeur, piliers inébranlables de mon existence,

Vos prières ont été mon sanctuaire et votre affection, ma boussole. Par votre soutien infaillible, vous avez tracé la voie lumineuse de mes accomplissements. Merci d'avoir cru en mon potentiel lorsque tout restait à bâtir, et d'avoir orchestré avec amour chaque étape de ma réussite.

À mes aïeux bien-aimés, mes chers grands-parents,

Mémoires vivantes de notre lignée et sources d'une tendresse inépuisable. Votre sagesse a éclairé mon chemin et vos douces prières ont été un bouclier contre les incertitudes de ce parcours. Puissiez-vous trouver dans cette œuvre l'hommage sincère à votre bienveillance.

À mon estimée partenaire de projet, Amal,

Pour l'élan de ton engagement et la rare alchimie qui a couronné nos efforts conjoints. Ton esprit d'équipe et notre synergie ont transcendé ce labeur pour en faire une véritable odyssée humaine.

À mon cercle de cœur, ma famille et mes fidèles amis,

Vous qui avez embrassé mes espérances et adouci ce cheminement par votre simple présence. Recevez l'empreinte de ma gratitude infinie et le témoignage d'une affection impérissable.

REMERCIEMENTS

Tout d'abord, nous tenons à exprimer notre profonde gratitude envers Allah Tout-Puissant pour nous avoir accordé la santé, la force, la patience et la persévérance nécessaires afin de mener à bien ce projet de fin d'études.

Nous tenons à remercier chaleureusement notre encadrante académique, **Mme Emna Charfi Ep Hammami**, pour sa disponibilité constante, ses précieux conseils scientifiques, sa rigueur méthodologique et son suivi attentif qui ont grandement orienté la qualité de ce travail.

Nous exprimons également notre sincère reconnaissance à notre encadrant professionnel, **M. Yassine Masmoudi**, pour son accueil au sein de l'entreprise, son partage d'expertise technique, ses directives judicieuses et le temps qu'il nous a consacré malgré ses nombreuses obligations professionnelles.

Nous adressons nos vifs remerciements à la présidente du jury, **Mme Rahma Bouaziz**, ainsi qu'à l'examinatrice, **Mme Wiem El Bekri**, pour nous avoir fait l'honneur d'évaluer notre travail, d'examiner ce mémoire et de l'enrichir par leurs remarques précieuses et constructives.

Enfin, nous remercions l'ensemble du personnel de **IRS Technologie** pour leur bienveillance, ainsi que toutes les personnes qui ont contribué, de près ou de loin, par leur aide technique ou leurs encouragements, à l'aboutissement réussi de ce travail.

Table des matières

Liste des figures vii

Liste des tableaux ix

LISTE DES ABRÉVIATIONS x

Introduction générale 2

Chapitre 1 : Contexte général et Cyber Threat Intelligence 4

1 Introduction . . . 5
2 Présentation de l'organisme d'accueil . . . 5
2.1 Présentation de l'entreprise IRS Technologie . . . 5
2.2 Domaines d'expertise . . . 5
2.3 Services et activités . . . 6
2.4 Fiche technique de l'organisme . . . 7
3 Contexte du projet . . . 7
4 Évolution du paysage des cybermenaces . . . 8
4.1 Sophistication et industrialisation des cybermenaces . . . 8
4.2 Expansion de la surface d'attaque . . . 10
4.3 Limites des mécanismes défensifs traditionnels . . . 10
5 Concepts et principes fondamentaux de la CTI . . . 11
5.1 Définition de la CTI . . . 11
5.2 Principes et objectifs de la CTI . . . 12
5.3 Sources du renseignement cyber . . . 13
5.4 Exploitation des signaux faibles . . . 14
5.5 Apport de l'intelligence artificielle à la CTI . . . 14
6 Cycle de vie du renseignement CTI . . . 15
7 Étude des plateformes CTI existantes . . . 17
7.1 Plateformes CTI open source . . . 17
7.1.1 MISP . . . 17
7.1.2 OpenCTI . . . 17
7.2 Plateformes CTI commerciales . . . 18
7.2.1 Recorded Future . . . 18
7.2.2 Mandiant Advantage . . . 18
7.2.3 CrowdStrike Falcon Intelligence . . . 19
7.3 Analyse comparative des plateformes CTI . . . 19
7.4 Limites des plateformes CTI existantes . . . 20
8 Solution proposée : plateforme ONYX . . . 20
8.1 Objectifs du projet . . . 20
8.2 Écosystème fonctionnel de la plateforme ONYX . . . 21

9 Conclusion 23

Chapitre 2 : Analyse des Besoins et Conception Architecturale 24
1 Introduction 25
2 Analyse des Besoins 25
2.1 Besoins fonctionnels 25
2.2 Besoins non fonctionnels 26
3 Modélisation fonctionnelle 27
4 Choix technologiques 32
4.1 Nécessité du traitement automatique du langage naturel 32
4.2 Choix du modèle d'analyse sémantique : SciBERT 33
4.3 Choix d'une architecture de stockage polyglotte 34
5 Architecture fonctionnelle de la plateforme ONYX 35
5.1 Vue d'ensemble de l'architecture 35
5.2 Module de collecte et d'ingestion des données 36
5.3 Module d'analyse et d'orchestration 37
5.4 Module de stockage et indexation 38
5.5 Module de restitution et d'interopérabilité 40
5.5.1 Interface utilisateur et visualisation 40
5.5.2 Exportation vers les systèmes partenaires 41
6 Modèle de Sécurité 41
6.1 Authentification et contrôle d'accès 42
6.2 Journalisation et auditabilité 43
6.3 Sécurisation des APIs 43
6.4 Sécurité de la collecte sur le Dark Web 44
7 Conclusion 45

Chapitre 3 : Implémentation et Réalisation de la Plateforme 46
1 Introduction 48
2 Environnement technologique et pile logicielle 48
2.1 Architecture backend et orchestration 49
2.2 Pipeline de collecte et analyse sémantique 50
2.3 Architecture de persistance 50
2.4 Interface applicative et visualisation 51
2.5 Sécurité, interopérabilité et déploiement 51
3 Implémentation du pipeline de collecte et de normalisation 52
3.1 Architecture générale du pipeline ETL 52
3.2 Collecte des sources ouvertes 53
3.3 Collecte des sources du Dark Web 55
3.4 Prétraitement, déduplication et normalisation STIX 56
4 Implémentation du moteur d'analyse et de corrélation 57
4.1 Extraction des IoCs et analyse sémantique 57
4.2 Scoring, priorisation et cycle de vie des IoCs 59
4.3 Génération de règles de détection et assistance conversationnelle 59
5 Architecture de stockage et indexation 60
5.1 Stockage relationnel et documentaire 60
5.2 Modélisation des relations avec Neo4j 60
5.3 Recherche, indexation et orchestration asynchrone 61

6 Interface utilisateur et visualisation analytique . . . 62
6.1 Tableau de bord analytique . . . 62
6.2 Exploration relationnelle via le graphe de menaces . . . 63
6.3 Communication continue et diffusion des événements . . . 63
7 Interopérabilité et intégration externe . . . 65
7.1 Diffusion des renseignements vers les plateformes externes . . . 65
7.2 APIs REST et GraphQL . . . 66
8 Conclusion . . . 67

Chapitre 4 : Déploiement et Validation Opérationnelle 68
Introduction . . . 69
1 Cycle de traitement des données . . . 69
1.1 Initialisation de l'infrastructure et mécanismes de secours . . . 69
1.2 Supervision de la Collecte et Télémétrie OSINT . . . 70
1.3 Diffusion et gestion de la fraîcheur des indicateurs . . . 71
2 Restitution analytique et exploitation opérationnelle . . . 72
2.1 Indicateurs globaux et évaluation du risque . . . 72
2.2 Profilage stratégique et cartographie sectorielle . . . 73
2.3 Investigation granulaire : explorateur d'indicateurs . . . 74
2.4 Modélisation topologique : graphe de menaces . . . 75
2.5 Projection tactique : matrice MITRE ATT&CK . . . 76
2.6 Analyse sémantique et explicabilité IA . . . 77
2.7 Interopérabilité et génération de rapports automatisés . . . 79
3 Évaluation de la Résilience Architecturale . . . 80
4 Synthèse de la validation . . . 82
Conclusion . . . 83

Conclusion générale 84

Bibliographie 85

ANNEXES 89
Annexe A : Code source de l'implémentation (Chapitre 3) . . . 89
A.0.1 Module de collecte et d'anonymisation . . . 89
A.0.2 Module de prétraitement et de déduplication . . . 91
A.0.3 Normalisation et structuration STIX 2.1 . . . 92
A.0.4 Génération automatique de règles de détection . . . 93
A.0.5 Corrélation des entités dans Neo4j . . . 93
A.0.6 Interface d'interopérabilité GraphQL . . . 94

Liste des figures

1.1 Logo d'IRS Technologie 5
1.2 Services proposés par IRS Technologie 6
1.3 Évolution et structuration du paysage des cybermenaces 8
1.4 Les trois niveaux du renseignement sur les cybermenaces 12
1.5 Cycle de vie itératif du renseignement CTI 16
1.6 Écosystème fonctionnel de la plateforme ONYX 22

2.1 Diagramme des cas d'utilisation de la plateforme ONYX 28
2.2 Séquence : acquisition et normalisation des données 29
2.3 Séquence : analyse NLP et enrichissement sémantique 30
2.4 Séquence : exportation STIX/TAXII 31
2.5 Séquence : recherche sémantique et vectorielle 32
2.6 Vue d'ensemble de l'architecture fonctionnelle de la plateforme ONYX 35
2.7 Module de collecte et flux d'ingestion des données 36
2.8 Module d'analyse sémantique et d'orchestration des traitements 37
2.9 Architecture de stockage et d'indexation 39
2.10 Tableau de bord et fonctions de visualisation 40
2.11 Mécanismes d'interopérabilité et exportation 41
2.12 Authentification JWT et contrôle d'accès RBAC 42

3.1 Pipeline ETL vers le standard STIX 2.1 53
3.2 Architecture asynchrone basée sur Twisted Reactor 54
3.3 Pipeline d'extraction, nettoyage et refangage 56
3.4 Persistance polymorphe des objets STIX 2.1 dans MongoDB 57
3.5 Vectorisation sémantique avec SciBERT 58
3.6 Traversée des relations dans Neo4j 61
3.7 Tableau de bord analytique de la plateforme ONYX 62
3.8 Mécanisme de communication continue et diffusion des événements 64
3.9 Architecture asynchrone avec Redis et Celery 66

4.1 Supervision en temps réel des agents de collecte. 70
4.2 Télémétrie des sources OSINT et flux de signaux en direct. 71
4.3 Tableau de bord principal et évaluation du score de risque. 72
4.4 Vue opérationnelle et cartographie globale des incidents. 73
4.5 Profilage des acteurs et répartition sectorielle des menaces. 73
4.6 Fiche de renseignement détaillée de l'acteur APT28. 74
4.7 Explorateur d'indicateurs de compromission (IoC). 75
4.8 Visualisation topologique du graphe de menaces. 76
4.9 Matrice MITRE ATT&CK interactive en mode heatmap. 77
4.10 Assistant conversationnel ONYX Copilot. 78
4.11 Laboratoire IA : moteur SciBERT et génération de règles de détection. 79

4.12 Laboratoire d'explicabilité IA (phase de détection). 79
4.13 Module d'exportation de rapports et gestion STIX/TLP. 80
4.14 Mécanisme de dégradation gracieuse 81

Liste des tableaux

1.1 Fiche technique de l'organisme 7
1.2 Analyse comparative des principales plateformes CTI 19

3.1 Principales technologies utilisées dans la plateforme ONYX 49

LISTE DES ABRÉVIATIONS

Abréviation	Désignation et signification
APT	*Advanced Persistent Threat* — Menace persistante avancée, désignant un acteur étatique ou para-étatique menant des intrusions longues et ciblées.
ASGI	*Asynchronous Server Gateway Interface* — Interface serveur passerelle asynchrone.
BLUF	*Bottom Line Up Front* — Doctrine de rédaction synthétique à destination exécutive, plaçant la conclusion opérationnelle en tête de document.
CERT	*Computer Emergency Response Team* — Équipe de réponse aux urgences informatiques.
CTI	*Cyber Threat Intelligence* — Renseignement sur les cybermenaces : processus de collecte, d'analyse et de diffusion d'informations structurées sur les adversaires et leurs modes opératoires.
ETL	*Extract, Transform, Load* — Pipeline d'extraction, de transformation et de chargement des données.
IOC	*Indicator of Compromise* — Indicateur de compromission : artefact technique attestant d'une activité malveillante.
JWT	*JSON Web Token* — Jeton d'authentification cryptographiquement signé au format JSON.
MISP	*Malware Information Sharing Platform* — Plateforme open source de partage de renseignement sur les menaces et les indicateurs de compromission.
MITRE	Organisation américaine de recherche et de développement, à l'origine du référentiel ATT&CK.

Suite à la page suivante...

Tableau 1 – suite de la page précédente

Abréviation	Désignation et signification
NER	*Named Entity Recognition* — Reconnaissance d'entités nommées : tâche NLP d'identification automatique des entités dans un texte.
NLP	*Natural Language Processing* — Traitement automatique du langage naturel.
NoSQL	*Not Only SQL* — Famille de systèmes de bases de données non relationnels.
OSINT	*Open Source Intelligence* — Renseignement collecté à partir de sources ouvertes et accessibles publiquement.
RaaS	*Ransomware as a Service* — Modèle économique cybercriminel dans lequel un rançongiciel est loué à des affiliés en échange d'une commission.
RAG	*Retrieval-Augmented Generation* — Architecture de génération augmentée par récupération documentaire.
RBAC	*Role-Based Access Control* — Contrôle d'accès basé sur les rôles.
REST	*Representational State Transfer* — Style d'architecture pour la conception d'API web sans état.
RGPD	Règlement Général sur la Protection des Données — Cadre juridique européen régissant le traitement des données à caractère personnel.
SIEM	*Security Information and Event Management* — Gestion des informations et des événements de sécurité.
SOC	*Security Operations Center* — Centre opérationnel de sécurité.
SOAR	*Security Orchestration, Automation and Response* — Orchestration et automatisation de la réponse aux incidents de sécurité.

Suite à la page suivante...

Tableau 1 – suite de la page précédente

Abréviation	Désignation et signification
SSE	*Server-Sent Events* — Mécanisme de diffusion unidirectionnelle d'événements du serveur vers le client.
STIX	*Structured Threat Information eXpression* — Standard ouvert d'échange et de représentation du renseignement cyber.
TAXII	*Trusted Automated eXchange of Intelligence Information* — Protocole de transport pour le partage automatisé du renseignement CTI au format STIX.
TLP	*Traffic Light Protocol* — Protocole de classification définissant les conditions de diffusion du renseignement.
TTP	*Tactics, Techniques and Procedures* — Tactiques, techniques et procédures d'attaque.

Introduction générale

La transformation numérique des organisations s'accompagne d'une augmentation continue des cybermenaces. Les systèmes d'information sont aujourd'hui fortement interconnectés et exposés à des attaques de plus en plus sophistiquées, capables de compromettre des données sensibles, de perturber les activités opérationnelles ou de porter atteinte à la réputation des entreprises. Dans ce contexte, la cybersécurité constitue un enjeu majeur pour les organisations publiques et privées.

Face à cette évolution, les approches traditionnelles basées uniquement sur la détection et la réaction aux incidents montrent certaines limites. Les équipes de sécurité doivent désormais être capables d'identifier les menaces et de disposer d'une meilleure visibilité sur les activités malveillantes. Cette nécessité a favorisé l'émergence du domaine de la *Cyber Threat Intelligence* (CTI), qui vise à collecter, analyser et exploiter des informations relatives aux menaces afin d'améliorer la prise de décision et la posture de défense des organisations.

Pour répondre à ces besoins, plusieurs plateformes CTI ont été développées au cours des dernières années. Des solutions telles que MISP, OpenCTI ou encore certaines plateformes commerciales permettent de centraliser et de partager des renseignements sur les cybermenaces. Elles offrent des fonctionnalités de collecte, de structuration et de diffusion de l'information destinées aux équipes de cybersécurité.

Cependant, certaines limitations subsistent, notamment en matière d'automatisation de l'analyse, de contextualisation des informations, d'exploitation des données non structurées ou encore de collecte continue provenant de sources variées. Ces contraintes peuvent réduire l'efficacité opérationnelle des analystes et compliquer la transformation des données brutes en renseignements directement exploitables.

C'est dans ce contexte que s'inscrit le présent projet, réalisé au sein d'**IRS Technologie**.

L'objectif est de concevoir une plateforme de Cyber Threat Intelligence capable de collecter, analyser, structurer et valoriser automatiquement des informations issues de sources hétérogènes. La solution proposée, nommée **ONYX CTI**, vise à fournir un environnement intégré permettant d'améliorer l'exploitation du renseignement cyber et d'assister les équipes de sécurité dans leurs activités de veille, d'investigation et de détection.

Ce mémoire est organisé en quatre chapitres :

— **Chapitre 1 : Contexte général, Cyber Threat Intelligence et étude de l'existant** présente le cadre du projet ainsi que les principales notions de la CTI et les solutions existantes.

— **Chapitre 2 : Analyse des besoins et conception de la plateforme ONYX** décrit les besoins du projet, les objectifs visés et l'architecture proposée.

— **Chapitre 3 : Architecture technique et implémentation de la plateforme ONYX** détaille les choix techniques retenus et la mise en œuvre des différents modules.

— **Chapitre 4 : Déploiement, validation et exploitation opérationnelle** présente le fonctionnement de la plateforme ainsi que la validation des fonctionnalités développées.

Chapitre

1 Contexte général et Cyber Threat Intelligence

Sommaire

1 Introduction **5**
2 Présentation de l'organisme d'accueil **5**
2.1 Présentation de l'entreprise IRS Technologie 5
2.2 Domaines d'expertise 5
2.3 Services et activités 6
2.4 Fiche technique de l'organisme 7
3 Contexte du projet **7**
4 Évolution du paysage des cybermenaces **8**
4.1 Sophistication et industrialisation des cybermenaces 8
4.2 Expansion de la surface d'attaque 10
4.3 Limites des mécanismes défensifs traditionnels 10
5 Concepts et principes fondamentaux de la CTI **11**
5.1 Définition de la CTI 11
5.2 Principes et objectifs de la CTI 12
5.3 Sources du renseignement cyber 13
5.4 Exploitation des signaux faibles 14
5.5 Apport de l'intelligence artificielle à la CTI 14
6 Cycle de vie du renseignement CTI **15**
7 Étude des plateformes CTI existantes **17**
7.1 Plateformes CTI open source 17
7.2 Plateformes CTI commerciales 18
7.3 Analyse comparative des plateformes CTI 19
7.4 Limites des plateformes CTI existantes 20
8 Solution proposée : plateforme ONYX **20**
8.1 Objectifs du projet 20
8.2 Écosystème fonctionnel de la plateforme ONYX 21
9 Conclusion **23**

1 Introduction

Ce chapitre présente le contexte général du projet ONYX. Nous commençons par présenter l'organisme d'accueil ainsi que l'environnement dans lequel le projet a été réalisé. Ensuite, nous étudions l'évolution des cybermenaces et les limites des approches de sécurité traditionnelles, avant d'introduire les principes du renseignement sur les cybermenaces (CTI). Nous analysons également les principales plateformes CTI existantes afin d'identifier leurs points forts et leurs limites. Enfin, nous présentons la solution proposée ONYX, ses objectifs ainsi que les principales idées sur lesquelles repose la plateforme.

2 Présentation de l'organisme d'accueil

2.1 Présentation de l'entreprise IRS Technologie

IRS Technologie est une entreprise tunisienne fondée en 1995, dont le siège social est établi à Sfax. Elle est spécialisée dans la fourniture de services informatiques professionnels, avec une orientation stratégique marquée vers la cybersécurité, les systèmes d'information et les infrastructures réseau. Forte de trois décennies d'expérience, l'entreprise accompagne ses clients dans leur transformation numérique tout en assurant la protection de leurs ressources critiques.

Figure 1.1 – Logo d'IRS Technologie

2.2 Domaines d'expertise

IRS Technologie intervient dans plusieurs domaines complémentaires de l'ingénierie informatique :

— **Intégration réseau** : conception et déploiement d'infrastructures réseau sécurisées et performantes, adaptées aux exigences opérationnelles des organisations.

— **Maintenance informatique** : interventions préventives et curatives sur les équipements, garantissant la continuité des systèmes en exploitation.

— **Sécurité des systèmes d'information** : réalisation d'audits de sécurité, conseil stratégique et mise en œuvre de solutions de protection adaptées aux menaces actuelles.

— **Virtualisation et cloud** : déploiement de serveurs virtuels et accompagnement à la migration vers des environnements cloud maîtrisés.

— **Support technique** : assistance continue et interventions rapides, à distance ou sur site, pour assurer la disponibilité des systèmes.

2.3 Services et activités

L'offre de services d'IRS Technologie couvre l'ensemble du cycle de vie des infrastructures informatiques :

— Installation de systèmes informatiques et de réseaux.

— Déploiement de solutions de sécurité, incluant pare-feux, antivirus et outils de surveillance réseau.

— Surveillance et gestion de la performance des équipements.

— Assistance technique à distance ou sur site.

— Mise en conformité avec les normes de sécurité en vigueur, notamment ISO 27001 [47] et le RGPD [46].

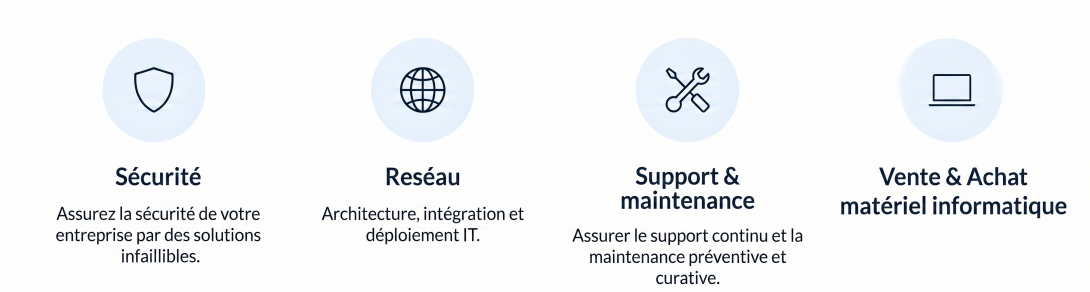

Figure 1.2 – Services proposés par IRS Technologie

2.4 Fiche technique de l'organisme

Le tableau suivant regroupe les informations de référence de l'entreprise, permettant une identification rapide de ses coordonnées et de son positionnement professionnel.

Tableau 1.1 – Fiche technique de l'organisme

Spécifications de l'Organisme d'Accueil	
Nom de l'organisme	IRS Technologie
Date de création	1995
Téléphone	+216 74 277 338
Adresse sociale	Sfax 3000 — Av. H. Bourguiba, IMM Taktak 71
Adresse web	https://www.irstechnologie.com
Adresse e-mail	support@irstechnologie.com

En résumé, IRS Technologie s'affirme comme un acteur de référence dans le domaine des services informatiques en Tunisie, proposant une offre complète en matière de maintenance, d'infrastructure réseau et de cybersécurité, au service des entreprises de toutes tailles. C'est dans ce cadre professionnel que s'inscrit le présent projet, qui répond à un besoin concret identifié dans l'écosystème de la défense cybernétique.

3 Contexte du projet

La transformation numérique et l'interconnexion croissante des systèmes d'information ont favorisé l'émergence de cybermenaces toujours plus nombreuses et plus sophistiquées. Les attaques actuelles sont menées par des acteurs organisés qui disposent d'outils avancés leur permettant d'agir rapidement, discrètement et à grande échelle. Dans ce contexte, la simple détection des incidents ne suffit plus ; les organisations doivent être capables d'anticiper les menaces avant qu'elles ne produisent des impacts significatifs.

Face à cette évolution, les approches de sécurité traditionnelles, principalement réactives, montrent leurs limites. Les équipes de cybersécurité doivent analyser un volume croissant de données provenant de sources variées, tout en identifiant les informations réellement pertinentes pour la défense de leur organisation.

Le renseignement sur les cybermenaces (*Cyber Threat Intelligence (CTI)*) répond à ce besoin

en permettant de collecter, d'analyser et de contextualiser les informations relatives aux menaces. En transformant des données brutes et hétérogènes en renseignements exploitables, la CTI aide les analystes à mieux comprendre les modes opératoires des attaquants, à détecter les signaux précurseurs d'une attaque et à améliorer les capacités de prévention et de réponse.

C'est dans cette perspective que s'inscrit le projet ONYX, dont l'objectif est de concevoir une plateforme souveraine de Cyber Threat Intelligence capable d'automatiser la collecte, l'analyse et la corrélation des renseignements issus de multiples sources, afin de fournir aux équipes de défense une vision plus complète et plus proactive des menaces.

4 Évolution du paysage des cybermenaces

La Figure 1.3 illustre l'évolution de la cybercriminalité vers un modèle plus structuré et professionnalisé, ayant favorisé l'apparition de nouvelles formes d'attaques telles que les APT, les rançongiciels en tant que service (RaaS), les attaques par la chaîne d'approvisionnement et l'automatisation offensive basée sur l'intelligence artificielle.

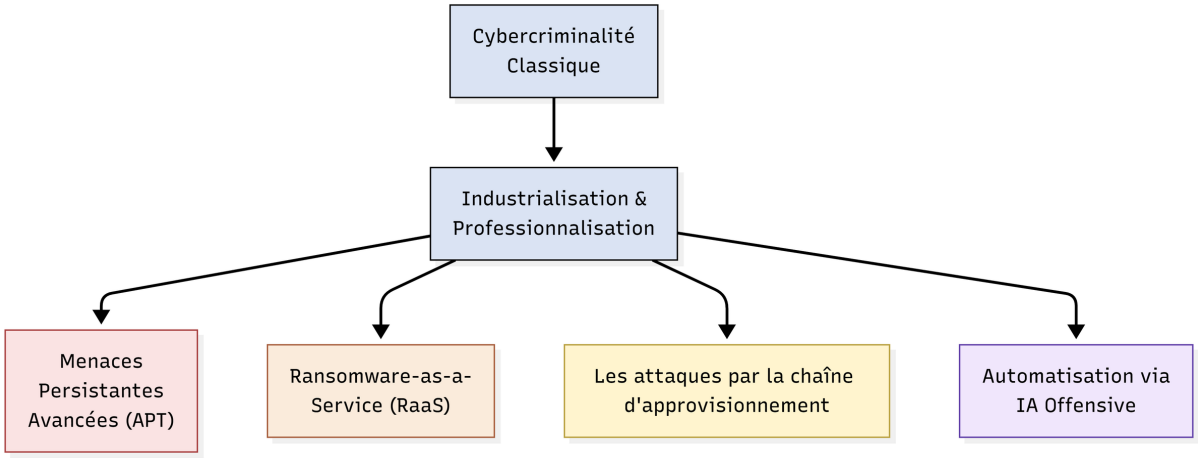

Figure 1.3 – Évolution et structuration du paysage des cybermenaces

4.1 Sophistication et industrialisation des cybermenaces

Les cybermenaces deviennent de plus en plus sophistiquées, automatisées et difficiles à détecter. Elles ne sont plus uniquement le fait d'individus isolés, mais sont souvent menées par des groupes organisés disposant de ressources techniques et financières importantes.

Parallèlement, la cybercriminalité s'est progressivement structurée en un véritable écosystème où les rôles sont répartis entre différents acteurs. Certains développent des logiciels malveillants, d'autres fournissent des accès compromis, tandis que d'autres se spécialisent dans l'extorsion ou la revente de données volées. Cette organisation favorise l'industrialisation des attaques et augmente leur efficacité.

Parmi les principales formes de menaces observées aujourd'hui, on distingue :

— **Les menaces persistantes avancées (APT)** : campagnes d'attaque sophistiquées visant à maintenir un accès durable à des systèmes critiques à des fins d'espionnage, de sabotage ou de vol d'informations.

— **Le rançongiciel en tant que service (RaaS)** : modèle permettant à des affiliés d'utiliser des outils de rançongiciel développés par d'autres groupes en échange d'un partage des profits.

— **Les attaques par la chaîne d'approvisionnement** : compromission d'un fournisseur ou d'un composant tiers afin d'atteindre indirectement la cible principale.

— **L'intelligence artificielle offensive** : utilisation de techniques d'automatisation et d'intelligence artificielle pour accélérer les attaques et contourner les mécanismes de défense.

— **Les services cybercriminels et marchés clandestins** : plateformes permettant l'échange d'outils d'attaque, d'accès compromis et de données volées, contribuant à la diffusion des cyberattaques à grande échelle.

Cette évolution renforce les capacités opérationnelles des attaquants et complique la détection précoce des menaces. Les organisations doivent donc adopter des mécanismes de défense plus proactifs, capables d'anticiper les attaques et d'exploiter efficacement le renseignement sur les cybermenaces.

4.2 Expansion de la surface d'attaque

L'environnement numérique des organisations a fortement évolué au cours des dernières années. L'essor du cloud, du télétravail et des services connectés a progressivement élargi la surface d'attaque et rendu les systèmes d'information plus exposés aux menaces.

Chaque application accessible, service en ligne ou terminal distant constitue désormais un point d'entrée potentiel pour un attaquant. Cette situation complique la surveillance des infrastructures et réduit la visibilité des équipes de sécurité.

— **La diversification des points d'accès** : les données transitent aujourd'hui entre des postes distants, des services cloud, des équipements mobiles et des infrastructures industrielles connectées. Cette distribution des ressources augmente le nombre de vecteurs d'attaque exploitables.

— **Les environnements hybrides et distribués** : la coexistence d'infrastructures locales, cloud et multi-cloud crée des architectures hétérogènes difficiles à superviser de manière unifiée. Cette complexité favorise l'apparition d'angles morts exploitables par les attaquants.

Cette évolution accroît considérablement la difficulté de détection des activités malveillantes et réduit l'efficacité des mécanismes défensifs traditionnels fondés sur une surveillance périmétrique statique.

4.3 Limites des mécanismes défensifs traditionnels

Les mécanismes de défense traditionnels reposent principalement sur une approche réactive : les actions de protection sont déclenchées après la détection d'une activité malveillante ou après la compromission d'un système. Cette approche a longtemps été suffisante pour faire face à des menaces relativement simples, mais elle montre aujourd'hui ses limites face à des attaques de plus en plus sophistiquées, rapides et automatisées.

Malgré le déploiement de solutions telles que les antivirus, les pare-feux, les IDS ou les SIEM, de nombreuses attaques parviennent encore à contourner les mécanismes de protection et

à rester actives pendant une période parfois importante avant d'être détectées. Ce délai offre aux attaquants l'opportunité d'explorer le système ciblé, d'étendre leurs privilèges, de compromettre de nouvelles ressources ou d'exfiltrer des informations sensibles.

Par ailleurs, le volume croissant des alertes générées par les outils de sécurité complique le travail des analystes. Ces derniers doivent traiter un grand nombre d'événements, dont une partie importante correspond à des faux positifs. Cette surcharge peut ralentir l'identification des incidents les plus critiques et retarder la mise en œuvre des mesures de réponse.

Face à ces limites, les organisations doivent compléter les mécanismes de détection classiques par des approches plus proactives. L'objectif n'est plus seulement de réagir aux attaques lorsqu'elles se produisent, mais également d'anticiper les menaces, d'identifier les signaux précurseurs et de produire un renseignement exploitable permettant de renforcer la posture de sécurité avant qu'une compromission ne survienne.

5 Concepts et principes fondamentaux de la CTI

Face à l'évolution des cybermenaces et aux limites des approches purement réactives, les organisations doivent renforcer leur capacité à anticiper les attaques et à comprendre les activités des acteurs malveillants. Dans ce contexte, la CTI s'est imposée comme une composante essentielle des stratégies modernes de cybersécurité.

5.1 Définition de la CTI

La Cyber Threat Intelligence (CTI), ou renseignement sur les cybermenaces, désigne le processus de collecte, d'analyse et d'exploitation des informations relatives aux menaces cybernétiques. Son objectif est de transformer des données brutes provenant de sources variées en renseignements exploitables permettant de soutenir la prise de décision en matière de sécurité.

La CTI contribue à mieux comprendre les techniques utilisées par les attaquants, à identifier les menaces émergentes et à améliorer les capacités de détection, de prévention et de réponse aux incidents. Elle permet ainsi aux équipes de cybersécurité de disposer d'une vision plus complète

et contextualisée des risques auxquels leur organisation est exposée.

5.2 Principes et objectifs de la CTI

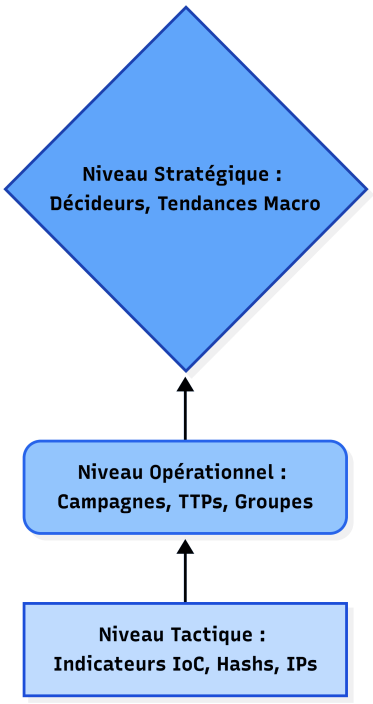

FIGURE 1.4 – Les trois niveaux du renseignement sur les cybermenaces

Afin de répondre aux besoins des différents acteurs de la cybersécurité, la CTI est généralement structurée selon trois niveaux complémentaires, illustrés par la Figure 1.4 et basés sur l'approche de la *Pyramid of Pain* [49].

Le niveau *tactique* se concentre sur les indicateurs techniques directement exploitables, tels que les adresses IP malveillantes, les hashs de fichiers suspects ou les noms de domaine compromis. Ces éléments sont principalement utilisés par les outils de détection et les équipes SOC.

Le niveau *opérationnel* s'intéresse aux campagnes d'attaque, aux techniques employées par les groupes malveillants ainsi qu'à leurs modes opératoires. Il permet de mieux comprendre le comportement des attaquants et de suivre l'évolution des menaces dans le temps.

Enfin, le niveau *stratégique* fournit une vision globale des tendances de la menace, des risques émergents et des impacts potentiels sur l'organisation. Ce niveau aide les responsables de sécurité à orienter les décisions de gouvernance et de gestion des risques.

L'objectif principal de la CTI est de fournir le bon renseignement, au bon moment et au bon niveau décisionnel, afin de soutenir les activités de prévention, de détection et de réponse aux incidents.

5.3 Sources du renseignement cyber

La CTI s'appuie sur plusieurs sources complémentaires afin d'obtenir une vision plus précise des activités malveillantes. Ces sources permettent de collecter des informations techniques, comportementales et contextuelles sur les cybermenaces. Leur croisement améliore la fiabilité des analyses et facilite l'identification précoce des attaques émergentes.

— **OSINT (Open Source Intelligence)** : collecte d'informations accessibles publiquement à partir des blogs spécialisés, des rapports de sécurité, des réseaux sociaux ou des bases de données ouvertes. Ces sources fournissent un contexte important sur les menaces et les vulnérabilités connues.

— **Threat Feeds** : flux continus d'indicateurs de compromission et de renseignements techniques fournis par des plateformes spécialisées. Ces données sont généralement transmises dans des formats standardisés facilitant leur intégration et leur traitement automatisé.

— **Dark Web** : surveillance des forums clandestins, des marchés illicites et des services cachés utilisés par les cybercriminels pour échanger des outils, préparer des campagnes malveillantes ou publier des données volées. Ces espaces représentent une source importante de signaux faibles et d'indicateurs précurseurs.

La diversité et l'hétérogénéité de ces sources rendent nécessaire la mise en place de mécanismes automatisés capables de collecter, corréler et analyser de grandes quantités de données.

5.4 Exploitation des signaux faibles

L'un des objectifs de la Cyber Threat Intelligence est d'identifier les menaces avant qu'elles ne se traduisent par des incidents de sécurité. Pour cela, elle s'appuie sur l'exploitation des **signaux faibles**, c'est-à-dire des indices pouvant révéler l'émergence d'une activité malveillante.

Ces signaux peuvent provenir de sources variées telles que les forums clandestins, les marchés illicites, les blogs spécialisés ou les canaux de communication utilisés par les groupes cybercriminels. Bien que souvent peu significatifs pris isolément, leur corrélation peut mettre en évidence la préparation d'une attaque ou l'apparition d'une nouvelle menace. L'identification de ces signaux nécessite des mécanismes automatisés de collecte et d'analyse capables de traiter un volume important de données hétérogènes.

L'exploitation des signaux faibles permet ainsi d'améliorer les capacités d'anticipation et de renforcer une approche proactive de la cybersécurité.

5.5 Apport de l'intelligence artificielle à la CTI

L'augmentation du volume et de l'hétérogénéité des données de sécurité rend difficile leur exploitation manuelle par les analystes. Dans ce contexte, l'intelligence artificielle constitue un levier important pour automatiser l'analyse des informations collectées, accélérer la détection des menaces et améliorer les capacités de corrélation.

— **Traitement du langage naturel (NLP)** : permet d'analyser automatiquement des textes non structurés issus des rapports de menaces, des blogs spécialisés ou des forums clandestins.

— **Reconnaissance d'entités nommées (NER)** : technique utilisée pour extraire automatiquement des informations importantes, telles que les adresses IP malveillantes, les groupes d'attaque, les logiciels malveillants ou les techniques MITRE ATT&CK associées [3].

— **Scoring intelligent** : mécanisme permettant d'évaluer automatiquement la criticité d'une menace selon plusieurs paramètres, notamment la fiabilité de la source, le contexte et le

niveau de confiance de l'analyse.

— **Assistant conversationnel** : interface permettant aux analystes d'interroger la base de connaissances CTI en langage naturel afin d'accéder rapidement aux informations pertinentes et de faciliter les investigations.

L'intégration de ces mécanismes d'intelligence artificielle permet ainsi de réduire la charge opérationnelle des analystes, d'améliorer la capacité de corrélation des données et d'accélérer la prise de décision face aux menaces émergentes.

6 Cycle de vie du renseignement CTI

La CTI repose sur un processus continu visant à transformer des données brutes provenant de sources variées en renseignements exploitables par les équipes de cybersécurité. Ce cycle permet de collecter, analyser et diffuser des informations pertinentes afin de renforcer les capacités de prévention, de détection et de réponse aux menaces.

Le cycle de vie du renseignement CTI s'articule généralement autour des étapes suivantes :

— **Collecte** : acquisition de données issues de sources diverses telles que les plateformes OSINT, les bases de vulnérabilités, les flux de renseignement et les sources du Web ou du Dark Web.

— **Préparation et normalisation** : nettoyage, structuration et mise en forme des données afin de faciliter leur exploitation.

— **Analyse et enrichissement** : extraction des informations pertinentes, identification des indicateurs de compromission et mise en contexte des menaces observées.

— **Évaluation et priorisation** : estimation de la criticité des menaces selon leur impact potentiel, leur contexte et la fiabilité des sources.

— **Diffusion du renseignement** : partage des résultats avec les analystes, les équipes SOC et les outils de sécurité afin de soutenir les activités de défense.

— **Retour d'expérience** : prise en compte des résultats des investigations et des incidents observés afin d'améliorer continuellement la qualité du renseignement produit.

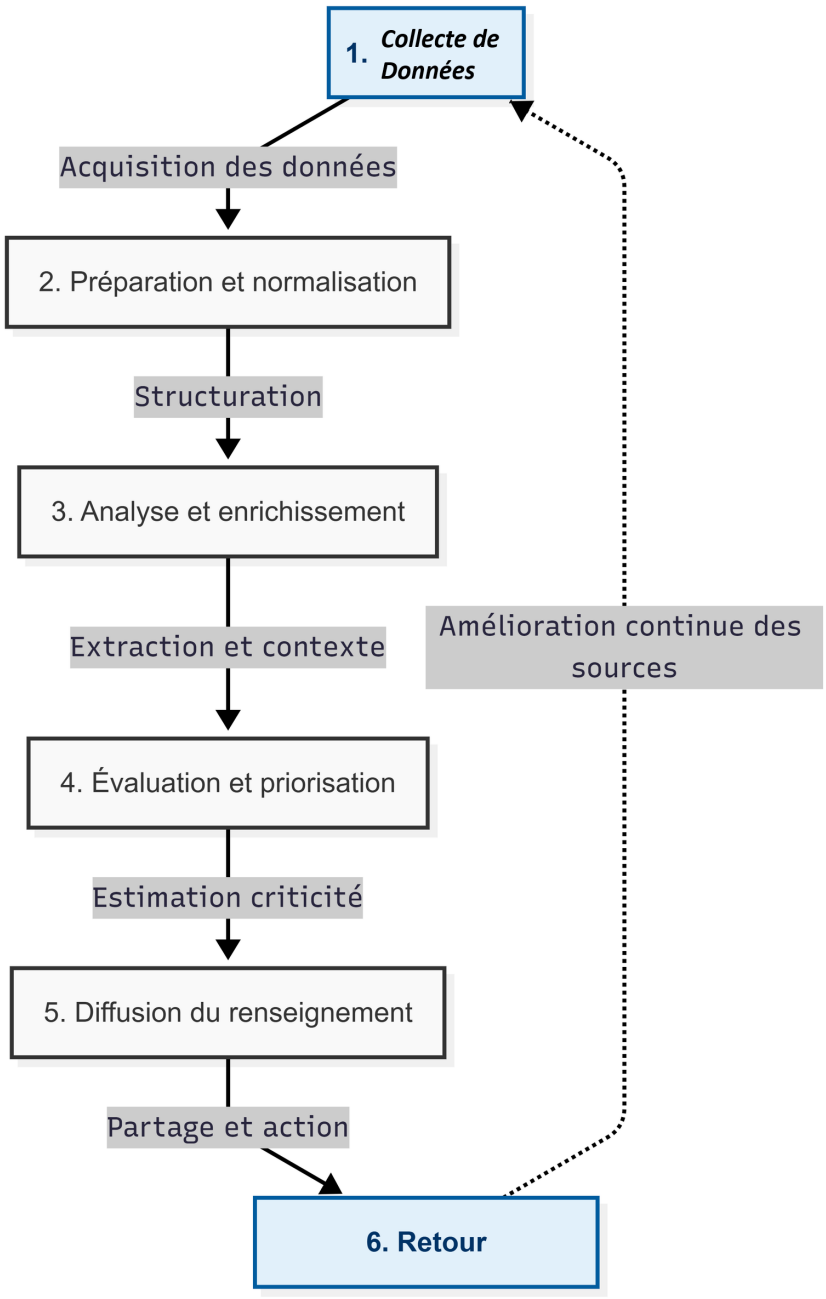

Figure 1.5 – Cycle de vie itératif du renseignement CTI

Ce cycle permet ainsi de transformer des données hétérogènes en renseignements contextualisés et directement exploitables. Les plateformes CTI modernes cherchent à automatiser une partie de ces étapes afin d'accélérer la production du renseignement et de réduire la charge opérationnelle des analystes.

7 Étude des plateformes CTI existantes

Dans cette section, nous analysons les principales plateformes CTI selon plusieurs critères : les capacités d'analyse automatisée, le niveau d'interopérabilité, la souveraineté des données, ainsi que les mécanismes de collecte et de corrélation du renseignement.

7.1 Plateformes CTI open source

Les plateformes CTI open source occupent une place importante dans l'écosystème du renseignement sur les cybermenaces. Elles offrent des mécanismes de partage, de structuration et de corrélation des informations tout en garantissant une maîtrise locale des données et une forte interopérabilité avec les standards ouverts. Parmi les solutions les plus répandues figurent notamment MISP [11] et OpenCTI [12].

7.1.1 MISP

MISP (*Malware Information Sharing Platform*) est l'une des plateformes les plus utilisées pour le partage collaboratif d'indicateurs de compromission (IoC). Développée par le CERT gouvernemental luxembourgeois, elle bénéficie d'une large adoption au sein des communautés de cybersécurité [11].

La plateforme propose de nombreuses taxonomies, mécanismes de classification et formats d'échange normalisés. Elle assure notamment une interopérabilité native avec les standards **STIX/TAXII** [1, 2], facilitant l'échange automatisé du renseignement avec d'autres plateformes et outils de sécurité.

Malgré ces avantages, MISP reste principalement orientée vers la gestion et le partage d'IoC. Ses capacités de corrélation avancée, d'analyse automatisée et de visualisation des menaces demeurent relativement limitées.

7.1.2 OpenCTI

OpenCTI, développée sous l'impulsion de l'ANSSI et du CERT-EU, adopte une approche orientée graphe pour la structuration du renseignement sur les menaces [12]. Basée sur le

standard STIX 2.1 [1], la plateforme permet de modéliser les relations entre différentes entités telles que les campagnes d'attaque, les groupes adverses, les vulnérabilités et les techniques utilisées.

Les informations sont modélisées sous forme de graphe de connaissances, facilitant l'analyse des relations entre les acteurs, les campagnes, les vulnérabilités et les techniques d'attaque. La plateforme intègre également le référentiel **MITRE ATT&CK** [3], largement utilisé pour la classification et la contextualisation des activités malveillantes.

Cependant, OpenCTI présente une architecture relativement complexe à déployer et à maintenir. De plus, les mécanismes d'analyse avancée et la collecte proactive sur le Dark Web reposent principalement sur des connecteurs externes.

7.2 Plateformes CTI commerciales

Les plateformes CTI commerciales proposent généralement des fonctionnalités avancées de collecte, de corrélation et d'analyse des menaces. Parmi les solutions les plus reconnues figurent Recorded Future [13], Mandiant Advantage [14] et CrowdStrike Falcon Intelligence [15].

7.2.1 Recorded Future

Recorded Future est une plateforme spécialisée dans l'agrégation et la corrélation automatisée de renseignements issus de sources ouvertes, techniques et clandestines [13]. Elle se distingue notamment par ses mécanismes de scoring des menaces et de contextualisation des indicateurs de compromission.

7.2.2 Mandiant Advantage

Mandiant Advantage s'appuie sur l'expertise de Mandiant en réponse aux incidents et en investigation numérique [14]. La plateforme fournit une veille mondiale sur les groupes d'attaquants, les campagnes malveillantes et les techniques émergentes, tout en facilitant les activités de *threat hunting*.

7.2.3 CrowdStrike Falcon Intelligence

CrowdStrike Falcon Intelligence combine les capacités de renseignement sur les menaces avec les mécanismes de détection et de réponse de l'écosystème CrowdStrike [15]. Son approche privilégie l'analyse comportementale et l'intégration étroite avec les solutions EDR (*Endpoint Detection and Response* — Détection et réponse sur les postes de travail).

Malgré leurs capacités avancées, ces plateformes présentent certaines limites. Leurs mécanismes d'analyse et de corrélation reposent généralement sur des technologies propriétaires dont le fonctionnement reste peu transparent. Elles dépendent également d'infrastructures cloud externes, ce qui peut soulever des problématiques de souveraineté et de maîtrise des données sensibles. Enfin, leurs coûts de licence et les possibilités limitées de personnalisation peuvent constituer un frein pour certaines organisations.

7.3 Analyse comparative des plateformes CTI

Le Tableau 1.2 met en évidence les principales caractéristiques des plateformes CTI étudiées selon plusieurs critères fonctionnels et architecturaux, notamment les capacités d'analyse automatisée, les mécanismes de collecte, la modélisation du renseignement, la souveraineté des données ainsi que l'interopérabilité avec les standards du domaine.

Cette analyse montre que les solutions existantes offrent des capacités complémentaires, mais présentent encore certaines limites en matière d'automatisation analytique, de maîtrise des données sensibles ou de collecte proactive sur les sources profondes d'Internet.

Tableau 1.2 – Analyse comparative des principales plateformes CTI

Critère	**MISP**	**OpenCTI**	**Solutions commerciales**
Analyse automatisée	Limitée	Partiellement automatisée	Avancée mais majoritairement propriétaire
Maîtrise des données	Déploiement local	Déploiement local	Dépendance fréquente aux infrastructures cloud
Modélisation des menaces	Gestion principalement centrée sur les IoC	Graphe basé sur STIX 2.1	Modèles propriétaires selon l'éditeur
Acquisition dynamique	Flux externes	Connecteurs externes	Collecte multi-sources intégrée
Interopérabilité	Forte	Forte	Variable selon les solutions

7.4 Limites des plateformes CTI existantes

L'étude des principales plateformes CTI met en évidence un compromis récurrent entre capacités analytiques, souveraineté des données et flexibilité d'intégration. Les solutions open source offrent une bonne maîtrise des données et une forte interopérabilité, mais disposent généralement de mécanismes limités d'automatisation et d'analyse avancée. À l'inverse, les solutions commerciales proposent des fonctionnalités évoluées de corrélation, de priorisation et d'enrichissement des menaces, mais reposent souvent sur des technologies propriétaires et des infrastructures externes.

Par ailleurs, la collecte proactive de renseignements à partir de sources non conventionnelles, notamment le Dark Web, reste partiellement couverte par la plupart des plateformes étudiées. Les capacités d'analyse contextuelle, de corrélation multi-sources et de production automatisée de renseignement demeurent également limitées ou dépendantes de services complémentaires.

Ces limites montrent qu'aucune solution ne répond pleinement à l'ensemble des besoins identifiés. Elles justifient la conception d'une plateforme capable de combiner collecte proactive, analyse automatisée, souveraineté des données et interopérabilité au sein d'une architecture unifiée et maîtrisée.

8 Solution proposée : plateforme ONYX

Afin de répondre aux besoins identifiés précédemment, nous proposons ONYX, une plateforme de Cyber Threat Intelligence conçue pour automatiser la collecte, l'analyse et l'exploitation du renseignement sur les cybermenaces. La plateforme vise à transformer des données hétérogènes en informations contextualisées et exploitables par les équipes de cybersécurité.

8.1 Objectifs du projet

L'objectif principal de ce projet est de concevoir une plateforme de Cyber Threat Intelligence capable de transformer des données issues de sources hétérogènes en renseignements structurés,

contextualisés et directement exploitables par les équipes de cybersécurité.

Pour atteindre cet objectif, la plateforme ONYX vise à :

— automatiser la collecte de données provenant de sources ouvertes, institutionnelles et du Dark Web ;

— structurer et normaliser les informations collectées afin de garantir leur cohérence et leur exploitabilité ;

— enrichir et contextualiser les données grâce à des mécanismes d'analyse sémantique et de corrélation ;

— assister les analystes dans l'identification, la priorisation et l'investigation des menaces ;

— faciliter le partage et l'intégration du renseignement avec les plateformes et outils de sécurité existants.

8.2 Écosystème fonctionnel de la plateforme ONYX

ONYX est conçue comme une plateforme intégrée permettant d'automatiser les principales étapes du cycle de vie du renseignement sur les cybermenaces. Elle centralise la collecte, l'analyse, la corrélation et le partage des informations issues de sources multiples afin de fournir un renseignement exploitable aux équipes de cybersécurité.

La plateforme favorise une approche proactive en combinant des mécanismes de collecte de données, d'analyse intelligente et de diffusion du renseignement. Elle a également été conçue pour garantir la maîtrise des données sensibles et assurer son intégration avec les écosystèmes CTI et les outils de sécurité existants.

La Figure 1.6 présente l'écosystème fonctionnel de la plateforme ONYX ainsi que les principaux acteurs qui interagissent avec elle.

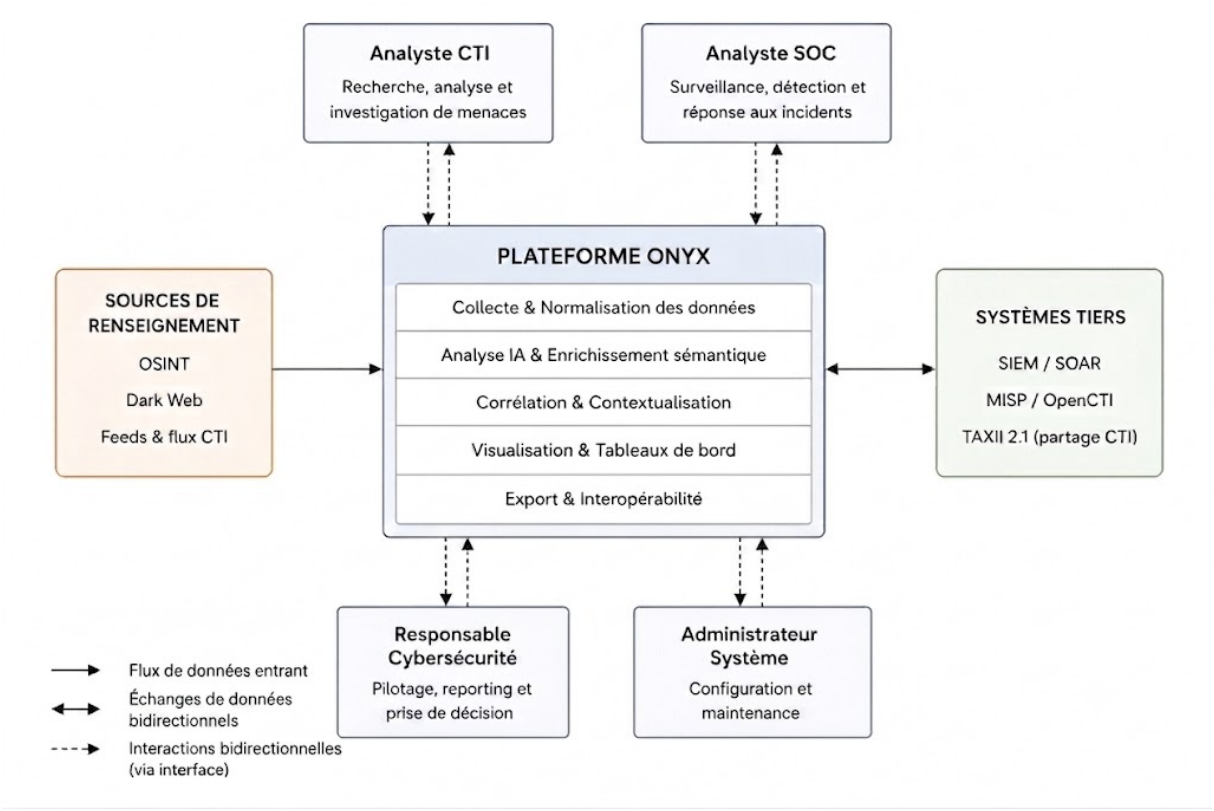

FIGURE 1.6 – Écosystème fonctionnel de la plateforme ONYX

La plateforme interagit avec plusieurs catégories d'acteurs humains et systèmes externes :

— **Analyste CTI** : analyse et contextualise les renseignements sur les menaces afin d'anticiper les campagnes d'attaque et de produire des rapports de cyberveille.

— **Analyste SOC** : exploite les informations fournies par la plateforme pour qualifier les alertes et les incidents de sécurité.

— **Responsable cybersécurité** : utilise les tableaux de bord et les rapports afin d'orienter les décisions liées à la gestion des risques.

— **Administrateur système** : assure le déploiement, la configuration et la supervision de la plateforme.

— **Sources de renseignement** : regroupent les flux OSINT, les sources institutionnelles, les *threat feeds* ainsi que les sources issues du Web et du Dark Web.

— **Plateformes tierces (SIEM, SOAR, MISP, OpenCTI)** : échangent des indicateurs et des renseignements avec ONYX afin de faciliter leur exploitation opérationnelle.

Pour répondre aux besoins des différents acteurs, ONYX s'appuie sur une architecture fonctionnelle organisée autour de plusieurs modules complémentaires. La plateforme assure l'acquisition des données provenant de sources ouvertes, du Web, du Dark Web et des flux CTI, puis leur intégration au sein d'un pipeline de traitement automatisé.

Les données collectées sont ensuite analysées et enrichies par le moteur central de la plateforme, qui assure leur traitement, leur corrélation et leur contextualisation afin de produire un renseignement exploitable. Les informations générées sont stockées et indexées dans une couche de persistance dédiée, permettant leur conservation, leur recherche et leur exploitation ultérieure.

Les résultats sont ensuite restitués aux utilisateurs à travers des tableaux de bord, des outils de visualisation et des interfaces d'investigation. Enfin, la plateforme intègre des mécanismes d'interopérabilité facilitant le partage automatisé du renseignement avec les plateformes CTI et les outils de sécurité partenaires.

L'ensemble de ces composants forme une chaîne CTI cohérente permettant de transformer des données brutes en renseignements contextualisés et directement exploitables par les équipes de cybersécurité.

9 Conclusion

Dans ce chapitre, nous avons présenté l'évolution du paysage des cybermenaces ainsi que les concepts fondamentaux de la Cyber Threat Intelligence. L'étude des solutions CTI existantes a mis en évidence plusieurs limites liées à l'automatisation, à la souveraineté des données et à la collecte proactive des renseignements. Ces constats ont conduit à la proposition de la plateforme ONYX, conçue comme une solution CTI souveraine, modulaire et orientée automatisation. Le chapitre suivant sera consacré à l'analyse des besoins et à la conception architecturale de la plateforme.

Chapitre

2 Analyse des Besoins et Conception Architecturale

Sommaire

1 Introduction **25**
2 Analyse des Besoins **25**
2.1 Besoins fonctionnels 25
2.2 Besoins non fonctionnels 26
3 Modélisation fonctionnelle **27**
4 Choix technologiques **32**
4.1 Nécessité du traitement automatique du langage naturel 32
4.2 Choix du modèle d'analyse sémantique : SciBERT 33
4.3 Choix d'une architecture de stockage polyglotte 34
5 Architecture fonctionnelle de la plateforme ONYX **35**
5.1 Vue d'ensemble de l'architecture 35
5.2 Module de collecte et d'ingestion des données 36
5.3 Module d'analyse et d'orchestration 37
5.4 Module de stockage et indexation 38
5.5 Module de restitution et d'interopérabilité 40
6 Modèle de Sécurité **41**
6.1 Authentification et contrôle d'accès 42
6.2 Journalisation et auditabilité 43
6.3 Sécurisation des APIs 43
6.4 Sécurité de la collecte sur le Dark Web 44
7 Conclusion **45**

1 Introduction

Ce chapitre présente l'analyse des besoins et la conception architecturale de la plateforme ONYX. À partir des limites identifiées dans l'étude de l'existant, nous définissons les exigences fonctionnelles et non fonctionnelles du système, puis nous décrivons les principaux scénarios d'utilisation ainsi que l'architecture générale de la plateforme. Nous présentons également les principaux modules fonctionnels, l'organisation du stockage des données et le modèle de sécurité adopté afin de garantir la souveraineté, l'interopérabilité et l'auditabilité du système. L'ensemble de ces éléments constitue la base conceptuelle et technique de la phase d'implémentation.

2 Analyse des Besoins

La conception de la plateforme ONYX repose sur une identification précise des besoins fonctionnels et des contraintes techniques du système. Cette analyse permet de définir les capacités attendues de la plateforme ainsi que les exigences liées à la sécurité, à la modularité, à la performance et à l'interopérabilité. Les besoins étudiés sont organisés en deux catégories complémentaires : les besoins fonctionnels, qui décrivent les services assurés par le système, et les besoins non fonctionnels, qui définissent les propriétés de qualité et les contraintes d'architecture à respecter.

2.1 Besoins fonctionnels

Les besoins fonctionnels définissent les principales capacités que la plateforme ONYX doit assurer afin de collecter, analyser et exploiter le renseignement sur les cybermenaces.

— **EF-1 Collecte multi-sources** : la plateforme doit être capable de collecter automatiquement des données issues de sources hétérogènes, telles que les flux institutionnels, les plateformes OSINT, les bases de vulnérabilités ainsi que certaines sources du Dark Web.

— **EF-2 Normalisation et structuration des données** : les informations collectées doivent

être transformées en objets structurés conformes aux standards CTI afin de garantir l'homogénéité et l'interopérabilité des données traitées.

— **EF-3 Analyse sémantique automatisée** : la plateforme doit intégrer un moteur d'analyse capable d'extraire automatiquement les entités de menace, de catégoriser les contenus et de produire des synthèses exploitables par les analystes.

— **EF-4 Scoring et priorisation des menaces** : le système doit évaluer dynamiquement la criticité des menaces en tenant compte de la fiabilité des sources, du contexte des attaques et du niveau de risque associé.

— **EF-5 Visualisation et investigation** : la plateforme doit fournir des mécanismes de visualisation permettant l'exploration des relations entre entités, l'analyse chronologique des événements et la génération de rapports de renseignement.

— **EF-6 Interopérabilité CTI** : la plateforme doit permettre l'échange bidirectionnel de renseignements avec des systèmes tiers via des API et des standards d'échange CTI reconnus.

2.2 Besoins non fonctionnels

Les besoins non fonctionnels définissent les contraintes de qualité et les principes d'architecture que la plateforme ONYX doit respecter afin de garantir sa sécurité, sa fiabilité et sa capacité d'évolution.

— **ENF-1 Maîtrise des données** : la plateforme doit pouvoir être déployée au sein d'une infrastructure entièrement contrôlée par l'organisation, sans dépendance à des services externes non maîtrisés.

— **ENF-2 Modularité et faible couplage** : l'architecture doit être organisée en modules indépendants communiquant via des interfaces clairement définies afin de faciliter la maintenance et l'évolution du système.

— **ENF-3 Scalabilité et extensibilité** : la plateforme doit pouvoir supporter une augmentation du volume de données et intégrer de nouveaux composants ou services sans remise en cause de l'architecture globale.

— **ENF-4 Sécurité intrinsèque** : le système doit intégrer nativement des mécanismes d'authentification, de contrôle d'accès, de protection des interfaces et de journalisation des activités.

— **ENF-5 Performance et disponibilité** : les opérations de collecte, d'analyse et de consultation doivent conserver des temps de réponse compatibles avec un usage opérationnel, tout en garantissant la continuité des services.

— **ENF-6 Auditabilité et traçabilité** : les traitements, les transformations de données et les résultats produits par la plateforme doivent être traçables, vérifiables et reproductibles afin d'assurer la transparence des analyses réalisées.

L'ensemble de ces exigences justifie la conception d'une architecture dédiée, capable de répondre simultanément aux contraintes de souveraineté, d'automatisation analytique et de collecte proactive identifiées dans l'étude de l'existant.

3 Modélisation fonctionnelle

La modélisation fonctionnelle permet de représenter les interactions entre les différents acteurs et la plateforme ONYX. Le diagramme de cas d'utilisation présenté dans la Figure 2.1 offre une vue globale des principales fonctionnalités du système ainsi que des opérations accessibles aux différents profils d'utilisateurs.

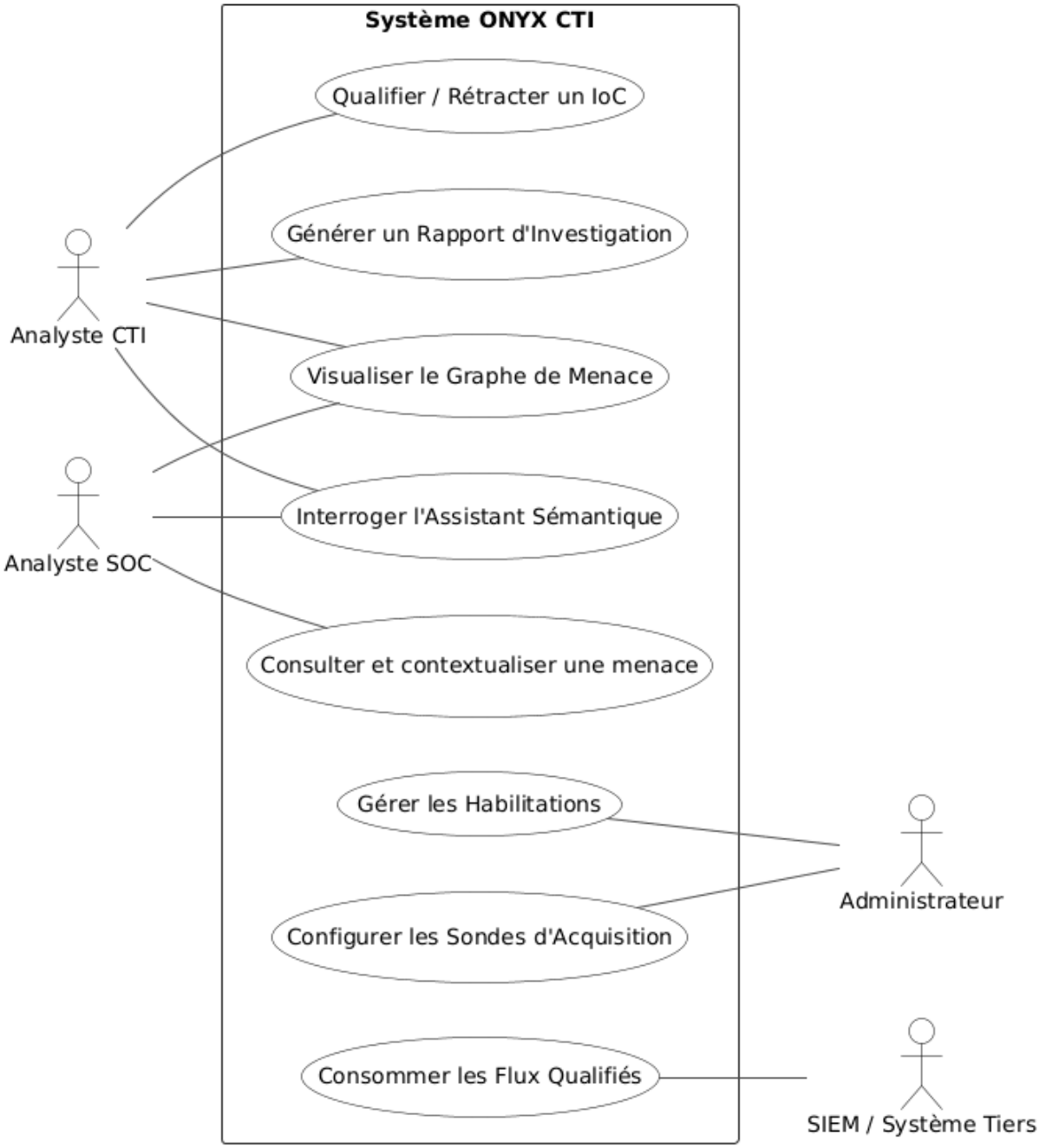

FIGURE 2.1 – Diagramme des cas d'utilisation de la plateforme ONYX

Afin de décrire le comportement dynamique du système, nous avons également modélisé plusieurs scénarios fonctionnels sous forme de diagrammes de séquence illustrant les échanges entre les acteurs et les composants de la plateforme.

Scénario 1 : Acquisition et normalisation des données

Ce scénario illustre le fonctionnement du processus de collecte et de normalisation des données au sein de la plateforme ONYX. Comme le montre la Figure 2.2, le collecteur asynchrone basé sur **Scrapy** [26] récupère les données brutes issues des sources ciblées, qu'il s'agisse du Web de surface ou du Dark Web, puis applique des opérations de prétraitement et de nettoyage avant de transmettre les données au pipeline ETL orchestré par **Celery** [25]. Ce dernier assure leur transformation et leur normalisation dans un format structuré exploitable par les composants analytiques et les mécanismes de stockage polyglotte de la plateforme.

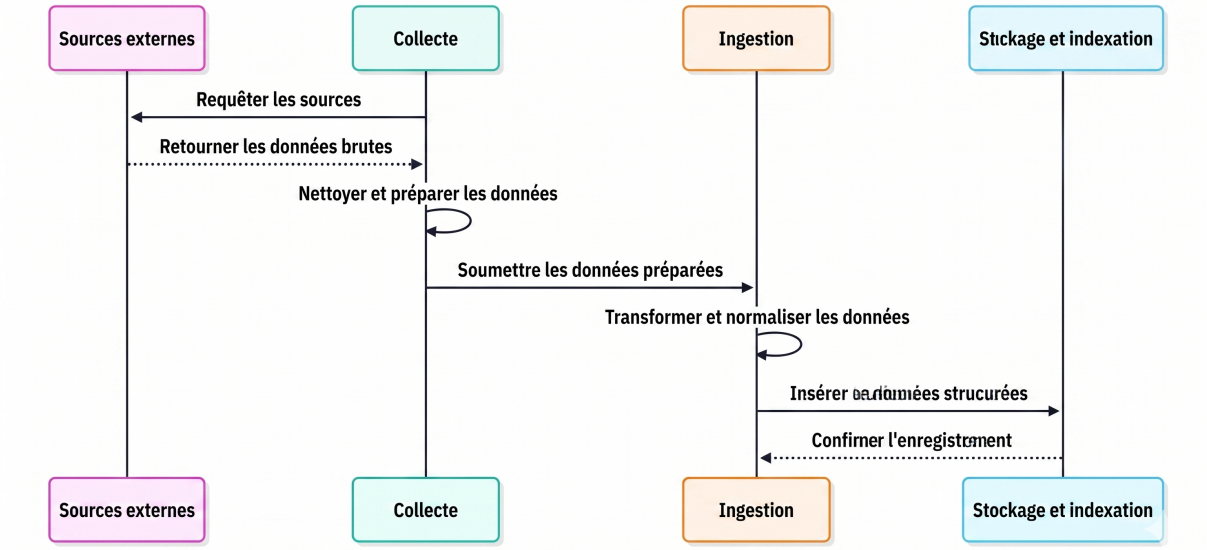

FIGURE 2.2 – Séquence : acquisition et normalisation des données

Scénario 2 : Analyse NLP et enrichissement sémantique

Une fois les données normalisées, le moteur d'analyse sémantique basé sur SciBERT [7] prend le relais. Comme l'illustre la Figure 2.3, le système analyse les contenus collectés, effectue des opérations de prétraitement et d'analyse NLP, puis extrait automatiquement les entités pertinentes telles que les acteurs malveillants, les techniques d'attaque, les outils utilisés et les indicateurs de compromission. Les informations extraites sont ensuite vectorisées et intégrées au graphe de connaissances Neo4j [31] sous forme de nœuds et de relations afin d'enrichir et de contextualiser le renseignement produit par la plateforme.

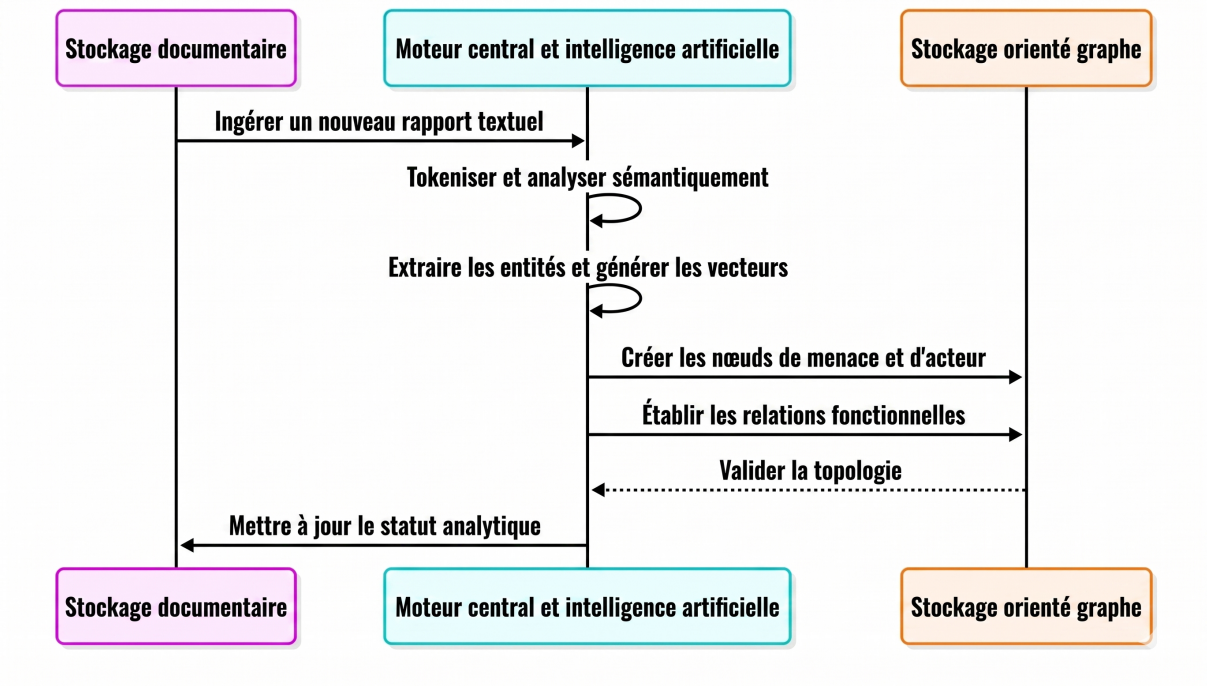

FIGURE 2.3 – Séquence : analyse NLP et enrichissement sémantique

Scénario 3 : Exportation standardisée du renseignement (STIX/TAXII)

Ce scénario illustre le processus d'exportation du renseignement entre la plateforme ONYX et les systèmes partenaires. Comme le montre la Figure 2.4, un système tiers tel qu'un **SIEM** s'authentifie auprès de l'interface de programmation ONYX via un jeton **JWT** [50] avant d'émettre une requête de récupération au module d'exportation **TAXII** [2]. La plateforme interroge alors la couche de stockage et d'indexation afin de retourner un ensemble d'indicateurs qualifiés et structurés au format **STIX 2.1** [1], prêts à être intégrés aux mécanismes de supervision, de détection et de corrélation du système partenaire.

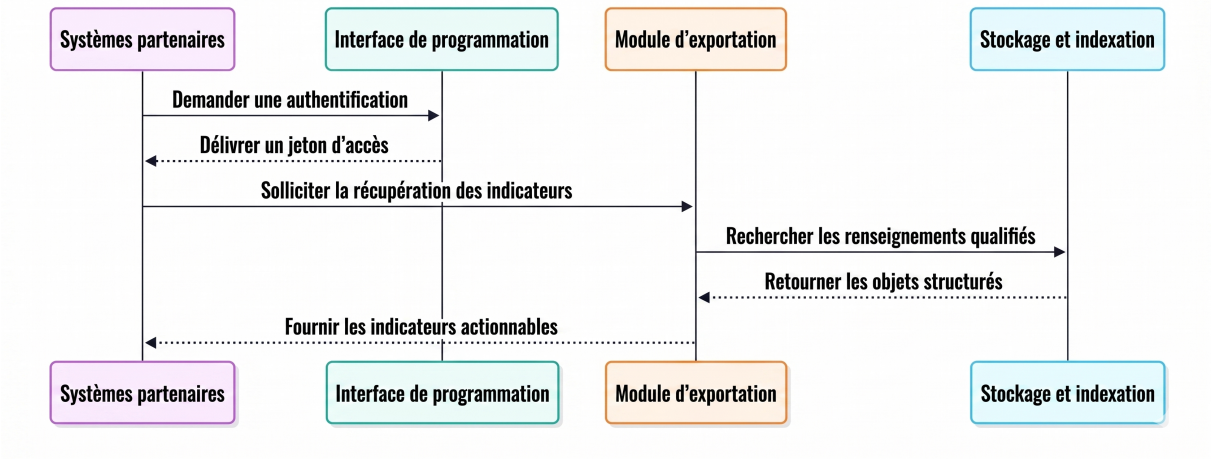

FIGURE 2.4 – Séquence : exportation STIX/TAXII

Scénario 4 : Recherche sémantique et vectorielle

Ce scénario illustre le mécanisme de recherche sémantique intégré à la plateforme ONYX. Comme le montre la Figure 2.5, l'analyste CTI soumet une requête en langage naturel ou sous forme de mots-clés via l'interface utilisateur et de visualisation. Cette requête est transmise au moteur central et d'intelligence artificielle basé sur **SciBERT** [7], qui génère une représentation vectorielle de la requête. Celle-ci est ensuite comparée aux vecteurs indexés dans la couche de stockage et d'indexation **Qdrant** [35] afin d'identifier, par recherche de similarité cosinus, les rapports et renseignements présentant la plus grande proximité sémantique avec la requête formulée.

Contrairement à une recherche textuelle classique basée uniquement sur la correspondance exacte des termes, cette approche permet de retrouver des contenus contextuellement similaires, même lorsque le vocabulaire utilisé diffère. Le système améliore ainsi l'exploration du renseignement et facilite l'identification de menaces, campagnes ou techniques d'attaque liées.

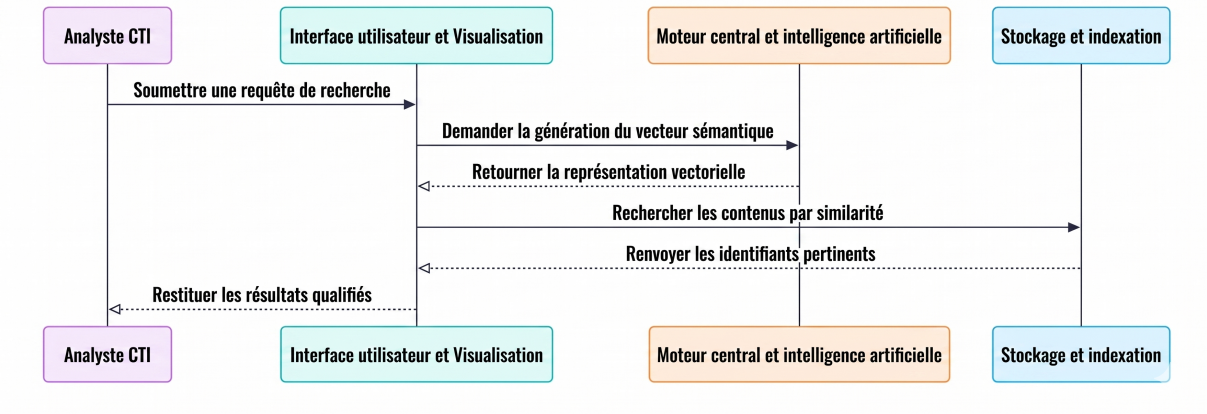

Figure 2.5 – Séquence : recherche sémantique et vectorielle

4 Choix technologiques

La conception de la plateforme ONYX repose sur plusieurs choix architecturaux et technologiques visant à répondre aux exigences fonctionnelles et non fonctionnelles identifiées précédemment. Ces choix concernent notamment les mécanismes d'analyse des données, les modèles d'intelligence artificielle utilisés ainsi que l'organisation de la couche de stockage.

Cette section présente les principales décisions de conception adoptées pour la plateforme et les motivations ayant conduit à leur sélection. L'objectif est de mettre en évidence leur contribution à la collecte, à l'analyse, à la corrélation et à l'exploitation du renseignement sur les cybermenaces.

4.1 Nécessité du traitement automatique du langage naturel

L'extraction d'indicateurs de compromission repose souvent sur des règles de détection, des expressions régulières ou des analyseurs syntaxiques. Bien que ces approches soient efficaces pour identifier des éléments techniques tels que les adresses IP, les noms de domaine ou les empreintes numériques, elles restent limitées lorsqu'il s'agit d'analyser des contenus textuels non structurés.

Les données issues du Web et du Dark Web contiennent généralement des informations rédigées sous forme de discussions, de rapports ou de publications techniques. Dans ce contexte, l'identification d'un indicateur ne suffit pas toujours : il est également nécessaire de comprendre

son rôle, son contexte d'utilisation et les relations qu'il entretient avec d'autres éléments de menace.

L'intégration de techniques de traitement automatique du langage naturel (NLP) permet ainsi d'extraire, de structurer et de contextualiser les informations pertinentes à partir de contenus textuels hétérogènes. Cette approche facilite la transformation des données brutes en renseignements exploitables et leur représentation sous des formats standardisés tels que STIX 2.1 [1].

4.2 Choix du modèle d'analyse sémantique : SciBERT

L'analyse des données collectées nécessite un modèle capable de traiter des contenus techniques, souvent non structurés et riches en terminologies spécialisées. Afin de sélectionner le modèle le plus adapté, plusieurs familles de modèles de langage ont été étudiées.

— **BERT Base** [8] : ce modèle généraliste offre de bonnes performances sur le langage courant, mais présente certaines limites pour l'analyse de textes techniques liés à la cybersécurité. Les termes spécialisés, les identifiants de vulnérabilités ou les indicateurs de compromission y sont parfois mal représentés.

— **SecBERT et CyBERT** : ces modèles sont spécifiquement orientés cybersécurité et permettent une meilleure prise en compte du vocabulaire métier. Toutefois, leur écosystème est généralement moins mature et leur intégration peut s'avérer plus complexe selon les contraintes de déploiement.

— **SciBERT** [7] : pré-entraîné sur un vaste corpus de publications scientifiques et techniques, SciBERT constitue un compromis intéressant entre spécialisation et généralisation. Il offre une bonne compréhension des textes techniques tout en conservant des performances adaptées à des tâches telles que l'extraction d'entités, la recherche sémantique et la vectorisation de documents.

Cette analyse a conduit au choix de SciBERT comme moteur d'analyse sémantique de la plateforme ONYX. Son aptitude à traiter des contenus techniques, combinée à ses capacités d'extraction et de représentation sémantique, en fait une solution adaptée aux objectifs du projet.

4.3 Choix d'une architecture de stockage polyglotte

La plateforme ONYX manipule plusieurs types de données ayant des caractéristiques très différentes. Certaines informations sont stockées sous forme de documents STIX, d'autres représentent des relations entre entités de menace, tandis que certaines nécessitent une recherche textuelle rapide ou une recherche sémantique basée sur des vecteurs. Dans ce contexte, l'utilisation d'une seule base de données aurait conduit à des compromis importants en matière de performances et de fonctionnalités.

Pour répondre à ces besoins, ONYX adopte une architecture de stockage polyglotte reposant sur plusieurs moteurs spécialisés, chacun étant utilisé pour le type de données qu'il gère le plus efficacement.

— **MongoDB** [30] est utilisé pour stocker les objets STIX et les documents de renseignement grâce à son modèle documentaire flexible.

— **Neo4j** [31] est dédié à la représentation des relations entre les entités de menace, ce qui facilite l'analyse des campagnes d'attaque et des chaînes de corrélation.

— **PostgreSQL** [34] assure la gestion des données structurées de la plateforme telles que les utilisateurs, les rôles, les configurations et les journaux d'audit.

— **Redis** [33] est utilisé comme cache et comme mécanisme de communication entre les différents services afin d'améliorer les performances globales.

— **Elasticsearch** [32] permet d'effectuer des recherches textuelles rapides au sein des rapports et des données collectées.

— **Qdrant** [35] est utilisé pour la recherche sémantique à partir des vecteurs générés par le moteur d'analyse NLP.

Ainsi, chaque moteur remplit un rôle spécifique au sein de l'architecture. Cette approche permet d'exploiter les points forts de chaque technologie tout en garantissant de bonnes performances pour les différentes fonctions de la plateforme.

5 Architecture fonctionnelle de la plateforme ONYX

Pour répondre aux exigences fonctionnelles et sécuritaires précédemment définies et justifiées, la plateforme ONYX repose sur une architecture modulaire organisée autour de plusieurs modules complémentaires. Cette organisation permet de séparer les fonctions de collecte, d'analyse, de stockage et de restitution du renseignement, tout en garantissant la flexibilité et l'évolutivité du système.

5.1 Vue d'ensemble de l'architecture

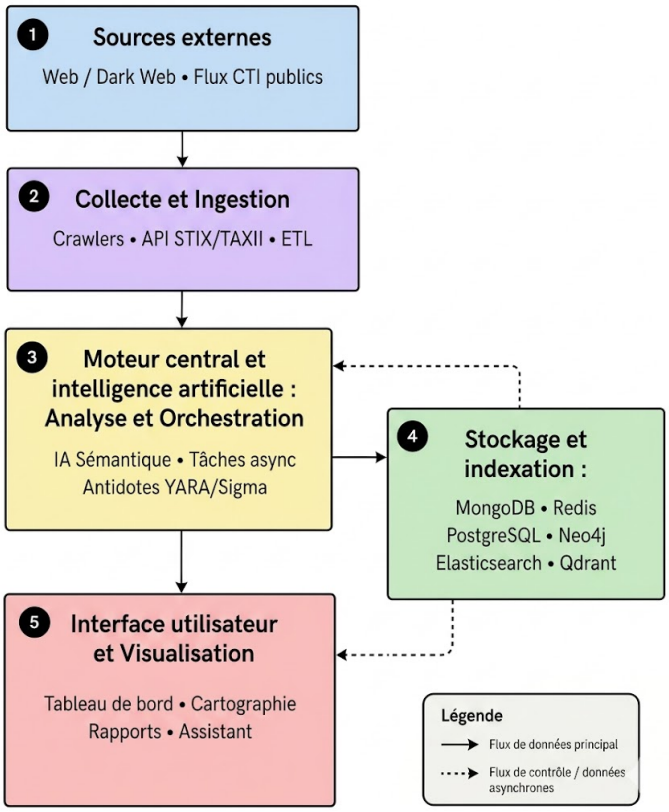

Figure 2.6 – Vue d'ensemble de l'architecture fonctionnelle de la plateforme ONYX

La Figure 2.6 présente l'architecture globale de la plateforme ONYX. Celle-ci est organisée autour de cinq modules fonctionnels complémentaires assurant la collecte, le traitement, le stockage et la restitution du renseignement sur les cybermenaces.

Le processus débute par les **sources externes** (module 1), qui regroupent les flux CTI publics, les sources du Web ainsi que les données issues du Dark Web. Ces informations sont

ensuite prises en charge par le module de **collecte et d'ingestion** (module 2), chargé de leur acquisition, de leur préparation et de leur normalisation.

Les données collectées sont ensuite transmises au **moteur d'analyse et d'orchestration** (module 3), qui assure les opérations d'analyse sémantique, d'enrichissement, de corrélation et de génération des renseignements exploitables. Les résultats produits sont stockés au sein du module de **stockage et d'indexation** (module 4), qui centralise les différentes catégories de données utilisées par la plateforme.

Enfin, les informations traitées sont restituées aux utilisateurs via le module **interface utilisateur et visualisation** (module 5), qui fournit des tableaux de bord, des outils d'investigation, des rapports et un assistant conversationnel. Cette architecture modulaire facilite l'évolution de la plateforme tout en assurant une séparation claire des responsabilités entre les différents composants.

5.2 Module de collecte et d'ingestion des données

La figure 2.7 illustre le fonctionnement global du module de collecte ainsi que les principaux flux d'ingestion alimentant la plateforme ONYX.

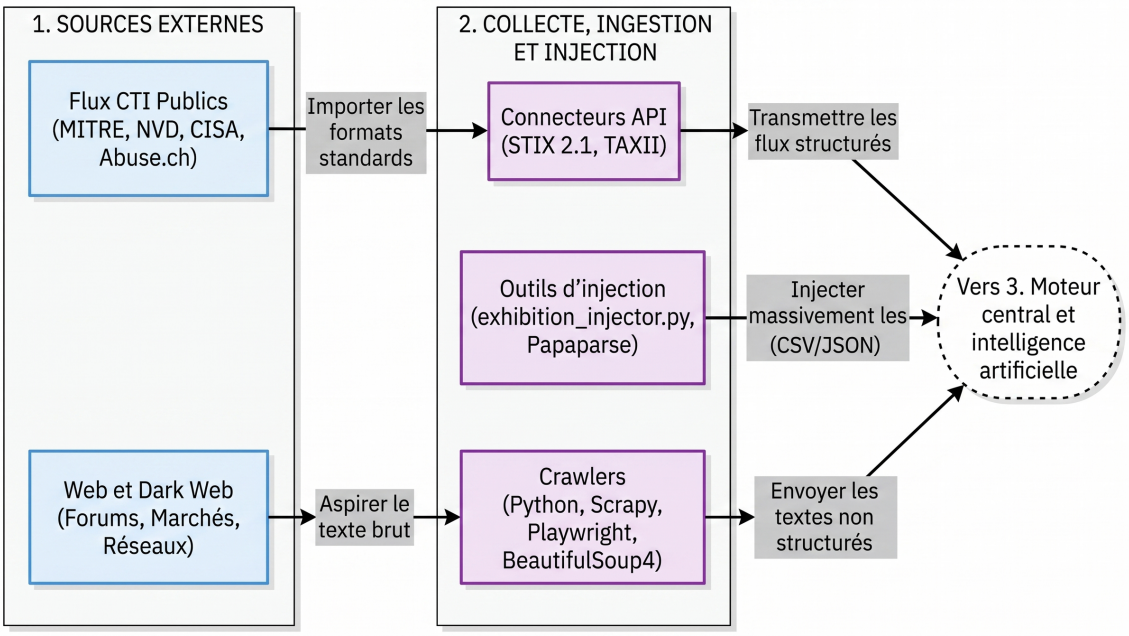

Figure 2.7 – Module de collecte et flux d'ingestion des données

Le module de collecte constitue le point d'entrée de la plateforme ONYX et assure

l'acquisition continue des données de menace provenant de sources hétérogènes.

Le premier vecteur repose sur des **sources ouvertes et institutionnelles** telles que les bases publiques de vulnérabilités, les flux CTI gouvernementaux et les registres communautaires d'indicateurs. Des connecteurs automatisés permettent d'importer ces données normalisées et de les transmettre vers la chaîne d'ingestion et de traitement.

Le second vecteur concerne les **sources profondes et clandestines**. Des agents de collecte spécialisés explorent les forums, marchés illicites et espaces de communication utilisés par les acteurs malveillants afin d'extraire des contenus textuels non structurés à forte valeur de renseignement. Des mécanismes d'isolation et d'anonymisation sont mis en œuvre afin de sécuriser les opérations de collecte.

L'ensemble des flux collectés converge ensuite vers le pipeline ETL de normalisation, chargé de structurer et préparer les données avant leur transmission au module d'analyse et d'enrichissement sémantique.

5.3 Module d'analyse et d'orchestration

La figure 2.8 présente l'organisation interne du module d'analyse ainsi que les principaux mécanismes de traitement et d'orchestration des données au sein de la plateforme ONYX.

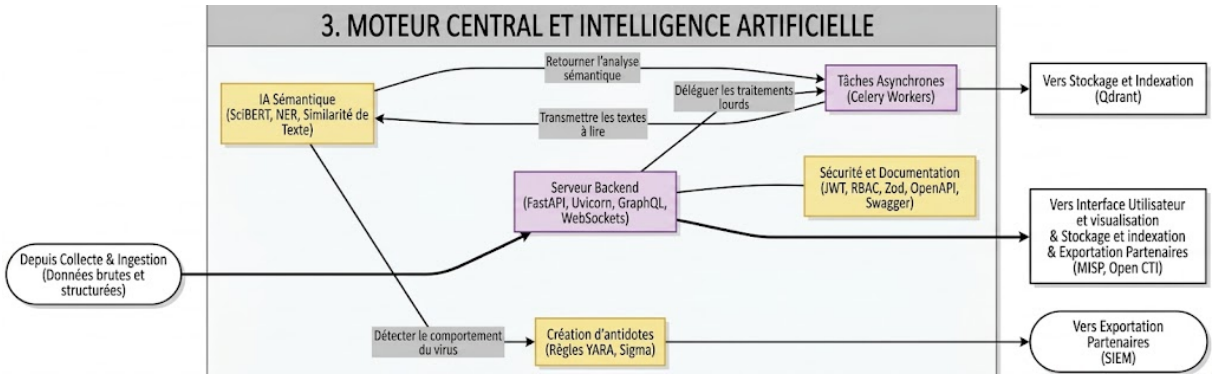

Figure 2.8 – Module d'analyse sémantique et d'orchestration des traitements

Le module d'analyse constitue le moteur cognitif de la plateforme ONYX. Il repose sur une architecture orchestrée autour d'une API centrale et de traitements asynchrones permettant d'assurer l'analyse, l'enrichissement et la coordination des flux de renseignement cyber.

La **fonction d'analyse sémantique** s'appuie sur des workers NLP basés sur SciBERT afin

de traiter les contenus textuels collectés. Le système réalise automatiquement l'extraction des entités pertinentes, la catégorisation des menaces ainsi que l'identification des relations entre acteurs, vulnérabilités, techniques d'attaque et indicateurs de compromission.

La **fonction d'orchestration asynchrone** repose sur une architecture FastAPI/Celery couplée à un broker Redis permettant de répartir et coordonner les traitements lourds de manière distribuée. Cette approche améliore la scalabilité du système et garantit un traitement fluide des tâches d'analyse et d'enrichissement.

La **fonction de priorisation et d'exploitation** permet d'évaluer la criticité des menaces analysées et de produire des renseignements exploitables par les analystes SOC et CTI. Le module peut également générer des règles de détection et transmettre les résultats vers les composants de stockage, de visualisation et d'interopérabilité de la plateforme.

5.4 Module de stockage et indexation

La Figure 2.9 présente l'organisation du module de stockage et les principaux mécanismes de persistance intégrés à la plateforme ONYX.

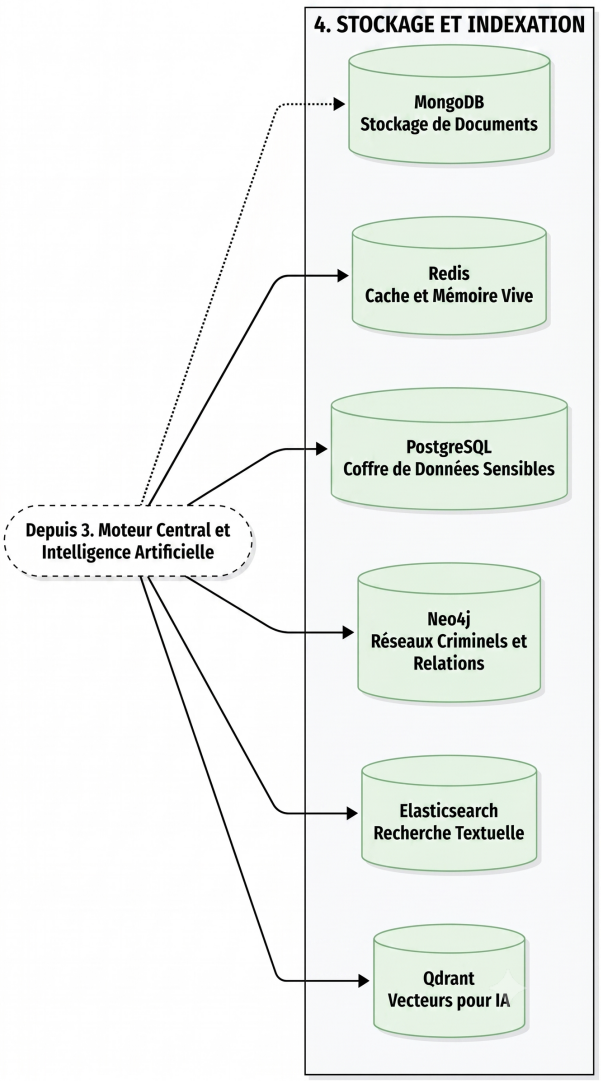

FIGURE 2.9 – Architecture de stockage et d'indexation

Le module de stockage reçoit les données produites par le moteur d'analyse et assure leur persistance, leur indexation ainsi que leur mise à disposition pour les opérations de recherche, de corrélation et de visualisation.

Afin de répondre à la diversité des données manipulées par la plateforme, cette couche repose sur une architecture de stockage polyglotte présentée dans la Section 4. Chaque catégorie de données est ainsi confiée au moteur de stockage le plus adapté à ses caractéristiques et à ses usages. Les détails des technologies utilisées ainsi que leur rôle respectif seront présentés dans le chapitre consacré à l'implémentation de la plateforme.

5.5 Module de restitution et d'interopérabilité

Le module de restitution et d'interopérabilité assure la diffusion du renseignement produit par la plateforme ONYX, aussi bien vers les analystes humains que vers les systèmes de sécurité partenaires. Il regroupe les mécanismes de visualisation, de reporting et d'échange automatisé des données de renseignement.

5.5.1 Interface utilisateur et visualisation

La figure 2.10 illustre les principaux mécanismes de restitution visuelle intégrés à la plateforme ONYX.

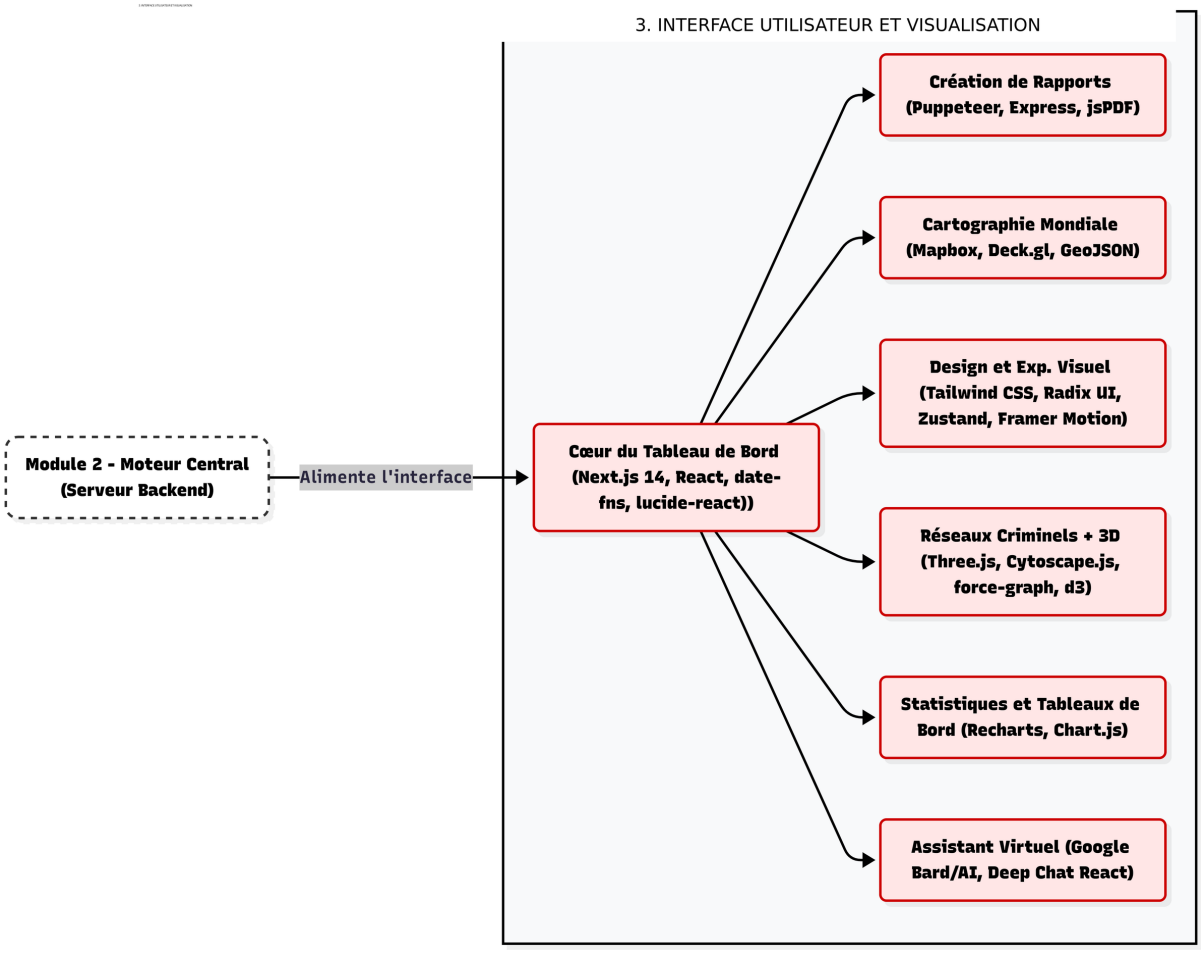

Figure 2.10 – Tableau de bord et fonctions de visualisation

L'interface utilisateur constitue le tableau de bord central de la plateforme. Elle propose plusieurs modes de visualisation complémentaires : cartographie géospatiale des menaces, représentation graphique des relations entre entités, tableaux statistiques dynamiques, génération de rapports exportables et assistant conversationnel interrogeable en langage

naturel. Ces mécanismes facilitent l'analyse des menaces et accélèrent la prise de décision des analystes.

5.5.2 Exportation vers les systèmes partenaires

La figure 2.11 présente les mécanismes d'échange et de diffusion du renseignement vers les systèmes partenaires.

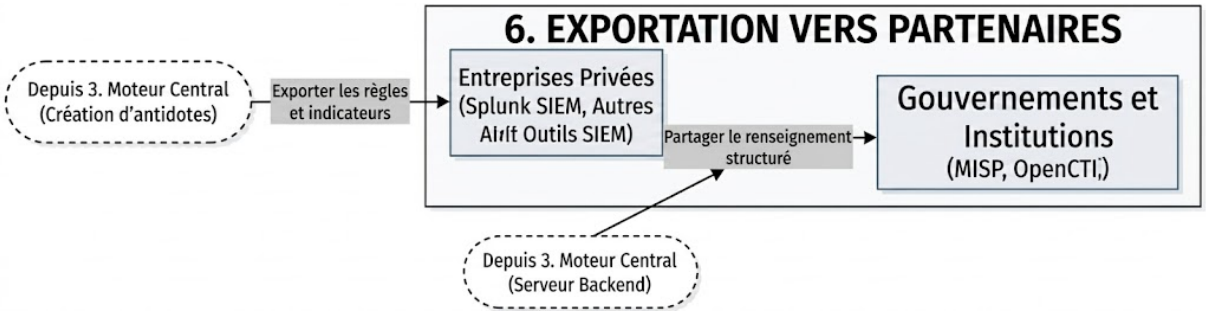

Figure 2.11 – Mécanismes d'interopérabilité et exportation

Le module d'interopérabilité permet l'exportation automatisée des indicateurs et des objets de renseignement qualifiés vers des plateformes externes. Des connecteurs spécialisés assurent l'intégration avec les systèmes SIEM, tels que Splunk, ainsi qu'avec les plateformes CTI communautaires comme MISP [11] et OpenCTI [12]. Cette interconnexion favorise le partage du renseignement et renforce les capacités de détection et de réaction des systèmes de défense.

6 Modèle de Sécurité

La nature sensible des données manipulées par la plateforme ONYX nécessite l'intégration de mécanismes de sécurité robustes à l'ensemble de l'architecture. Afin de garantir la confidentialité et le contrôle des accès, la plateforme adopte le paradigme du **Zero Trust**, selon lequel aucun utilisateur, service ou requête n'est considéré comme fiable par défaut. Chaque interaction avec le système doit ainsi faire l'objet d'une authentification et d'une vérification explicite des permissions avant l'accès aux ressources protégées.

Comme l'illustre la Figure 2.12, le modèle de sécurité de la plateforme repose sur une architecture d'authentification basée sur les jetons JWT et sur un mécanisme de contrôle d'accès RBAC. Après validation cryptographique des identifiants, le système délivre un jeton

sécurisé utilisé pour authentifier les requêtes et vérifier les droits d'accès associés aux rôles des utilisateurs et des systèmes tiers.

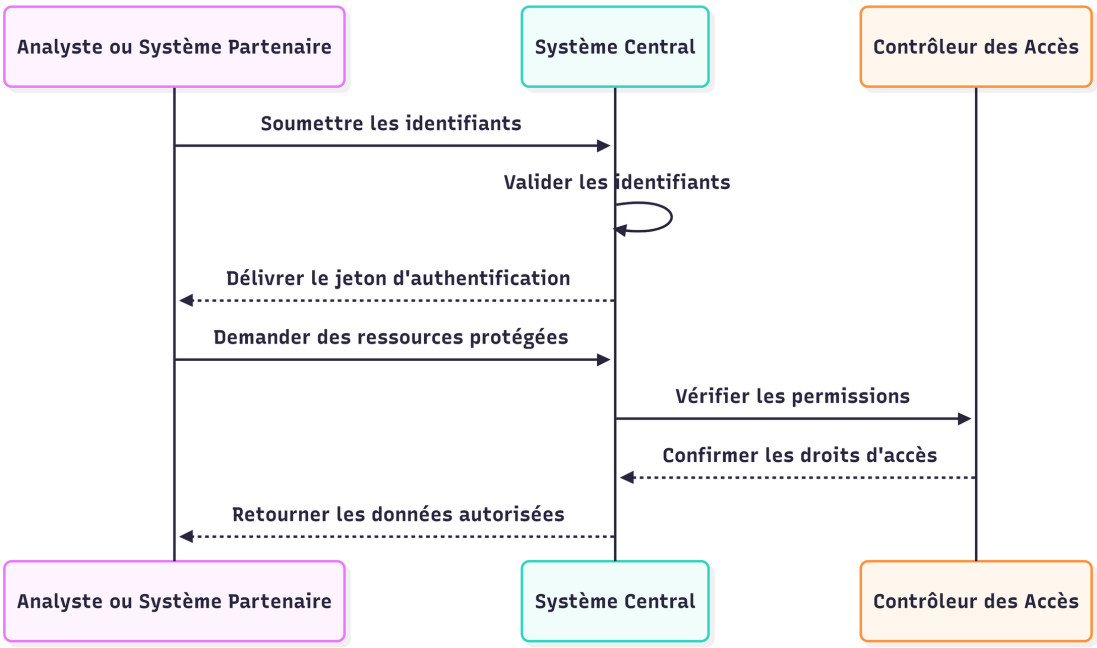

FIGURE 2.12 – Authentification JWT et contrôle d'accès RBAC

6.1 Authentification et contrôle d'accès

L'accès à la plateforme repose sur une architecture sans état (*stateless*), dans laquelle aucune session persistante n'est conservée côté serveur. La sécurisation des accès s'appuie sur deux mécanismes complémentaires : l'authentification par jetons JWT et le contrôle d'accès basé sur les rôles.

— **Authentification par jetons JWT** : toute interaction avec la plateforme, qu'elle provienne d'un utilisateur ou d'un système tiers, nécessite la présentation d'un jeton cryptographiquement signé. Ce jeton contient l'identité de l'appelant ainsi qu'une durée de validité limitée, permettant d'éviter la gestion de sessions persistantes et de réduire la surface d'attaque du système.

— **Contrôle d'accès basé sur les rôles (RBAC)** : chaque requête adressée à l'API fait l'objet d'une vérification des privilèges associés au rôle de l'utilisateur. Les opérations sensibles, telles que la configuration du système ou la suppression de données, sont

réservées aux administrateurs. Les systèmes partenaires disposent quant à eux de droits limités, conformément au principe du moindre privilège.

6.2 Journalisation et auditabilité

Afin de garantir la traçabilité des opérations et la transparence du système, l'ensemble des actions effectuées au sein de la plateforme ONYX fait l'objet d'une journalisation structurée. Ces mécanismes permettent de conserver un historique détaillé des traitements réalisés et des accès effectués.

— **Traçabilité des traitements analytiques** : chaque objet de renseignement généré conserve la référence de sa source d'origine ainsi que les métadonnées associées à son traitement. Les scores calculés par le moteur analytique score de confiance, criticité ou état de déclin sont enregistrés avec les paramètres ayant conduit à leur génération, garantissant ainsi l'auditabilité des résultats produits.

— **Journalisation des accès et des actions** : toutes les interactions avec la plateforme, notamment les requêtes API, les opérations de consultation, d'exportation ou de modification, sont enregistrées dans des journaux structurés. En cas d'incident de sécurité ou de compromission d'un compte, ces journaux permettent de reconstituer précisément la séquence des événements.

6.3 Sécurisation des APIs

La sécurisation des interfaces de programmation repose sur une approche de défense en profondeur combinant plusieurs mécanismes complémentaires destinés à protéger les échanges et les services exposés par la plateforme.

— **Chiffrement des communications** : l'ensemble des échanges, y compris les communications internes entre modules, est protégé par le protocole TLS 1.3 afin de garantir la confidentialité et l'intégrité des données transitant dans le système.

— **Validation stricte des entrées** : chaque requête reçue par l'API fait l'objet d'une

validation syntaxique et typée avant son traitement. Cette vérification permet de prévenir les principales attaques d'injection, notamment les injections SQL et NoSQL, avant qu'elles n'atteignent la logique applicative.

— **Contrôle du débit des requêtes** : des mécanismes de limitation du nombre de requêtes par unité de temps sont associés à l'authentification JWT afin de réduire les risques d'attaques par déni de service et de limiter les tentatives d'énumération automatisée des ressources exposées.

6.4 Sécurité de la collecte sur le Dark Web

La collecte de données sur les sources clandestines expose la plateforme à des risques particuliers, tels que l'identification des agents de collecte, les tentatives de contre-attaque ou l'injection de contenus malveillants. Afin de sécuriser ce processus, plusieurs mécanismes d'isolation et de compartimentation ont été intégrés à l'architecture.

— **Isolation réseau** : le module de collecte basé sur le réseau Tor [44] est déployé dans un segment réseau isolé du reste de l'infrastructure. Cette séparation limite les risques de fuite d'informations et empêche tout accès direct aux composants internes de la plateforme.

— **Conteneurisation éphémère** : chaque agent de collecte s'exécute dans un conteneur Docker [45] isolé, instancié uniquement pour la durée de la tâche puis supprimé automatiquement. Cette approche réduit les risques de persistance d'un état compromis entre deux sessions de collecte.

— **Flux unidirectionnels** : les agents de collecte communiquent uniquement vers le bus interne de traitement des données. Aucune connexion entrante depuis les sources externes vers le cœur du système n'est autorisée, limitant ainsi les risques d'intrusion par rebond.

— **Externalisation des secrets (Zero Trust)** : afin de respecter les principes d'hygiène informatique [46], aucun mot de passe ou clé cryptographique n'est inscrit en dur (hardcoded) dans le code source de la plateforme. Les identifiants sensibles, tels que le mot de passe de contrôle du réseau Tor, sont injectés dynamiquement au moment du déploiement via des variables d'environnement. Cette séparation stricte entre le code et

la configuration garantit qu'une éventuelle fuite du code source ne compromettra pas l'infrastructure.

7 Conclusion

Ce chapitre a permis de définir l'architecture fonctionnelle et technique de la plateforme ONYX ainsi que les principaux mécanismes de sécurité, de traitement et d'interopérabilité qui la composent. L'approche modulaire, les choix algorithmiques stricts (NLP et indexation vectorielle) et l'architecture polyglotte retenus offrent une infrastructure évolutive et adaptée aux exigences du renseignement cybernétique temps réel. Le chapitre suivant est consacré à l'implémentation et à la réalisation concrète des différents composants de la plateforme.

Chapitre

3 Implémentation et Réalisation de la Plateforme

Sommaire

1 Introduction **48**

2 Environnement technologique et pile logicielle **48**

2.1 Architecture backend et orchestration 49

2.2 Pipeline de collecte et analyse sémantique 50

2.3 Architecture de persistance 50

2.4 Interface applicative et visualisation 51

2.5 Sécurité, interopérabilité et déploiement 51

3 Implémentation du pipeline de collecte et de normalisation **52**

3.1 Architecture générale du pipeline ETL 52

3.2 Collecte des sources ouvertes 53

3.3 Collecte des sources du Dark Web 55

3.4 Prétraitement, déduplication et normalisation STIX 56

4 Implémentation du moteur d'analyse et de corrélation **57**

4.1 Extraction des IoCs et analyse sémantique 57

4.2 Scoring, priorisation et cycle de vie des IoCs 59

4.3 Génération de règles de détection et assistance conversationnelle . . 59

5 Architecture de stockage et indexation **60**

5.1 Stockage relationnel et documentaire 60

5.2 Modélisation des relations avec Neo4j 60

5.3 Recherche, indexation et orchestration asynchrone 61

6 Interface utilisateur et visualisation analytique **62**

6.1 Tableau de bord analytique 62

6.2 Exploration relationnelle via le graphe de menaces 63

6.3 Communication continue et diffusion des événements 63

7 Interopérabilité et intégration externe **65**

7.1 Diffusion des renseignements vers les plateformes externes 65

7.2 APIs REST et GraphQL 66

8 Conclusion **67**

1 Introduction

Le chapitre précédent a présenté les fondements conceptuels et l'architecture générale de la plateforme ONYX. Ce troisième chapitre décrit sa mise en œuvre technique ainsi que les principaux mécanismes développés pour assurer la collecte, l'analyse, le stockage et l'exploitation du renseignement cyber. Nous y présentons l'architecture technique de la plateforme, les technologies retenues, ainsi que les principaux modules implémentés : le pipeline ETL de collecte et de normalisation, le moteur d'analyse sémantique, la couche de persistance polyglotte, les mécanismes de sécurité et les interfaces d'interopérabilité.

2 Environnement technologique et pile logicielle

La plateforme ONYX repose sur une pile technologique modulaire combinant des technologies spécialisées pour la collecte, l'analyse sémantique, l'orchestration asynchrone, la persistance polyglotte et la visualisation du renseignement cyber. Le Tableau 3.1 présente les principales technologies intégrées au sein de l'architecture logicielle de la plateforme.

Tableau 3.1 – Principales technologies utilisées dans la plateforme ONYX

Domaine	Technologies	Rôle
Environnement	Ubuntu, Python, TypeScript	Système d'exploitation et langages principaux de développement.
Backend	FastAPI, Uvicorn, Celery, Redis, GraphQL	API REST et GraphQL, orchestration asynchrone et communication inter-services.
Collecte	Scrapy, Playwright, BeautifulSoup4	Collecte OSINT/Dark Web et extraction de contenus.
IA et NLP	SciBERT	Analyse sémantique et extraction d'entités.
Persistance	PostgreSQL, MongoDB, Neo4j, Elasticsearch, Qdrant, Redis	Stockage relationnel, documentaire, graphe, vectoriel et cache.
Frontend	React, Next.js, Tailwind CSS, Cytoscape.js, Three.js	Tableau de bord et visualisation interactive.
Cartographie et statistiques	Mapbox, Deck.gl, Recharts, Chart.js	Visualisation géospatiale et analytique.
Sécurité et interopérabilité	JWT, RBAC, STIX 2.1, TAXII, YARA, Sigma	Contrôle d'accès, échange CTI et règles de détection.
Développement et déploiement	Docker, Docker Compose, Git, GitHub, VS Code, Postman	Conteneurisation, gestion du code et validation des API.

2.1 Architecture backend et orchestration

La plateforme est développée et déployée sous **Ubuntu 22.04 LTS**, choisi pour sa stabilité et sa compatibilité avec les technologies de conteneurisation et d'intelligence artificielle. Le serveur applicatif et les mécanismes de traitement reposent principalement sur **Python**, utilisé pour la collecte des données, le pipeline ETL, les traitements NLP et l'automatisation. L'interface applicative est développée en **TypeScript** avec l'écosystème **Node.js**, afin de concevoir une interface utilisateur dynamique et interactive.

Le serveur applicatif repose sur **FastAPI** [24] et **Uvicorn**, utilisés pour le développement et l'exécution des API REST et GraphQL. Les interfaces **GraphQL** sont implémentées avec **Strawberry GraphQL** [29], afin de faciliter les requêtes dynamiques du tableau de bord analytique. L'exécution des traitements asynchrones est assurée par **Celery** [25], utilisé pour les tâches lourdes telles que la collecte distribuée, l'analyse NLP ou la génération automatique de règles de détection. La coordination des *workers* et la gestion des files de messages reposent

sur **Redis** [33]. La plateforme utilise également les **WebSockets** pour diffuser en temps réel les alertes et événements de sécurité vers l'interface utilisateur.

2.2 Pipeline de collecte et analyse sémantique

Le pipeline de collecte repose principalement sur **Scrapy** [26], utilisé pour l'extraction automatisée des données issues de sources ouvertes et semi-structurées. Pour les contenus dynamiques nécessitant l'exécution de scripts JavaScript, la plateforme intègre **Playwright** [27], capable de simuler un navigateur en mode non visible (*headless browsing*). L'extraction et le nettoyage des contenus HTML sont réalisés avec **BeautifulSoup4**, avant la normalisation des données dans le pipeline ETL.

Les capacités d'analyse sémantique reposent sur **SciBERT** [7], modèle NLP spécialisé dans les corpus scientifiques et techniques, utilisé pour la reconnaissance d'entités nommées (NER), l'extraction des éléments clés des rapports de menace et la vectorisation des documents. Le choix de SciBERT repose sur sa capacité à traiter un vocabulaire hautement technique, caractéristique des rapports de renseignement cyber (Threat Intelligence). SciBERT a été retenu comme moteur d'analyse sémantique de la plateforme. Il permet l'extraction d'entités, la vectorisation des documents et l'identification de relations contextuelles au sein des rapports de menace. Les représentations produites sont utilisées pour l'enrichissement du renseignement et la recherche sémantique. Ces mécanismes permettent d'identifier automatiquement les acteurs malveillants, les vulnérabilités, les techniques d'attaque et les indicateurs de compromission, transformant ainsi les données textuelles non structurées en renseignement exploitable. Les représentations vectorielles produites sont également utilisées pour la recherche sémantique et la détection de similarités entre rapports et campagnes de menace.

2.3 Architecture de persistance

La couche de persistance repose sur une architecture polyglotte combinant plusieurs systèmes de stockage spécialisés selon la nature des données manipulées. **PostgreSQL** [34] est utilisé pour les données relationnelles structurées, notamment les comptes utilisateurs, les rôles RBAC et les journaux d'audit. **MongoDB** [30] assure la persistance des rapports

de renseignement et des objets STIX à structure variable. **Neo4j** [31] permet de modéliser les relations entre acteurs malveillants, infrastructures, techniques d'attaque et indicateurs de compromission. **Elasticsearch** [32] fournit des capacités de recherche textuelle et d'indexation rapide sur le corpus de renseignement. **Qdrant** [35] est utilisé pour la recherche par similarité sémantique à partir des *embeddings* générés par le moteur NLP. Enfin, **Redis** [33] sert de cache distribué et améliore les performances des traitements et des accès fréquents aux données.

2.4 Interface applicative et visualisation

L'interface utilisateur est développée avec **Next.js** [36] et **React** [37], permettant la création d'un tableau de bord dynamique et interactif orienté analyse CTI. La mise en forme repose sur **Tailwind CSS** et **Radix UI**, tandis que **Zustand** assure la gestion des états locaux et **Framer Motion** les animations d'interface. La visualisation des graphes relationnels utilise **Cytoscape.js** [38], **Three.js** [39] et **Force-Graph** afin d'explorer les relations entre entités de menace dans un environnement interactif. Les fonctionnalités de cartographie et d'analyse statistique reposent sur **Mapbox** [40], **Deck.gl**, **GeoIP**, **Recharts** [41] et **Chart.js**. La génération automatique des rapports PDF est assurée par **Puppeteer** via des scripts automatisés Node.js.

2.5 Sécurité, interopérabilité et déploiement

Le contrôle d'accès repose sur les mécanismes **JWT** et **RBAC**, permettant une gestion sécurisée des authentifications et des privilèges des utilisateurs. La validation des données est assurée par **Pydantic** [28], tandis que la documentation des API est générée automatiquement avec **OpenAPI** et **Swagger**. L'interopérabilité avec les systèmes partenaires repose sur les standards **STIX 2.1** [1] et **TAXII** [2], utilisés pour l'échange automatisé du renseignement cyber. La plateforme intègre également des flux de renseignement publics tels que **CISA** [16], **MITRE** [3] et **Abuse.ch** [18, 19, 20], et peut interagir avec des solutions CTI et SIEM comme **MISP** [11], **OpenCTI** [12] et **Splunk**. La génération automatique de règles de détection produit des fichiers compatibles avec les formats **YARA** [42] et **Sigma** [43].

Les services de la plateforme sont conteneurisés avec **Docker** [45] et orchestrés via

Docker Compose, assurant l'isolation des composants et l'uniformité des environnements de développement et de production. Le code source est versionné avec **Git** et hébergé sur **GitHub**, facilitant le suivi des modifications et le travail collaboratif. Le développement est réalisé avec **Visual Studio Code**, tandis que les tests et la validation des API REST et GraphQL sont effectués avec **Postman**.

3 Implémentation du pipeline de collecte et de normalisation

3.1 Architecture générale du pipeline ETL

Le pipeline ETL de la plateforme ONYX assure la transformation des données brutes issues de sources hétérogènes en renseignement structuré et exploitable. Comme l'illustre la Figure 3.1, les données collectées passent par plusieurs étapes successives de nettoyage, de structuration, d'analyse sémantique et de normalisation avant leur conversion en objets conformes au standard STIX 2.1.

Cette architecture permet d'unifier des contenus provenant aussi bien des sources ouvertes que des environnements du Dark Web afin de produire un renseignement cyber exploitable par les modules analytiques et les mécanismes de corrélation de la plateforme.

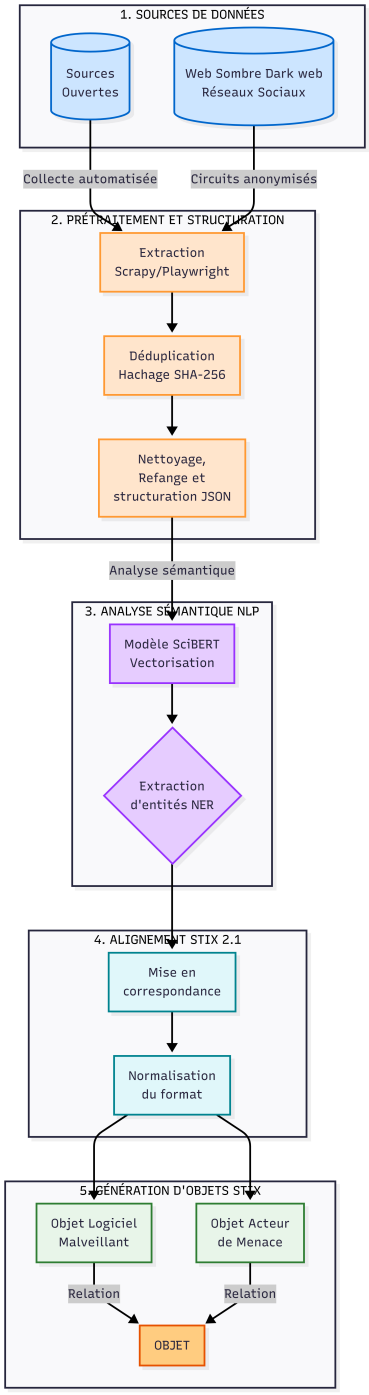

FIGURE 3.1 – Pipeline ETL vers le standard STIX 2.1

3.2 Collecte des sources ouvertes

La collecte des sources ouvertes constitue la première étape du pipeline d'acquisition de la plateforme ONYX. Elle vise à récupérer automatiquement des renseignements issus de sources publiques variées afin d'alimenter les mécanismes d'analyse et de corrélation de la plateforme.

L'architecture de collecte repose sur deux approches complémentaires. La première

s'appuie sur des connecteurs capables d'interroger périodiquement des API institutionnelles telles que **CISA**, **MITRE ATT&CK** et **Abuse.ch**, qui fournissent des données structurées concernant les vulnérabilités, les campagnes malveillantes, les techniques d'attaque et les indicateurs de compromission actifs. La seconde repose sur des agents de collecte automatisés (*Spiders*) chargés d'explorer des blogs spécialisés, des portails d'alerte sécurité et des plateformes communautaires afin d'identifier des signaux émergents absents des flux officiels.

Pour orchestrer cette collecte à grande échelle, la plateforme utilise **Scrapy** selon un modèle asynchrone non bloquant basé sur le moteur Twisted Reactor, illustré par la Figure 3.2. Cette approche permet de gérer simultanément un grand nombre de connexions réseau tout en limitant la consommation de ressources système. Le moteur applique également des mécanismes de régulation limitation des requêtes simultanées et délais entre connexions afin de respecter les politiques d'accès des sources interrogées.

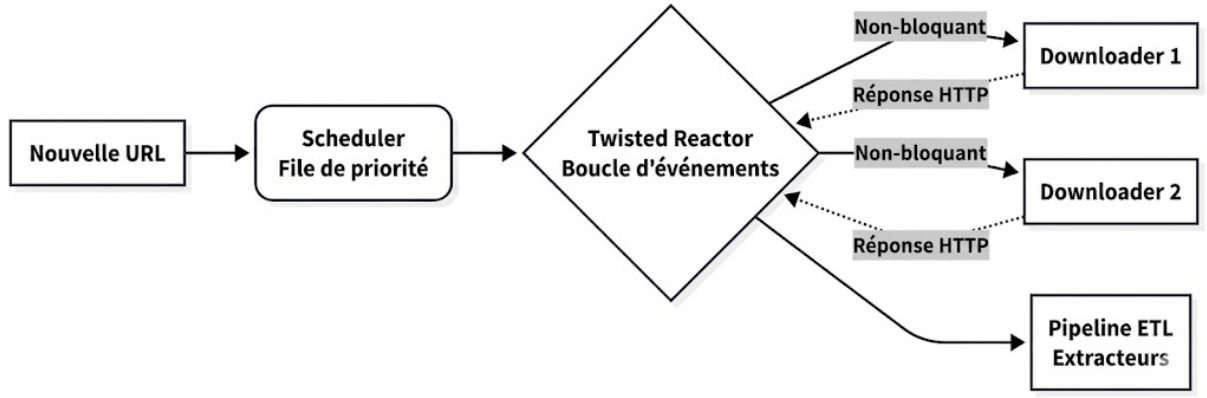

Figure 3.2 – Architecture asynchrone basée sur Twisted Reactor

Certaines plateformes chargent dynamiquement leur contenu via JavaScript, ce qui empêche les collecteurs classiques d'accéder aux données visibles par l'utilisateur. Afin de contourner cette limitation, la plateforme intègre **Playwright**, un moteur capable de piloter un navigateur Chromium en mode *headless*. Chaque session exécute le code JavaScript de la page, attend le chargement complet du contenu, puis extrait les informations utiles avant leur transmission au pipeline ETL. Les sessions sont isolées les unes des autres afin d'éviter toute persistance de cookies ou de données de navigation entre deux collectes.

3.3 Collecte des sources du Dark Web

La collecte des sources du Dark Web constitue l'un des composants les plus sensibles de l'architecture ONYX. Les forums clandestins, les marchés illicites et les blogs de divulgation de données volées représentent des sources précieuses de renseignement précoce, mais leur exploration expose la plateforme à des risques de traçage, de détection ou de compromission. Plusieurs mécanismes de sécurité opérationnelle et de furtivité ont donc été intégrés au pipeline de collecte.

Toutes les communications vers les services cachés accessibles en `.onion` transitent par le réseau **Tor**, ce qui permet de masquer l'identité des sondes de collecte et d'éviter l'exposition directe de l'infrastructure ONYX aux plateformes surveillées. Un gestionnaire de circuits supervise en permanence l'état des connexions et peut déclencher un arrêt immédiat en cas de comportement suspect.

Afin d'éviter l'identification des collecteurs, les circuits Tor sont renouvelés périodiquement : après un certain nombre de requêtes, le système envoie automatiquement une commande `NEWNYM` au port de contrôle Tor pour construire un nouveau circuit et modifier l'adresse IP de sortie. Les temps de rotation sont calculés aléatoirement selon une distribution proche des comportements humains réels, rendant la détection plus difficile. L'implémentation complète de ce mécanisme est présentée dans l'Annexe 1.

Plusieurs mécanismes complémentaires renforcent la discrétion des agents de collecte :

— **Rotation des identités navigateur** : chaque session utilise une signature de navigateur différente afin de reproduire le comportement d'utilisateurs légitimes du navigateur Tor.

— **Conformité des en-têtes HTTP** : les requêtes générées reproduisent les profils d'en-têtes utilisés par les navigateurs réels, limitant ainsi les anomalies détectables côté serveur.

— **Isolation des circuits par domaine** : chaque service `.onion` est associé à un circuit Tor dédié afin de cloisonner les activités de collecte et limiter les risques de corrélation entre sources.

3.4 Prétraitement, déduplication et normalisation STIX

Les données collectées proviennent de sources hétérogènes telles que des pages Web, des flux JSON, des rapports techniques ou des forums spécialisés. Avant leur exploitation, elles passent par une phase de prétraitement visant à améliorer la qualité et la cohérence des informations analysées.

Un mécanisme de déduplication est appliqué à chaque document collecté. Après nettoyage du contenu HTML, une empreinte SHA-256 est calculée à partir du texte extrait. Cette empreinte permet d'identifier rapidement les documents déjà présents dans le corpus et d'éviter leur traitement multiple. Le code complet de ce mécanisme est présenté dans l'Annexe 2.

Les documents retenus sont ensuite nettoyés et normalisés. Les éléments HTML non pertinents sont supprimés, puis un mécanisme de *refangage* restaure automatiquement les indicateurs volontairement obfusqués dans les publications de cybersécurité. Les formes telles que `hxxp` ou `[.]` sont ainsi reconverties vers leur représentation exploitable.

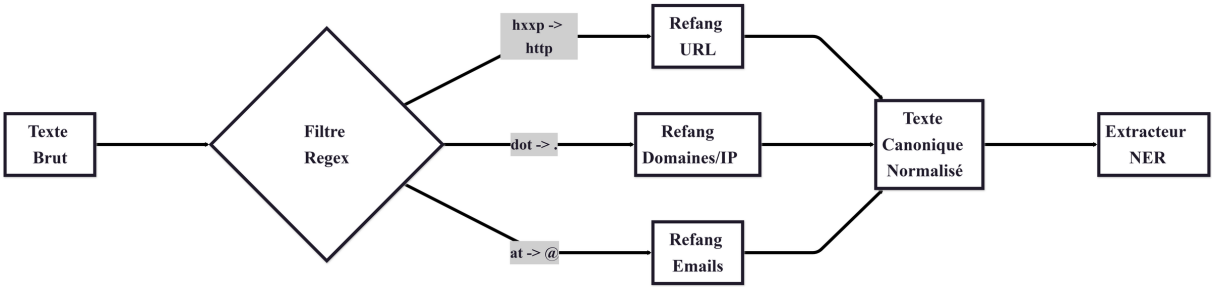

FIGURE 3.3 – Pipeline d'extraction, nettoyage et refangage

Les informations extraites sont ensuite converties en objets conformes au standard **STIX 2.1**, facilitant la structuration et l'échange du renseignement cyber. Des attributs personnalisés préfixés par `x_onyx_` sont ajoutés afin d'enrichir les objets avec des métadonnées spécifiques à la plateforme. Un exemple d'objet STIX généré est présenté dans l'Annexe 3.

Les objets produits sont finalement stockés dans **MongoDB**. La persistance repose sur une logique idempotente : lorsqu'un indicateur déjà connu est détecté, ses informations sont mises à jour plutôt que dupliquées, garantissant ainsi la cohérence du référentiel CTI.

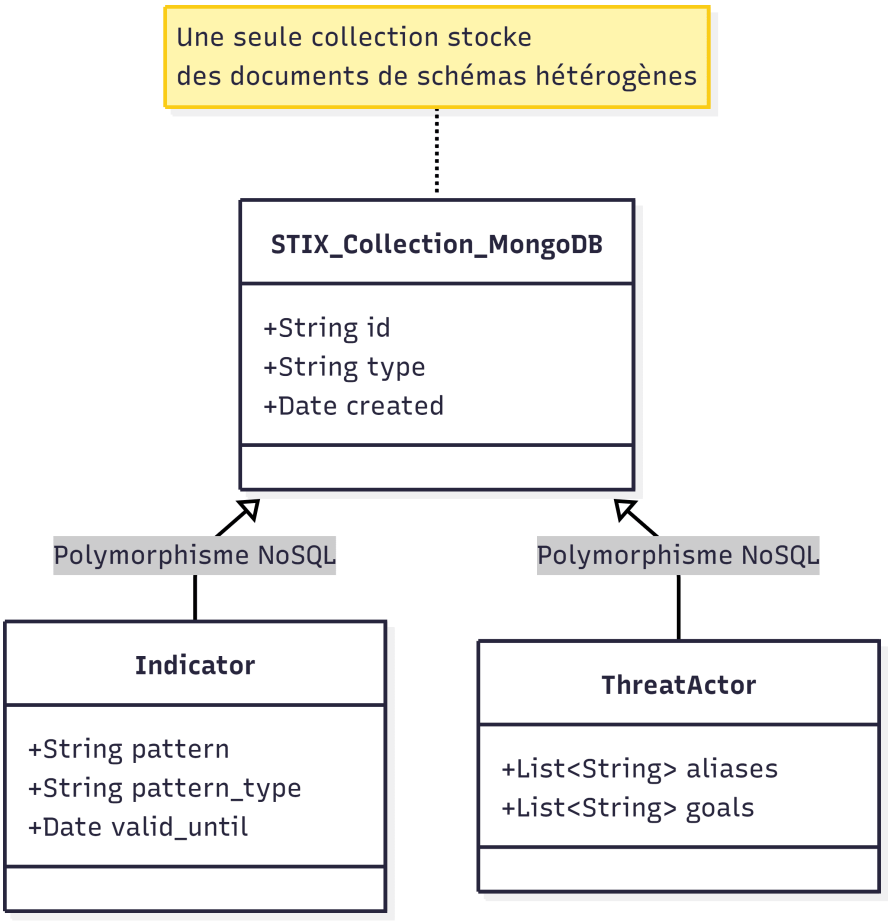

FIGURE 3.4 – Persistance polymorphe des objets STIX 2.1 dans MongoDB

4 Implémentation du moteur d'analyse et de corrélation

Le moteur d'analyse et de corrélation constitue le composant central de la plateforme ONYX. Son rôle est de transformer les données collectées en renseignements exploitables grâce à plusieurs mécanismes complémentaires : extraction d'indicateurs, analyse sémantique, priorisation des menaces, corrélation contextuelle et génération automatisée de règles de détection.

4.1 Extraction des IoCs et analyse sémantique

La première étape du pipeline analytique consiste à identifier automatiquement les indicateurs de compromission présents dans les contenus collectés.La plateforme utilise une cascade d'expressions régulières spécialisées afin d'extraire les principaux types d'indicateurs :

adresses IP, noms de domaine, URL malveillantes, empreintes cryptographiques et signatures techniques. Les motifs les plus spécifiques, tels que les empreintes SHA-512 ou SHA-256, sont évalués avant les motifs plus généraux afin de limiter les erreurs de classification. Chaque indicateur extrait est ensuite validé à travers plusieurs mécanismes de filtrage permettant d'éliminer les faux positifs évidents : les adresses IP privées, les valeurs incohérentes ou les chaînes artificielles sont ainsi automatiquement rejetées.

Au-delà de cette extraction syntaxique, la plateforme intègre un moteur d'analyse NLP basé sur le modèle **SciBERT**, qui permet de capturer le contenu sémantique des rapports de renseignement et d'identifier les relations contextuelles entre les menaces. Comme le montre la Figure 3.5, chaque document analysé est transformé en une représentation vectorielle de 768 dimensions, ce qui permet de rapprocher automatiquement des rapports décrivant des comportements malveillants similaires, même lorsque les termes employés diffèrent. L'analyse sémantique facilite également l'identification des techniques MITRE ATT&CK, la détection des relations entre campagnes malveillantes et l'enrichissement contextuel des indicateurs collectés.

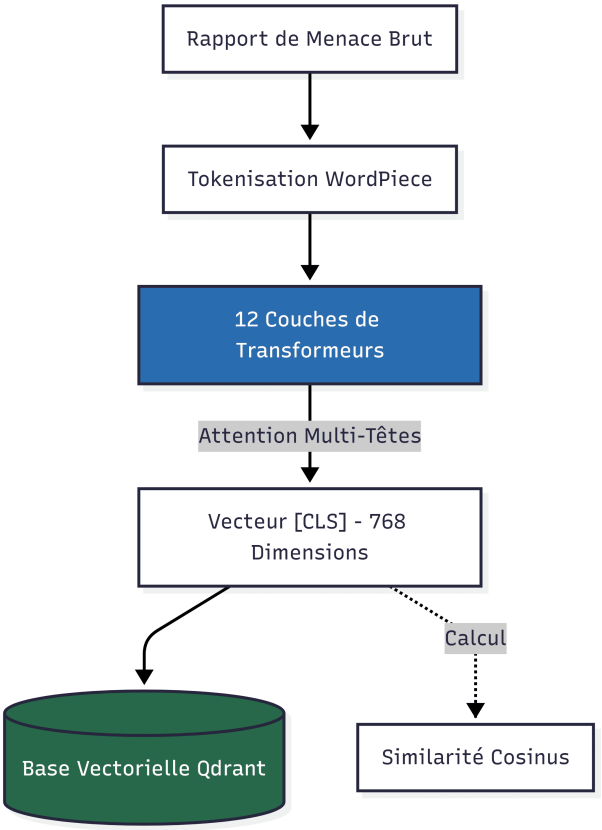

FIGURE 3.5 – Vectorisation sémantique avec SciBERT

4.2 Scoring, priorisation et cycle de vie des IoCs

Tous les indicateurs détectés ne présentent pas le même niveau de criticité. La plateforme attribue donc à chaque menace un score dynamique permettant de prioriser les traitements et les actions défensives. Le calcul de ce score repose principalement sur la fiabilité de la source d'acquisition, le niveau de confiance du moteur NLP, la fraîcheur temporelle de l'indicateur et le type de menace détectée. Les indicateurs issus de sources institutionnelles reconnues et observés récemment obtiennent ainsi un score plus élevé que les indicateurs anciens ou provenant de sources moins fiables.

Afin d'éviter l'accumulation d'indicateurs obsolètes, la plateforme intègre un moteur de gestion du cycle de vie permettant de modéliser la perte progressive de pertinence des menaces au fil du temps. Chaque indicateur évolue dynamiquement entre quatre états opérationnels :

— **VALID** : indicateur actif nécessitant une action immédiate ;

— **DEGRADING** : indicateur en phase de dégradation ;

— **STALE** : indicateur ancien conservé pour analyse historique ;

— **OBSOLETE** : indicateur archivé et retiré des mécanismes actifs de détection.

Ce mécanisme automatise le cycle de vie des IoCs et réduit la charge de maintenance des analystes SOC et CTI.

4.3 Génération de règles de détection et assistance conversationnelle

Lorsqu'une menace est validée, la plateforme peut automatiquement produire des règles de détection exploitables par les outils de cybersécurité. Deux formats principaux sont supportés : **YARA** pour la détection de fichiers malveillants, et **Sigma** pour la détection d'événements suspects dans les SIEM et les journaux systèmes. Un exemple de règle Sigma générée automatiquement par la plateforme ONYX est présenté dans l'Annexe 4.

Afin de faciliter l'exploitation du renseignement cyber, la plateforme intègre également un assistant conversationnel capable d'être interrogé en langage naturel. L'utilisateur peut poser des questions concernant les campagnes d'attaque, les groupes adverses, les techniques MITRE

ATT&CK ou les indicateurs observés récemment. L'assistant s'appuie sur le moteur Google GenAI pour l'interprétation des requêtes et interroge en temps réel la base de connaissances CTI de la plateforme afin de fournir des réponses contextualisées et exploitables.

5 Architecture de stockage et indexation

La plateforme ONYX manipule plusieurs catégories de données : objets STIX,2.1, rapports de renseignement, relations entre entités, vecteurs sémantiques, journaux d'audit et données de cache. Afin de répondre efficacement à ces besoins hétérogènes, une architecture de stockage polyglotte a été mise en œuvre. Chaque type de donnée est confié au moteur le plus adapté à ses caractéristiques afin d'assurer des performances optimales pour la persistance, la recherche, la corrélation et l'analyse du renseignement cyber.

5.1 Stockage relationnel et documentaire

PostgreSQL est utilisé pour les données fortement structurées de la plateforme, notamment les comptes utilisateurs, les rôles RBAC, les journaux d'audit et les paramètres de configuration. Son modèle relationnel garantit la cohérence et l'intégrité des données sensibles.

MongoDB assure le stockage des objets STIX,2.1 et des rapports de renseignement. Son modèle documentaire est particulièrement adapté à l'hétérogénéité des objets CTI, dont les structures peuvent varier selon leur nature. Cette approche facilite l'ingestion et l'évolution des données sans imposer de schéma relationnel rigide.

5.2 Modélisation des relations avec Neo4j

La plateforme utilise **Neo4j** pour représenter et explorer les relations complexes entre les différentes entités de renseignement. Comme l'illustre la Figure 3.6, chaque acteur, campagne, logiciel malveillant ou indicateur est modélisé sous forme de nœud relié aux autres entités par des relations orientées.

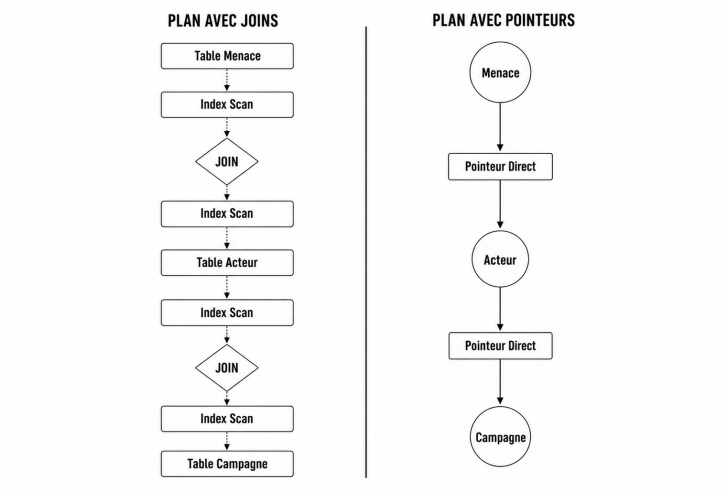

FIGURE 3.6 – Traversée des relations dans Neo4j

Cette modélisation facilite la reconstruction des chaînes d'attaque et la corrélation des indicateurs appartenant à une même campagne malveillante. Un exemple de requête Cypher utilisée pour reconstruire une chaîne d'attaque à partir d'un indicateur donné est disponible dans l'Annexe 5. Grâce au mécanisme d'*index-free adjacency*, Neo4j permet des traversées de graphe rapides, indépendamment de la taille globale de la base de connaissances.

5.3 Recherche, indexation et orchestration asynchrone

La plateforme combine deux moteurs complémentaires pour la recherche et l'exploitation des données. **Elasticsearch** assure l'indexation et la recherche rapide au sein des rapports et des informations collectées. **Qdrant** complète cette approche en prenant en charge la recherche vectorielle basée sur les embeddings générés par SciBERT, permettant d'identifier des contenus sémantiquement similaires même lorsque les termes utilisés diffèrent.

Redis joue un double rôle dans l'architecture ONYX. Il est utilisé comme cache mémoire afin d'accélérer l'accès aux données fréquemment consultées, mais également comme broker de messages pour **Celery**. Cette combinaison permet d'exécuter en arrière-plan les traitements coûteux, tels que l'analyse sémantique, l'indexation vectorielle ou la génération de règles de détection, tout en préservant la réactivité de l'application.

6 Interface utilisateur et visualisation analytique

L'interface utilisateur constitue le point d'interaction principal entre la plateforme ONYX et les analystes SOC/CTI. Elle a été conçue pour offrir une visualisation claire, réactive et centralisée du renseignement produit par le système, tout en facilitant les investigations complexes et l'exploration des relations entre menaces.

L'interface est développée à l'aide de **Next.js** et **React**, permettant une navigation fluide sans rechargement complet des pages et une mise à jour dynamique des composants. La couche de présentation repose sur **Tailwind CSS** pour la cohérence visuelle et la mise en forme responsive des composants, **Radix UI** pour la construction d'éléments accessibles compatibles avec la navigation clavier, **Zustand** pour la gestion légère de l'état global de l'application, et **Framer Motion** pour les transitions et animations d'interface. Cette architecture permet de maintenir une interface réactive tout en limitant la complexité applicative.

6.1 Tableau de bord analytique

Comme l'illustre la Figure 3.7, la plateforme intègre un tableau de bord centralisé regroupant l'ensemble des informations opérationnelles nécessaires à l'analyse des menaces.

Figure 3.7 – Tableau de bord analytique de la plateforme ONYX

Le tableau de bord regroupe plusieurs composants analytiques complémentaires : des **métriques globales et KPIs** synthétisant les indicateurs actifs, alertes critiques et activités

des collecteurs ; une **cartographie géospatiale** visualisant les infrastructures malveillantes identifiées à partir des adresses IP résolues géographiquement ; un **flux temps réel** affichant instantanément les nouvelles détections validées par le moteur analytique ; un **tableau des indicateurs** permettant la consultation et le filtrage des objets STIX 2.1 selon leur type, score de criticité ou état de déclin ; et un **assistant conversationnel IA** pour l'interrogation de la base CTI en langage naturel. L'ensemble de ces composants permet aux analystes de disposer d'une vue globale et contextualisée de l'état des menaces surveillées par la plateforme.

6.2 Exploration relationnelle via le graphe de menaces

La plateforme intègre un moteur de visualisation relationnelle permettant d'explorer les graphes de menaces générés à partir des données corrélées. Grâce à **Three.js** et **Force-Graph**, chaque entité de renseignement acteur malveillant, campagne, malware ou indicateur est représentée sous forme de nœud interactif relié aux autres entités par des relations orientées. L'analyste peut ainsi explorer dynamiquement les relations entre entités, isoler des sous-graphes associés à une campagne donnée, zoomer ou pivoter librement la scène 3D, et afficher les propriétés détaillées d'un nœud sélectionné. **Cytoscape.js** complète cette visualisation pour les graphes hiérarchiques ou radiaux nécessitant une représentation plus structurée des chaînes d'attaque.

6.3 Communication continue et diffusion des événements

Dans un contexte de cyberdéfense, le délai entre la détection d'une menace et sa prise en charge par les équipes opérationnelles doit être réduit au minimum. Pour répondre à cette exigence, la plateforme ONYX abandonne le modèle classique de requêtage périodique (*HTTP Polling*), trop coûteux en bande passante et générateur de latence, au profit d'une architecture événementielle fondée sur les **WebSockets**. Ce protocole maintient une connexion persistante entre le navigateur de l'analyste et le serveur applicatif, permettant au serveur de pousser les informations dès qu'elles sont disponibles, sans attendre une demande du client.

Le serveur applicatif, développé avec **FastAPI** et exécuté par **Uvicorn**, repose sur un modèle d'exécution asynchrone conforme à la spécification ASGI. Ce modèle lui permet de

maintenir un grand nombre de connexions simultanées sans bloquer le fil d'exécution principal. Pour découpler les traitements lourds de la couche d'affichage, le système adopte un patron de conception *Publish-Subscribe* orchestré par **Redis**, qui joue le rôle de bus de messages entre les différents composants de la plateforme.

FIGURE 3.8 – Mécanisme de communication continue et diffusion des événements

Comme l'illustre la Figure 3.8, le cycle de vie d'une alerte suit un flux asynchrone en quatre étapes :

1. **Génération de l'événement** : lorsqu'un worker Celery achève une tâche critique validation d'un nouvel indicateur de compromission, extraction d'entités par le modèle SciBERT, ou dégradation du score d'un IoC par le moteur de cycle de vie il publie un message structuré sur un canal Redis dédié.
2. **Acheminement ASGI** : le serveur FastAPI, abonné à ces canaux via des coroutines asynchrones, intercepte l'événement sans bloquer les autres traitements en cours.
3. **Diffusion vers le client** : le gestionnaire WebSocket transmet l'information, formatée en JSON, à travers la connexion persistante vers l'interface utilisateur.
4. **Mise à jour de l'interface** : côté client, l'architecture React/Next.js intercepte le message et met à jour uniquement les composants concernés du tableau de bord, sans rechargement complet de la page.

Les événements diffusés par ce canal couvrent trois catégories opérationnelles :

— **Renseignement tactique** : nouvelles détections d'indicateurs critiques et changements d'état des IoCs, tels que le basculement d'un indicateur de l'état `VALID` vers l'état `REVOKED`.

— **Renseignement opérationnel** : alertes issues de la veille continue et identification de nouvelles campagnes malveillantes détectées par les collecteurs.

— **Télémétrie analytique** : résultats d'analyse NLP produits par SciBERT et mises à jour

sur l'avancement des tâches du pipeline d'ingestion.

Cette architecture réduit significativement le délai entre la détection d'une menace et sa visualisation par l'analyste. Elle améliore ainsi le *Mean Time to Detect* (MTTD) des équipes SOC et CTI, en leur garantissant une vue synchronisée avec l'état réel des menaces traitées par le moteur d'analyse d'ONYX.

7 Interopérabilité et intégration externe

La plateforme ONYX a été conçue pour s'intégrer naturellement dans les écosystèmes de cybersécurité existants. L'objectif n'est pas de fonctionner comme un système isolé, mais comme un composant central capable de partager, corréler et diffuser le renseignement produit vers les outils de défense et les plateformes CTI externes.

7.1 Diffusion des renseignements vers les plateformes externes

Les indicateurs validés par ONYX sont exportés automatiquement sous forme de bundles **STIX 2.1** vers deux catégories de destinations complémentaires.

D'une part, la plateforme s'interface avec des plateformes communautaires de partage d'indicateurs telles que **MISP** et **OpenCTI** via des connecteurs dédiés. Cette synchronisation permet le partage collaboratif des indicateurs de compromission, l'enrichissement mutuel des bases de renseignement, l'amélioration de la détection des campagnes malveillantes, et l'intégration du renseignement ONYX dans des environnements CTI déjà existants.

D'autre part, les IoCs validés sont exportés via le protocole **TAXII 2.1** vers des systèmes de gestion des événements de sécurité (*SIEM*) tels que **Splunk**, **Wazuh** ou **Elastic SIEM**. Cette intégration permet l'injection automatique des indicateurs dans les règles de détection, l'enrichissement des tableaux de bord SOC, la corrélation en temps réel entre événements locaux et renseignements CTI externes, ainsi que la réduction du délai entre détection et réaction opérationnelle. Grâce à cette approche, les nouvelles menaces identifiées par ONYX peuvent être exploitées immédiatement par les dispositifs de supervision et de détection déjà

déployés au sein du SOC.

L'utilisation conjointe des standards STIX 2.1 et TAXII garantit l'interopérabilité avec les principaux outils CTI et SIEM du marché.

7.2 APIs REST et GraphQL

L'ensemble des fonctionnalités de la plateforme est exposé via une API développée avec **FastAPI**. Cette couche d'abstraction permet l'intégration d'ONYX avec des applications tierces, des tableaux de bord externes et des outils d'automatisation de sécurité.

Comme l'illustre la Figure 3.9, l'architecture serveur applicatif repose sur un modèle de traitement asynchrone utilisant **Redis** et **Celery** afin de déléguer les tâches coûteuses sans bloquer les services principaux.

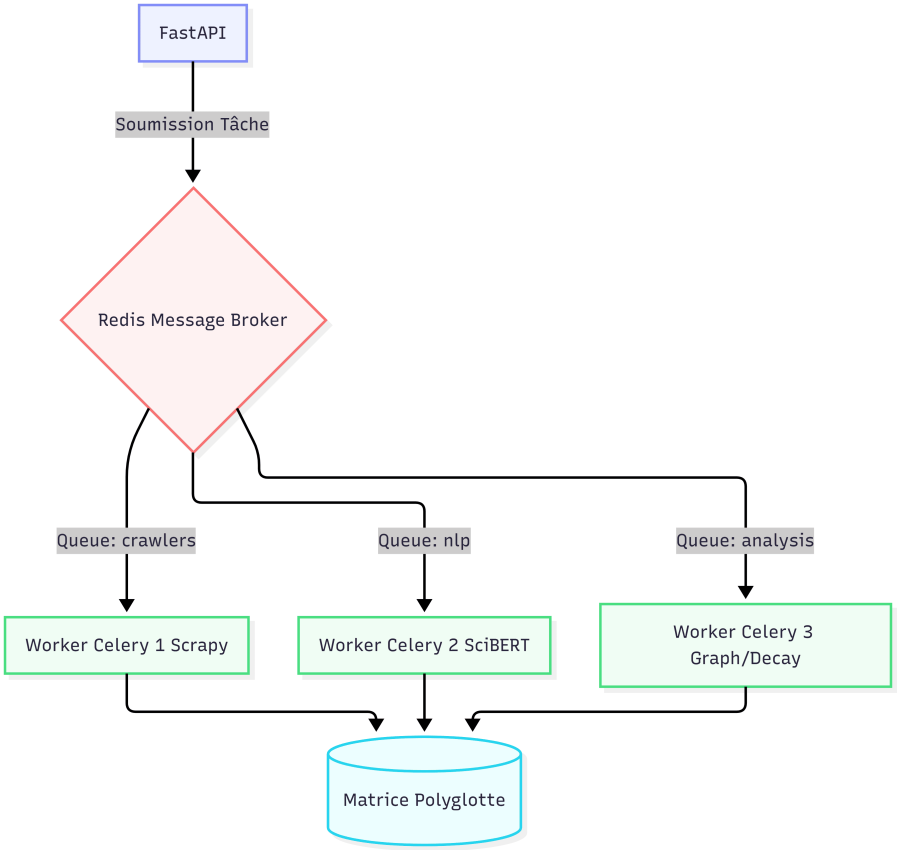

FIGURE 3.9 – Architecture asynchrone avec Redis et Celery

Deux interfaces complémentaires sont proposées. L'interface **REST** fournit les opérations classiques de consultation et de gestion des données, couvrant la gestion des indicateurs, l'authentification JWT, l'export TAXII et l'administration des ressources CTI. L'interface

GraphQL, implémentée avec Strawberry, permet aux clients de sélectionner précisément les champs nécessaires afin de réduire le volume des données échangées ; les détails d'implémentation correspondants sont disponibles dans l'Annexe 6. Cette approche améliore l'efficacité des échanges réseau et facilite l'intégration de tableaux de bord analytiques ou d'applications externes nécessitant uniquement un sous-ensemble des données disponibles.

8 Conclusion

Dans ce chapitre, nous avons présenté l'implémentation technique de la plateforme ONYX, depuis les mécanismes de collecte jusqu'aux modules d'analyse, de stockage et de visualisation du renseignement cyber. L'ensemble des composants développés forme une architecture cohérente, modulaire et orientée automatisation, capable de transformer des données hétérogènes en renseignements contextualisés et exploitables par les équipes SOC et CTI. Le chapitre suivant sera consacré à la validation fonctionnelle et à l'évaluation des performances de la plateforme.

Chapitre

4 Déploiement et Validation Opérationnelle

Sommaire

Introduction **69**

1 Cycle de traitement des données **69**

1.1 Initialisation de l'infrastructure et mécanismes de secours 69

1.2 Supervision de la Collecte et Télémétrie OSINT 70

1.3 Diffusion et gestion de la fraîcheur des indicateurs 71

2 Restitution analytique et exploitation opérationnelle **72**

2.1 Indicateurs globaux et évaluation du risque 72

2.2 Profilage stratégique et cartographie sectorielle 73

2.3 Investigation granulaire : explorateur d'indicateurs 74

2.4 Modélisation topologique : graphe de menaces 75

2.5 Projection tactique : matrice MITRE ATT&CK 76

2.6 Analyse sémantique et explicabilité IA 77

2.7 Interopérabilité et génération de rapports automatisés 79

3 Évaluation de la Résilience Architecturale **80**

4 Synthèse de la validation **82**

Conclusion **83**

Introduction

Ce chapitre présente la validation fonctionnelle et technique de la plateforme ONYX dans des conditions d'exploitation représentatives. Il illustre, captures d'écran à l'appui, le fonctionnement des principaux modules de la plateforme : le cycle de traitement des indicateurs de compromission, les fonctionnalités du tableau de bord analytique, et le comportement du système face aux défaillances.

1 Cycle de traitement des données

Cette section présente le parcours d'une information au sein de la plateforme ONYX, depuis sa collecte jusqu'à son exploitation par les différents modules du système. Le traitement d'un indicateur de compromission (IoC) s'articule autour de plusieurs étapes successives : l'acquisition des données, leur analyse et leur enrichissement, leur diffusion vers les interfaces de visualisation, puis leur suivi tout au long de leur cycle de vie.

1.1 Initialisation de l'infrastructure et mécanismes de secours

Au démarrage, la plateforme initialise l'ensemble de ses composants essentiels, notamment les bases de données, les services de collecte, les modules d'analyse ainsi que les référentiels nécessaires au traitement du renseignement cyber. Cette phase garantit la disponibilité des ressources requises avant le lancement des opérations de collecte et d'analyse.

Afin d'assurer la continuité du service, ONYX intègre un mécanisme de secours permettant de faire face à l'indisponibilité temporaire de certaines sources externes. En cas d'échec d'accès aux flux OSINT, la plateforme bascule automatiquement vers un jeu de données préalablement validé, lui permettant de conserver un état opérationnel dès son démarrage.

Cette approche améliore la résilience du système et limite l'impact des défaillances externes sur le processus de collecte du renseignement.

1.2 Supervision de la Collecte et Télémétrie OSINT

La collecte constitue la première étape du cycle de renseignement de la plateforme ONYX. Elle permet d'alimenter en continu le système avec des données issues de sources ouvertes et du Dark Web, qui seront ensuite analysées et enrichies.

Une fois l'initialisation achevée, plusieurs agents de collecte opèrent en parallèle afin d'assurer l'acquisition continue des données. L'interface de supervision présentée à la Figure 4.1 fournit une vue centralisée de leur activité. Elle permet de suivre l'état des agents, le volume d'indicateurs collectés ainsi que les opérations de collecte en temps réel.

La plateforme s'appuie sur trois catégories d'agents :

— **Agents Dark Web** : les agents *Scout-A1* et *Scout-A2* explorent les forums et blogs spécialisés accessibles via le réseau Tor [44]. Une rotation automatique des circuits est appliquée afin de limiter les mécanismes de blocage.

— **Agent Web de surface** : l'agent *Scout-B1* collecte des informations issues de sources ouvertes et recense les adresses IP associées à des infrastructures malveillantes connues.

— **Agent d'analyse** : l'agent *Spider-Omega* extrait automatiquement les indicateurs de compromission à partir des contenus collectés.

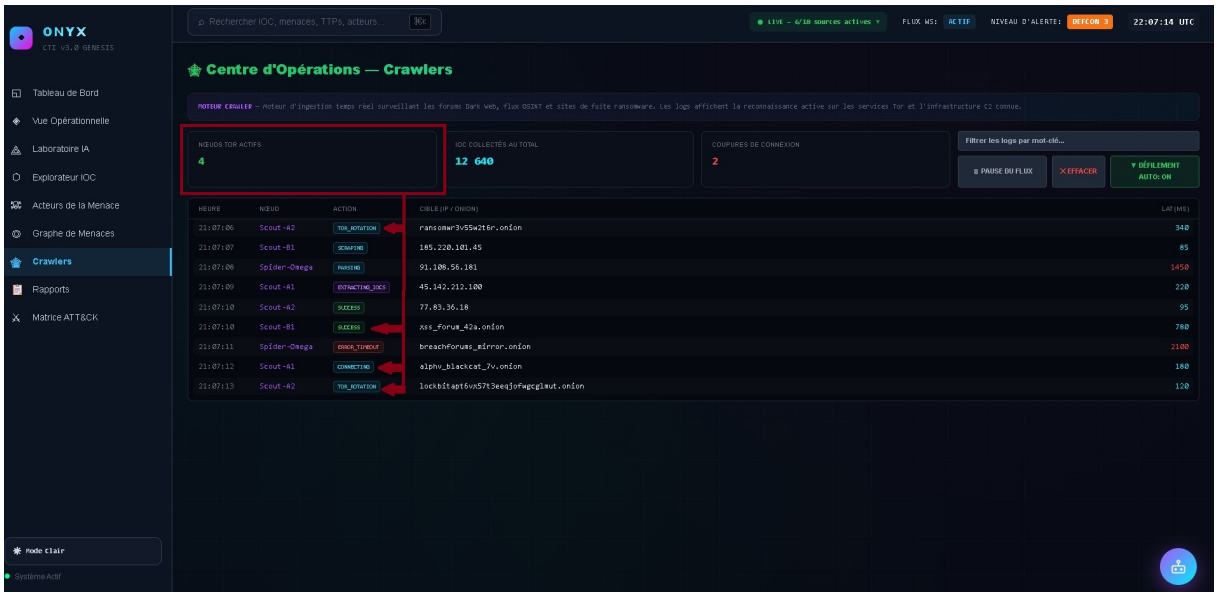

FIGURE 4.1 – Supervision en temps réel des agents de collecte.

En parallèle, le module OSINT interroge jusqu'à 18 sources institutionnelles. Le panneau

de télémétrie (figure 4.2) affiche l'état de chaque connecteur ainsi qu'un flux en temps réel des indicateurs ingérés, permettant de vérifier la continuité du flux d'acquisition.

FIGURE 4.2 – Télémétrie des sources OSINT et flux de signaux en direct.

Les indicateurs collectés sont ensuite soumis à des mécanismes de déduplication et d'enrichissement automatique. Ces traitements incluent notamment la géolocalisation, la classification des menaces ainsi que leur association aux techniques du référentiel MITRE ATT&CK [3].

1.3 Diffusion et gestion de la fraîcheur des indicateurs

Une fois analysés et enrichis, les indicateurs sont diffusés en temps réel vers les différents modules de visualisation de la plateforme. Cette synchronisation repose sur des mécanismes de communication basés sur **WebSocket**, permettant la mise à jour automatique des tableaux de bord et des interfaces d'investigation.

Afin de garantir la pertinence du renseignement affiché, chaque indicateur est associé à un score de fraîcheur reflétant son niveau d'actualité. Les indicateurs récemment observés conservent une priorité élevée, tandis que ceux qui n'ont plus été observés depuis une longue période voient progressivement leur importance diminuer.

Ce mécanisme permet de mettre en avant les menaces les plus récentes et de maintenir une représentation cohérente du paysage de menaces au sein de la plateforme.

2 Restitution analytique et exploitation opérationnelle

Cette section présente les principaux modules de visualisation et d'investigation de la plateforme ONYX. Ces interfaces permettent aux analystes de consulter les indicateurs collectés, d'évaluer les risques, d'explorer les relations entre les menaces et d'exploiter le renseignement produit par la plateforme.

2.1 Indicateurs globaux et évaluation du risque

Le tableau de bord principal présenté à la Figure 4.3 regroupe les principaux indicateurs de synthèse de la plateforme. La jauge centrale affiche un score de risque global calculé à partir des indicateurs actifs et de leur niveau de criticité. Des compteurs complémentaires, tels que le nombre d'IoC actifs ou de vulnérabilités critiques détectées, offrent une vision rapide de l'état général du système. Un flux d'alertes met également en évidence les événements récents nécessitant une attention particulière.

FIGURE 4.3 – Tableau de bord principal et évaluation du score de risque.

La vue opérationnelle présentée à la Figure 4.4 complète cette analyse en fournissant des informations détaillées sur les données stockées dans le référentiel CTI. Elle intègre également une cartographie géographique des incidents récents, facilitant l'identification des zones les plus actives et la visualisation de la répartition des menaces observées.

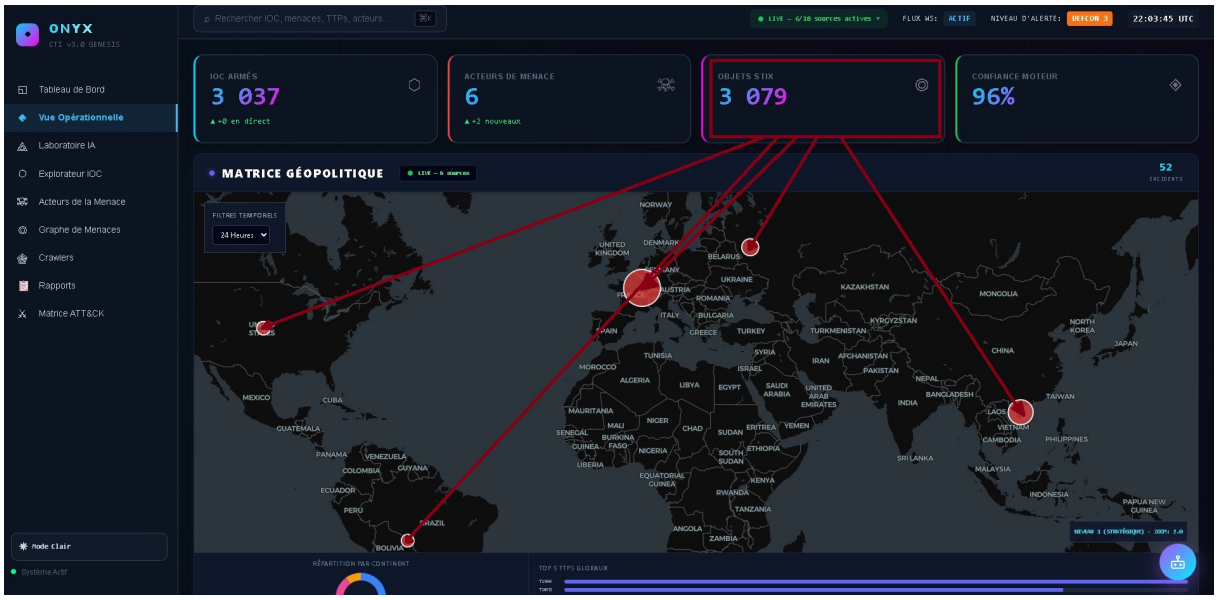

FIGURE 4.4 – Vue opérationnelle et cartographie globale des incidents.

2.2 Profilage stratégique et cartographie sectorielle

Afin de faciliter l'analyse des menaces, ONYX intègre un module dédié au profilage des acteurs malveillants et à l'identification des secteurs les plus exposés. Cette fonctionnalité permet aux analystes de mieux comprendre l'origine des menaces et d'évaluer leur impact potentiel.

L'interface présentée à la Figure 4.5 combine deux vues complémentaires. La première établit un classement des acteurs de menace selon leur niveau de dangerosité et leur catégorie d'activité (espionnage, sabotage ou cybercriminalité). La seconde fournit une répartition sectorielle des attaques observées, mettant en évidence les domaines les plus ciblés dans les données collectées.

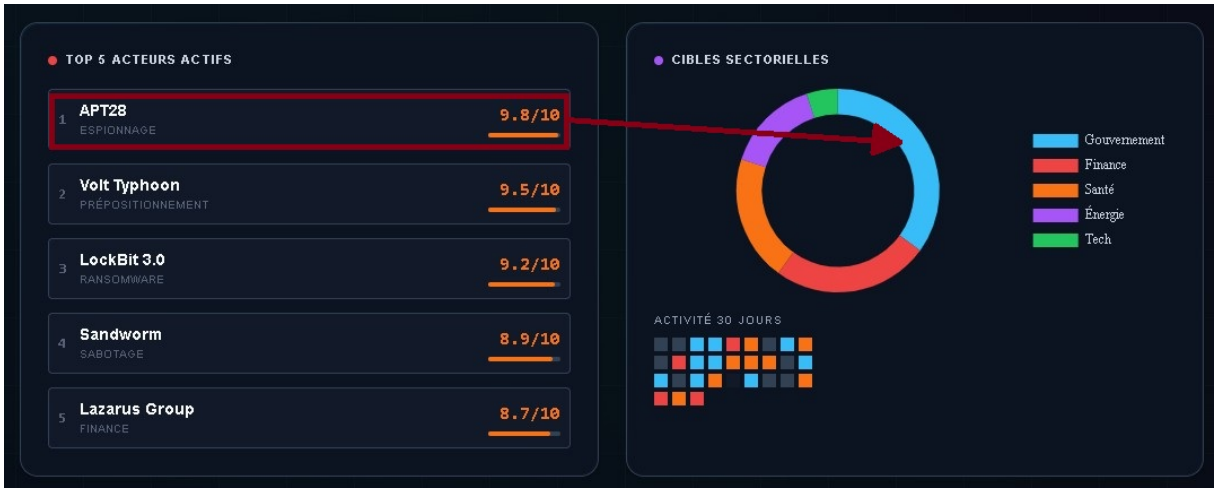

FIGURE 4.5 – Profilage des acteurs et répartition sectorielle des menaces.

La sélection d'un acteur permet d'accéder à une fiche de renseignement détaillée, illustrée à la Figure 4.6. Cette fiche centralise les informations disponibles sur l'acteur concerné, notamment les outils associés, les techniques utilisées et les indicateurs observés. Deux niveaux de consultation sont proposés afin de répondre aux besoins de différents profils d'utilisateurs : une vue synthétique destinée aux décideurs (*BOARD*) et une vue technique destinée aux analystes (*SOC*).

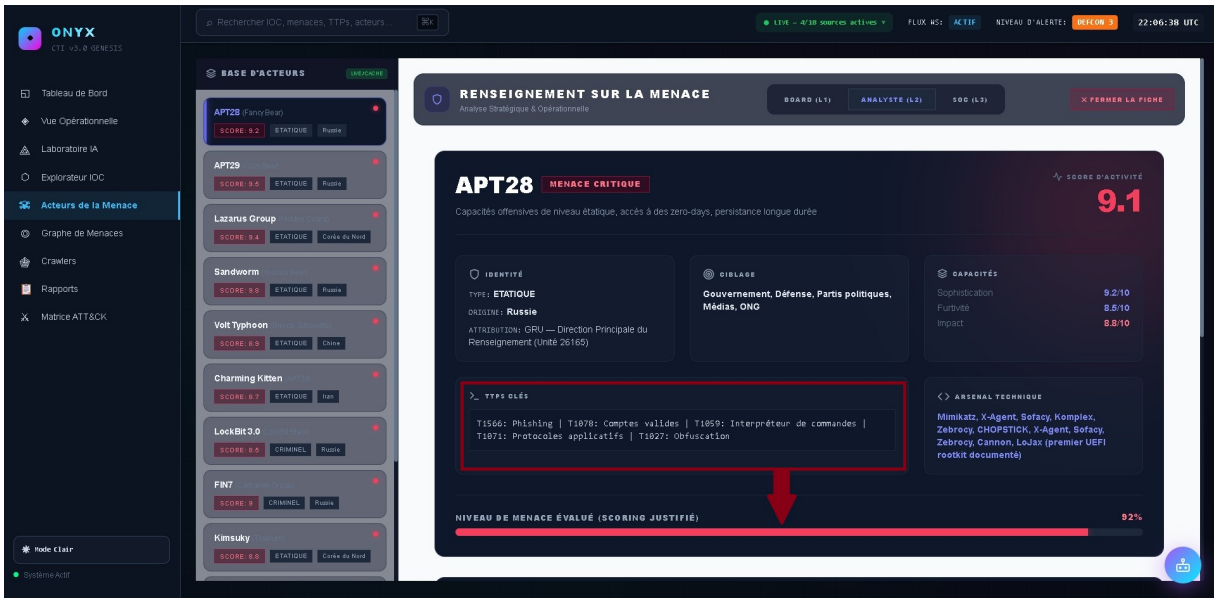

FIGURE 4.6 – Fiche de renseignement détaillée de l'acteur APT28.

2.3 Investigation granulaire : explorateur d'indicateurs

L'explorateur d'indicateurs constitue l'un des principaux outils d'investigation de la plateforme ONYX. Il permet aux analystes d'accéder à l'ensemble des indicateurs de compromission collectés, de les filtrer selon différents critères et d'examiner rapidement les éléments les plus pertinents pour une investigation.

Comme l'illustre la Figure 4.7, chaque indicateur est présenté avec ses principales métadonnées, notamment son type, son score de confiance et son état dans le cycle de vie du renseignement. Cette vue facilite la consultation, le tri et la priorisation des indicateurs en fonction du contexte d'analyse.

L'interface intègre également des actions d'investigation permettant d'approfondir l'analyse d'un indicateur sélectionné et d'accéder aux informations associéées au sein de la plateforme.

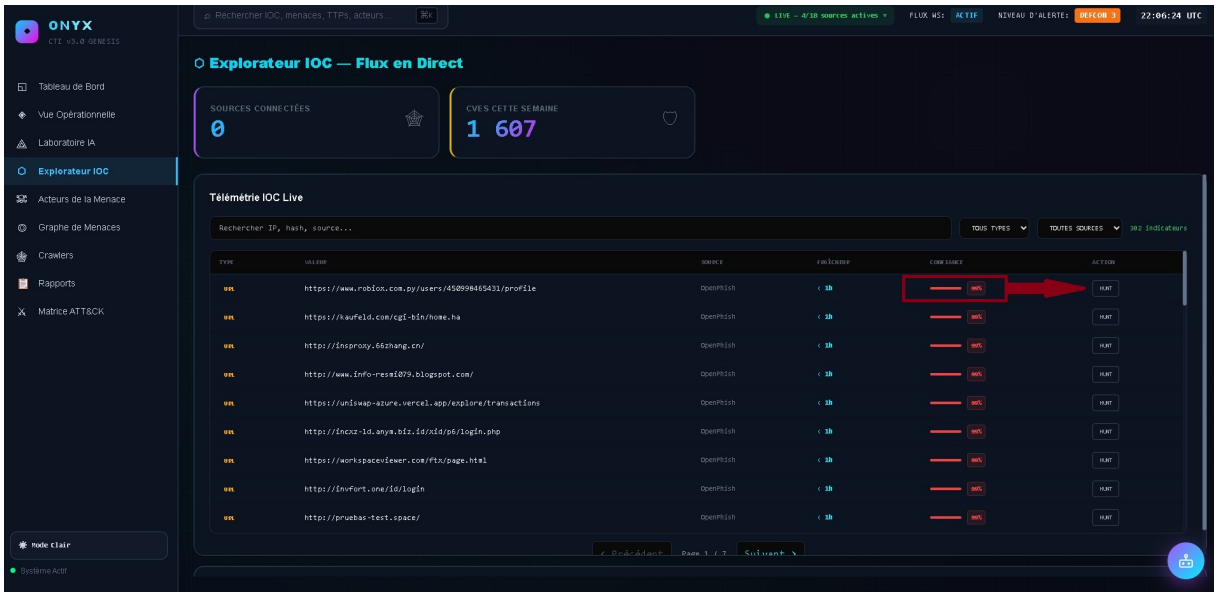

FIGURE 4.7 – Explorateur d'indicateurs de compromission (IoC).

2.4 Modélisation topologique : graphe de menaces

Afin de faciliter l'analyse des relations entre les différents éléments du renseignement cyber, ONYX intègre un module de visualisation basé sur un graphe de connaissances. Cette représentation permet d'explorer les liens existants entre les acteurs malveillants, les campagnes, les indicateurs de compromission, les vulnérabilités et les infrastructures observées.

Comme l'illustre la Figure 4.8, les entités sont représentées sous forme de nœuds reliés par des relations explicites. Chaque catégorie d'entité est distinguée visuellement afin de faciliter la navigation et l'interprétation du graphe.

Cette approche permet d'identifier rapidement des corrélations qui seraient plus difficiles à détecter dans une représentation tabulaire classique, telles qu'une infrastructure partagée par plusieurs groupes malveillants, une vulnérabilité exploitée par différentes campagnes ou encore des relations indirectes entre plusieurs indicateurs de compromission.

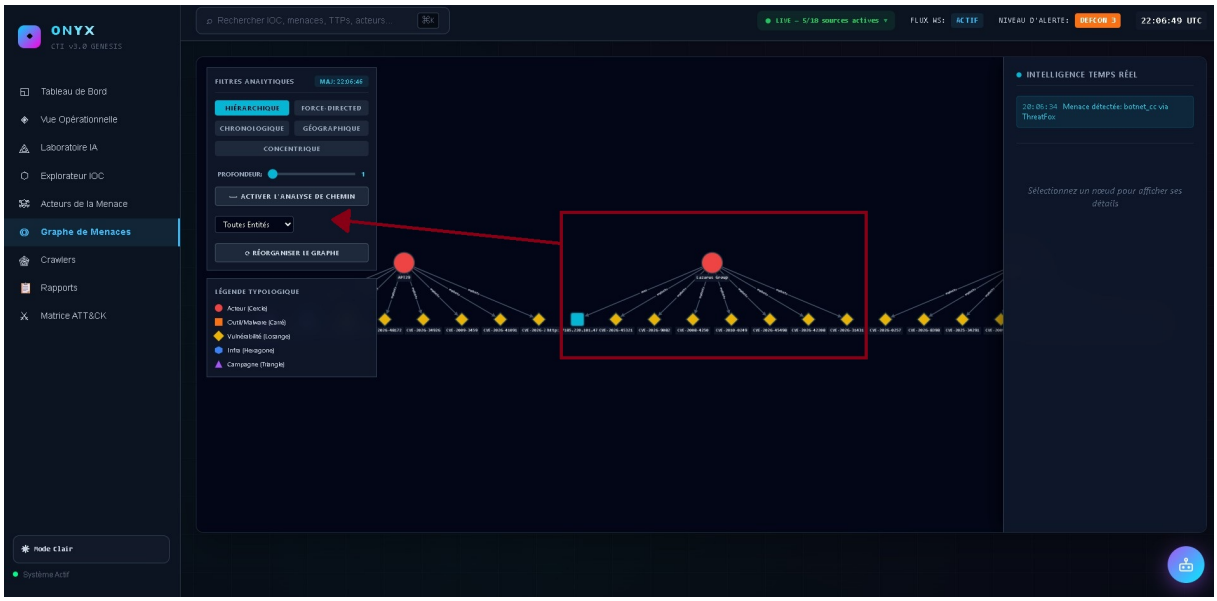

FIGURE 4.8 – Visualisation topologique du graphe de menaces.

2.5 Projection tactique : matrice MITRE ATT&CK

Afin de contextualiser les menaces observées, la plateforme ONYX intègre une représentation interactive du référentiel MITRE ATT&CK [3]. Cette vue permet aux analystes d'identifier rapidement les tactiques et techniques les plus fréquemment rencontrées dans les données collectées.

Comme l'illustre la Figure 4.9, la matrice est affichée sous forme de carte de chaleur (*heatmap*). L'intensité de la couleur associée à chaque cellule reflète la fréquence d'apparition de la technique correspondante dans le corpus analysé. Cette représentation facilite l'identification des comportements malveillants dominants et des techniques les plus utilisées par les acteurs de menace.

L'interface permet également d'explorer le contenu de la matrice de manière interactive. La sélection d'une cellule affiche les informations détaillées relatives à la technique concernée, offrant ainsi un accès direct au contexte tactique associé.

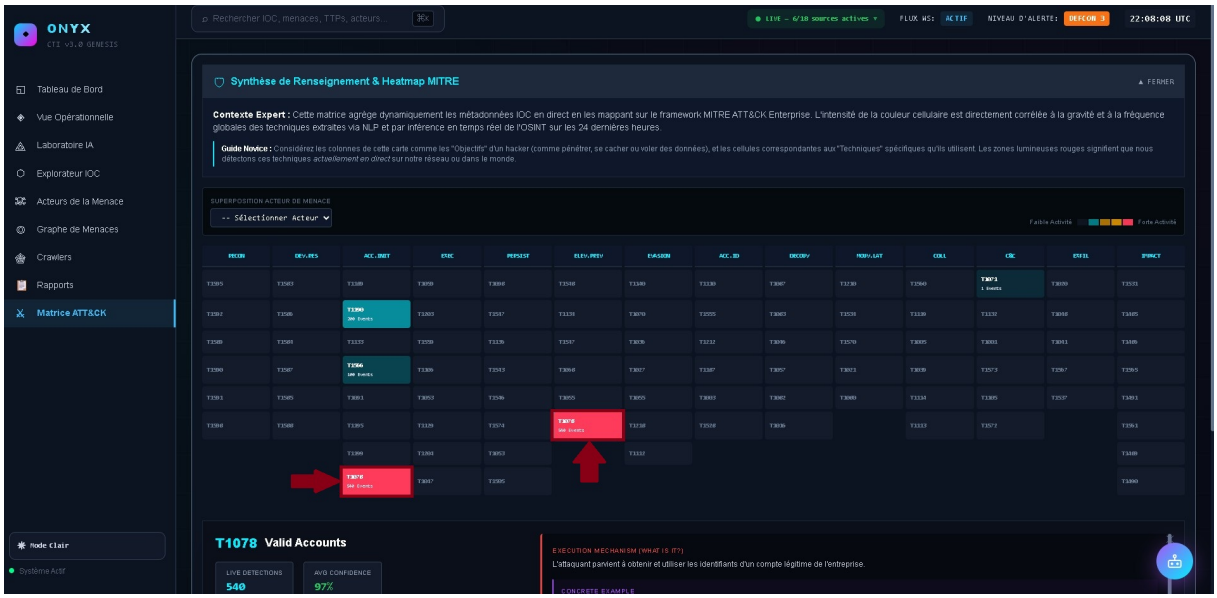

FIGURE 4.9 – Matrice MITRE ATT&CK interactive en mode heatmap.

2.6 Analyse sémantique et explicabilité IA

La plateforme ONYX intègre plusieurs modules dédiés à l'analyse sémantique et à l'interprétation des renseignements produits par le moteur d'intelligence artificielle. Ces outils permettent à la fois d'exploiter les données collectées, d'assister les analystes dans leurs investigations et d'améliorer la compréhension des résultats générés automatiquement.

Le premier module correspond à l'assistant conversationnel **ONYX Copilot**, présenté à la Figure 4.10. Il permet d'interroger la base de connaissances CTI en langage naturel et de rechercher rapidement des informations relatives aux menaces observées. Les réponses sont générées à l'aide d'un mécanisme de type *Retrieval-Augmented Generation* (RAG) [10], garantissant leur ancrage dans les données effectivement collectées et analysées par la plateforme.

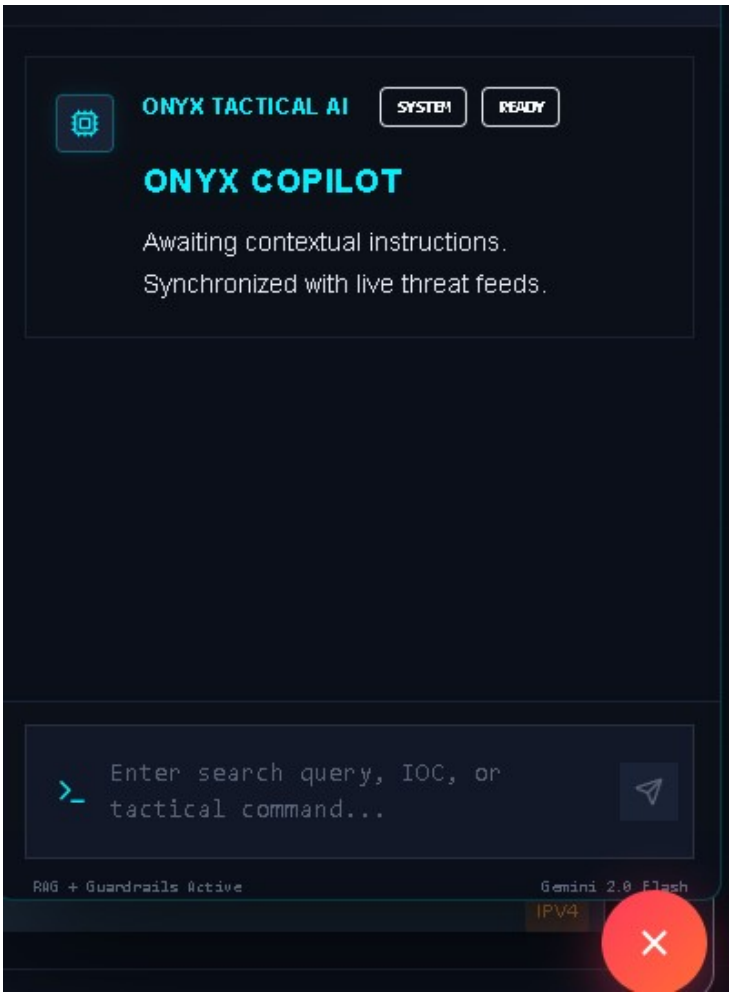

FIGURE 4.10 – Assistant conversationnel ONYX Copilot.

La Figure 4.11 illustre le laboratoire IA, qui permet de suivre en temps réel le fonctionnement du moteur d'analyse sémantique basé sur SciBERT [7]. Cette interface présente les différentes étapes de traitement d'un document ainsi que les résultats produits, notamment les entités extraites et les règles de détection Sigma ou YARA [43, 42] générées automatiquement à partir du contenu analysé.

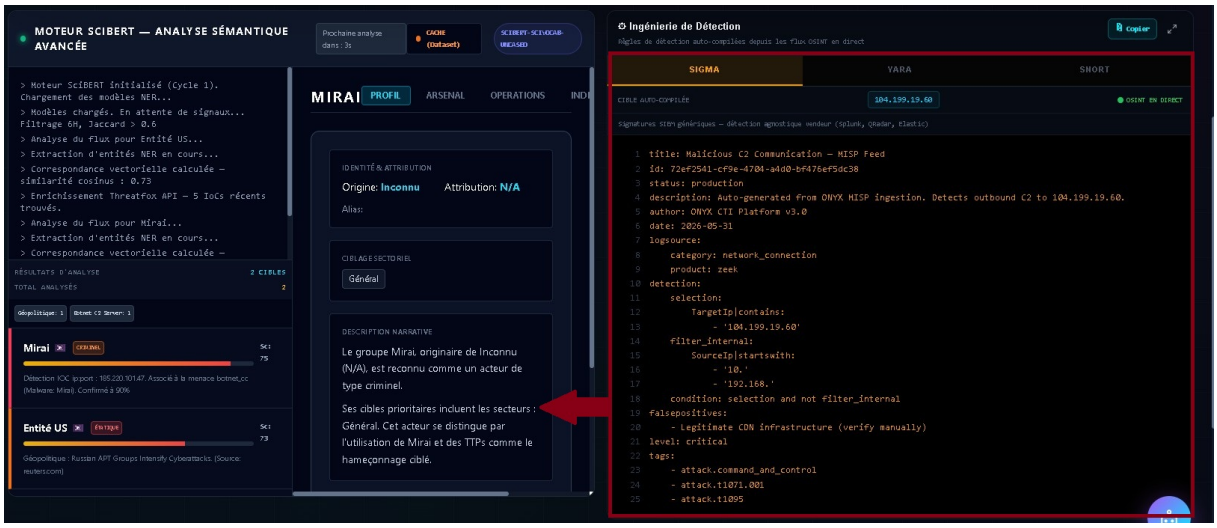

FIGURE 4.11 – Laboratoire IA : moteur SciBERT et génération de règles de détection.

Afin de renforcer la confiance dans les résultats produits, ONYX intègre également un laboratoire d'explicabilité illustré à la Figure 4.12. Ce module fournit une justification textuelle des décisions prises par le moteur d'analyse en mettant en évidence les éléments ayant conduit à l'identification d'un comportement malveillant. L'analyste peut ainsi comprendre, vérifier et valider les résultats avant leur exploitation opérationnelle.

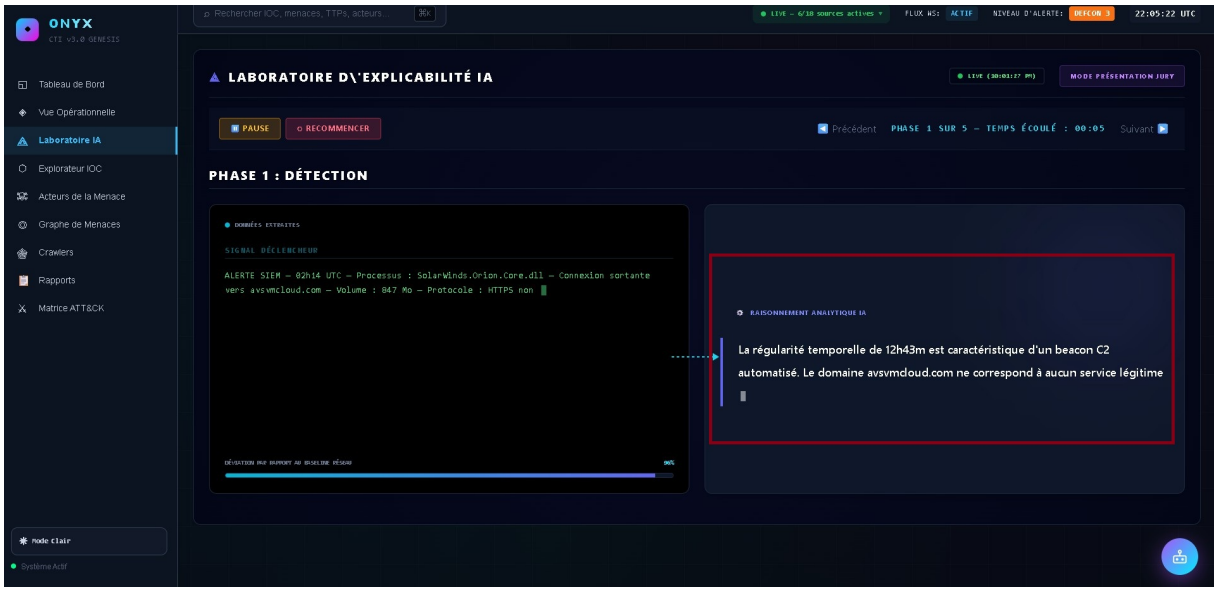

FIGURE 4.12 – Laboratoire d'explicabilité IA (phase de détection).

2.7 Interopérabilité et génération de rapports automatisés

Afin de faciliter le partage et l'exploitation du renseignement produit, ONYX intègre un module dédié à la génération automatique de rapports et à l'exportation des données vers

des plateformes tierces. Cette fonctionnalité favorise l'intégration de la plateforme dans un écosystème CTI existant et simplifie la diffusion du renseignement auprès des différents acteurs de la cybersécurité.

L'interface présentée à la Figure 4.13 permet de générer des rapports structurés à partir des informations collectées et analysées par la plateforme. L'utilisateur peut définir le niveau de confidentialité des données grâce aux marquages TLP (*Traffic Light Protocol*) [5], afin d'adapter la diffusion du renseignement au contexte opérationnel.

Les rapports produits suivent une structure inspirée de l'approche *BLUF* (*Bottom Line Up Front*), facilitant l'accès rapide aux informations essentielles. Les données peuvent également être exportées au format **STIX 2.1** [1], garantissant leur compatibilité avec les plateformes CTI, les solutions SIEM et les outils de sécurité partenaires.

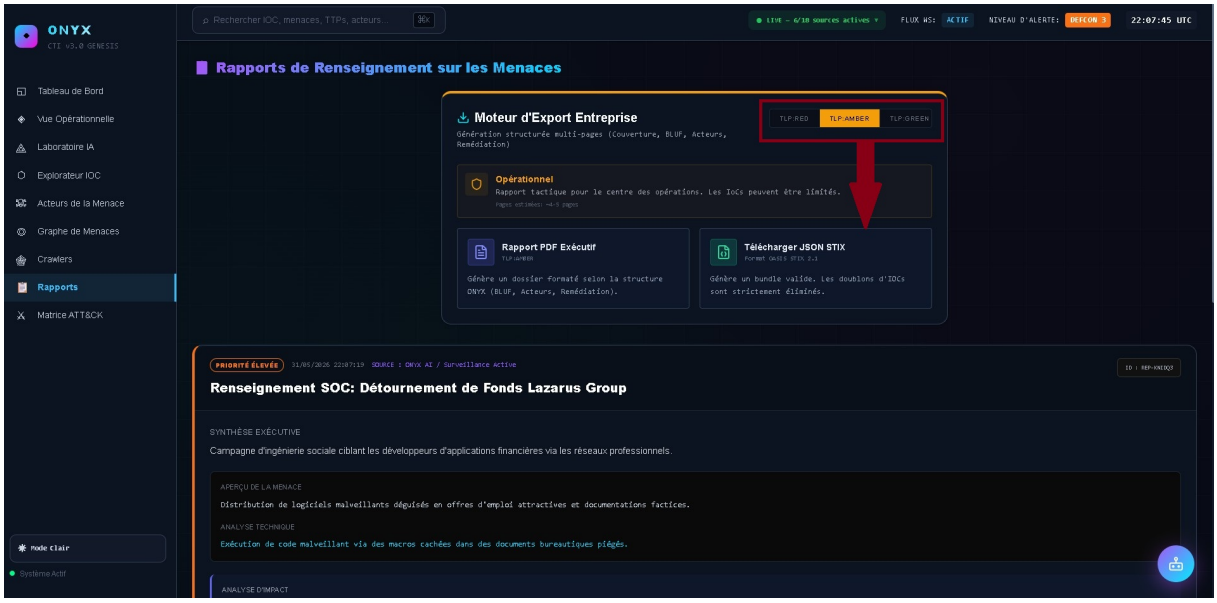

FIGURE 4.13 – Module d'exportation de rapports et gestion STIX/TLP.

3 Évaluation de la Résilience Architecturale

La robustesse d'une plateforme de renseignement sur les cybermenaces ne se mesure pas uniquement à ses capacités analytiques, mais aussi à sa capacité à rester opérationnelle lorsque certains de ses composants deviennent indisponibles. La plateforme ONYX intègre pour cela un mécanisme de dégradation gracieuse (*graceful degradation*), qui garantit la continuité du service quelle que soit la disponibilité des dépendances externes.

Le principe est simple : si un composant est indisponible, le système bascule automatiquement vers un niveau de repli alternatif, sans interruption visible pour l'analyste. La Figure 4.14 illustre cette cascade de niveaux successifs.

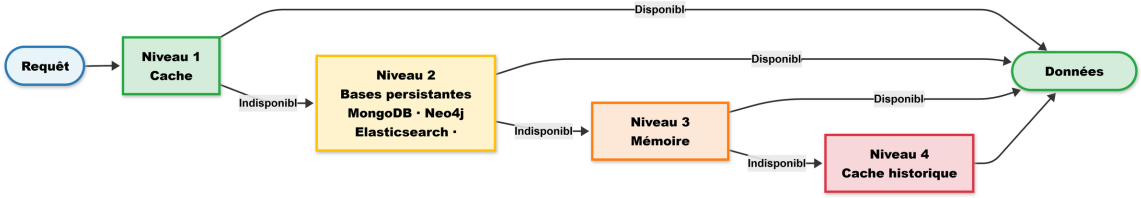

FIGURE 4.14 – Mécanisme de dégradation gracieuse

Les quatre niveaux fonctionnent de la manière suivante :

1. **Cache rapide (Redis)** : toute requête est d'abord traitée depuis le cache Redis [33], qui offre les temps de réponse les plus courts et limite la sollicitation des bases de données. Ce niveau couvre les données fréquemment consultées, comme les scores de criticité ou les résultats de requêtes récentes. Si Redis est indisponible, le système passe automatiquement au niveau suivant.
2. **Bases de données persistantes** : si le cache est inaccessible, les données sont récupérées directement depuis les bases adaptées à chaque type d'information : MongoDB [30] pour les objets STIX, Neo4j [31] pour les relations entre entités, Elasticsearch [32] pour la recherche textuelle, et PostgreSQL [34] pour les données structurées sensibles. Ce niveau garantit la fidélité des informations, au prix d'une latence légèrement plus élevée.
3. **Mémoire applicative** : si toutes les bases de données sont défaillantes, la plateforme utilise les indicateurs déjà chargés en mémoire lors de la dernière initialisation réussie. Le tableau de bord reste fonctionnel, même si les données affichées peuvent ne pas refléter les acquisitions les plus récentes.
4. **Cache historique local** : en dernier recours, lorsque toutes les sources externes sont inaccessibles, un échantillon de données historiques pré-vérifié est chargé automatiquement. Ce niveau évite l'affichage d'une interface vide et garantit qu'un contexte de menace minimal reste disponible pour l'analyste.

Ce mécanisme répond directement à l'exigence non fonctionnelle ENF-5 définie au

Chapitre 2, relative à la performance et à la disponibilité de la plateforme. Il garantit qu'aucune défaillance externe isolée n'entraîne l'arrêt complet de l'interface, et que les données restituées restent exploitables quel que soit l'état des composants. Dans un environnement de sécurité opérationnelle, où toute interruption non planifiée peut réduire la capacité de détection des équipes, cette conception constitue un choix architectural essentiel.

4 Synthèse de la validation

Les différents scénarios présentés dans ce chapitre ont permis de valider le fonctionnement des principaux composants de la plateforme ONYX. Les résultats obtenus confirment la capacité du système à collecter, analyser, corréler et exploiter des renseignements issus de sources hétérogènes dans un environnement unifié.

La validation a notamment porté sur plusieurs aspects essentiels :

— l'acquisition automatisée des données provenant de sources OSINT et du Dark Web ;

— l'enrichissement, la corrélation et la gestion du cycle de vie des indicateurs de compromission ;

— la visualisation des menaces à travers des tableaux de bord, des cartographies et des graphes de connaissances ;

— l'analyse sémantique basée sur SciBERT ainsi que la génération automatisée de règles de détection ;

— l'explicabilité des résultats produits par les mécanismes d'intelligence artificielle ;

— l'interopérabilité avec les écosystèmes CTI grâce aux standards STIX 2.1, TLP, Sigma et YARA.

Ces résultats démontrent la cohérence de l'architecture proposée et mettent en évidence la capacité de la plateforme ONYX à automatiser plusieurs étapes du cycle de vie du renseignement sur les cybermenaces tout en facilitant leur exploitation opérationnelle.

Conclusion

Ce chapitre a permis de valider le fonctionnement des principaux modules de la plateforme ONYX. Les différents scénarios présentés ont confirmé sa capacité à collecter, analyser, corréler et exploiter des renseignements issus de sources hétérogènes. Les résultats obtenus démontrent la cohérence de l'architecture proposée ainsi que l'intégration effective des mécanismes d'analyse sémantique, de corrélation des menaces et d'interopérabilité CTI. Ils mettent également en évidence le potentiel de la plateforme pour assister les équipes SOC et CTI dans leurs activités de veille, d'investigation et de détection des menaces.

Conclusion générale

Ce projet de fin d'études a permis de concevoir et de développer **ONYX CTI**, une plateforme dédiée au renseignement sur les cybermenaces intégrant des capacités de collecte, d'analyse et d'exploitation du renseignement cyber. La solution proposée répond aux enjeux actuels de la cybersécurité en permettant la transformation de données hétérogènes issues de sources ouvertes et du Dark Web en informations structurées et exploitables par les équipes de sécurité.

Les différentes phases du projet ont permis d'étudier les concepts fondamentaux de la Cyber Threat Intelligence, d'analyser les besoins fonctionnels et techniques de la solution, puis de concevoir une architecture modulaire couvrant l'ensemble du cycle de vie du renseignement. La plateforme développée intègre des mécanismes de collecte automatisée, d'analyse sémantique, de corrélation des menaces, de visualisation interactive et d'interopérabilité reposant sur les standards du domaine.

Les résultats obtenus lors de la phase de validation ont confirmé le bon fonctionnement des principaux modules de la plateforme. ONYX permet notamment la collecte et l'enrichissement automatisés des indicateurs de compromission, leur représentation sous différentes formes analytiques ainsi que leur partage au moyen des standards STIX 2.1 et TAXII. Ces résultats démontrent la faisabilité de l'approche proposée et l'intérêt d'une plateforme intégrée pour assister les équipes SOC et CTI dans leurs activités de veille, d'investigation et de détection.

Comme perspectives, plusieurs axes d'amélioration peuvent être envisagés, notamment l'intégration de nouveaux modèles d'intelligence artificielle pour l'analyse avancée des menaces, l'élargissement des capacités de collecte à d'autres sources spécialisées ainsi que le renforcement des mécanismes de corrélation et de détection des attaques complexes. Ces évolutions contribueraient à améliorer davantage la capacité de la plateforme à identifier les cybermenaces émergentes et à soutenir la prise de décision des analystes.

Bibliographie

[1] OASIS Cyber Threat Intelligence (CTI) Technical Committee, *STIX™ Version 2.1 — Structured Threat Information Expression*, OASIS Standard, 2021. https://docs.oasis-open.org/cti/stix/v2.1/stix-v2.1.html

[2] OASIS Cyber Threat Intelligence (CTI) Technical Committee, *TAXII™ Version 2.1 — Trusted Automated Exchange of Intelligence Information*, OASIS Standard, 2021. https://docs.oasis-open.org/cti/taxii/v2.1/taxii-v2.1.html

[3] MITRE Corporation, *MITRE ATT&CK® — Adversarial Tactics, Techniques, and Common Knowledge*, 2026. https://attack.mitre.org/

[4] B. E. Strom, A. Applebaum, D. P. Miller, K. C. Nickels, A. G. Pennington, C. B. Thomas, *MITRE ATT&CK® : Design and Philosophy*, MITRE Technical Report MTR190013, 2020. https://attack.mitre.org/docs/ATTACK_Design_and_Philosophy_March_2020.pdf

[5] Forum of Incident Response and Security Teams (FIRST), *Traffic Light Protocol (TLP) — Version 2.0*, 2022. https://www.first.org/tlp/

[6] Forum of Incident Response and Security Teams (FIRST), *Common Vulnerability Scoring System (CVSS) — Specification Document v4.0*, 2023. https://www.first.org/cvss/v4.0/specification-document

[7] I. Beltagy, K. Lo, A. Cohan, « SciBERT : A Pretrained Language Model for Scientific Text », *Proc. EMNLP*, pp. 3615–3620, 2019. https://arxiv.org/abs/1903.10676

[8] J. Devlin, M.-W. Chang, K. Lee, K. Toutanova, « BERT : Pre-training of Deep Bidirectional Transformers for Language Understanding », *Proc. NAACL-HLT*, pp. 4171–4186, 2019. https://arxiv.org/abs/1810.04805

[9] T. Wolf et al., « Transformers : State-of-the-Art Natural Language Processing », *Proc. EMNLP*, pp. 38–45, 2020. https://huggingface.co/transformers/

[10] P. Lewis et al., « Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks », *NeurIPS*, vol. 33, pp. 9459–9474, 2020. https://arxiv.org/abs/2005.11401

[11] C. Wagner, A. Dulaunoy, G. Wagener, A. Iklody, « MISP : The Design and Implementation of a Collaborative Threat Intelligence Sharing Platform », *Proc. WISCS*, pp. 49–56, 2016. https://www.misp-project.org/

[12] Luatix, *OpenCTI — Open Cyber Threat Intelligence Platform*, Documentation officielle, 2026. https://www.opencti.io/

[13] Recorded Future, *Intelligence Platform — Technical Overview*, 2026. https://www.recordedfuture.com/

[14] Mandiant, *Mandiant Advantage — Threat Intelligence Documentation*, 2026. https://www.mandiant.com/advantage/threat-intelligence

[15] CrowdStrike, *Falcon Intelligence — Product Documentation*, 2026. https://www.crowdstrike.com/products/threat-intelligence/

[16] CISA, *Known Exploited Vulnerabilities Catalog (KEV)*, 2026. https://www.cisa.gov/known-exploited-vulnerabilities-catalog

[17] NIST, *National Vulnerability Database (NVD)*, 2026. https://nvd.nist.gov/

[18] abuse.ch, *Feodo Tracker — Tracking Botnet C&C Servers*, 2026. https://feodotracker.abuse.ch/

[19] abuse.ch, *URLhaus — Sharing Malicious URLs*, 2026. https://urlhaus.abuse.ch/

[20] abuse.ch, *ThreatFox — Sharing Indicators of Compromise*, 2026. https://threatfox.abuse.ch/

[21] abuse.ch, *MalwareBazaar — Sharing Malware Samples*, 2026. https://bazaar.abuse.ch/

[22] AT&T Cybersecurity, *Open Threat Exchange (OTX) — API Documentation*, 2026. https://otx.alienvault.com/

[23] Proofpoint, *Emerging Threats Open Ruleset*, 2026. https://rules.emergingthreats.net/

[24] S. Ramírez, *FastAPI — Modern Web Framework for Python*, 2026. https://fastapi.tiangolo.com/

[25] A. Solem et al., *Celery — Distributed Task Queue*, 2026. https://docs.celeryq.dev/

[26] Zyte, *Scrapy — A Fast High-Level Web Crawling Framework*, 2026. https://scrapy.org/

[27] Microsoft, *Playwright — Reliable End-to-End Testing*, 2026. https://playwright.dev/

[28] S. Colvin, *Pydantic — Data Validation*, 2026. https://docs.pydantic.dev/

[29] P. Brinck et al., *Strawberry — Python GraphQL APIs*, 2026. https://strawberry.rocks/

[30] MongoDB, Inc., *MongoDB Documentation*, 2026. https://www.mongodb.com/docs/

[31] Neo4j, Inc., *Neo4j Documentation*, 2026. https://neo4j.com/docs/

[32] Elastic N.V., *Elasticsearch Documentation*, 2026. https://www.elastic.co/guide/en/elasticsearch/

[33] Redis Ltd., *Redis Documentation*, 2026. https://redis.io/docs/

[34] PostgreSQL Group, *PostgreSQL Documentation*, 2026. https://www.postgresql.org/docs/

[35] Qdrant, *Qdrant Documentation*, 2026. https://qdrant.tech/documentation/

[36] Vercel, Inc., *Next.js Documentation*, 2026. https://nextjs.org/docs

[37] Meta, *React Documentation*, 2026. https://react.dev/

[38] M. Franz et al., *Cytoscape.js : a graph theory library*, Bioinformatics, 2016. https://js.cytoscape.org/

[39] R. Cabello, *Three.js JavaScript 3D Library*, 2026. https://threejs.org/

[40] Mapbox, Inc., *Mapbox GL JS*, 2026. https://docs.mapbox.com/mapbox-gl-js/

[41] Recharts Group, *Recharts Documentation*, 2026. https://recharts.org/

[42] V. M. Álvarez, *YARA Pattern Matching*, VirusTotal, 2026. https://virustotal.github.io/yara/

[43] F. Roth et al., *Sigma Generic Signature Format*, SigmaHQ, 2026. https://sigmahq.io/

[44] R. Dingledine et al., « Tor : The Second-Generation Onion Router », *Proc. 13th USENIX Security*, 2004. https://www.torproject.org/

[45] Docker, Inc., *Docker Documentation*, 2026. https://docs.docker.com/

[46] ANSSI, *Guide d'hygiène informatique*, 2026. https://www.ssi.gouv.fr/guide/guide-dhygiene-informatique/

[47] ISO, *ISO/IEC 27001 :2022 Information Security Management*, 2022. https://www.iso.org/standard/27001

[48] NIST, *Cybersecurity Framework (CSF) v2.0*, 2024. https://www.nist.gov/cyberframework

[49] D. J. Bianco, *The Pyramid of Pain*, 2013. https://detect-respond.blogspot.com/2013/03/the-pyramid-of-pain.html

[50] IETF, *RFC 7519 — JSON Web Token (JWT)*, 2015. https://datatracker.ietf.org/doc/html/rfc7519

ANNEXES

Annexe A : Code source de l'implémentation (Chapitre 3)

Cette annexe regroupe les extraits de code associés à l'implémentation présentée au Chapitre 3. Les blocs sont organisés par responsabilité technique afin de faciliter la lecture, la traçabilité et la mise en relation avec les modules décrits dans le corps du rapport.

L'organisation retenue suit une progression fonctionnelle : collecte anonymisée, prétraitement, normalisation, génération de règles, corrélation graphe et exposition des indicateurs par interface d'interopérabilité.

A.0.1 Module de collecte et d'anonymisation

Ce module assure la rotation contrôlée des circuits Tor. Il limite la réutilisation d'un même circuit et introduit un délai stochastique après chaque renouvellement afin de réduire les comportements de collecte facilement identifiables.

```
import asyncio
import random
import math
import os

class TorCircuitRotator:
    def __init__(self, control_port=9051, max_requests_per_circuit=50):
        self._control_port = control_port
        self._max_requests = max_requests_per_circuit
        self._request_count = 0
        self._lock = asyncio.Lock()

```

```
        self._password = os.getenv("ONYX_TOR_CONTROL_PASSWORD")
        if not self._password:
            raise ValueError("Le mot de passe Tor n'est pas configure
            dans l'environnement.")

    def _stochastic_delay(self) -> float:
        mu, sigma = 1.5, 0.5
        delay = random.lognormvariate(math.log(mu), sigma)
        return max(0.8, min(delay, 6.0))

    async def maybe_rotate(self):
        self._request_count += 1
        if self._request_count < self._max_requests:
            return
        await self._send_newnym()

    async def _send_newnym(self):
        async with self._lock:
            reader, writer = await asyncio.wait_for(
                asyncio.open_connection("127.0.0.1", self._control_port),
                timeout=10.0)
            await reader.readline()
            writer.write(f'AUTHENTICATE "{self._password}"\r\n'.encode())
            await writer.drain()
            resp = await reader.readline()
            if b"250" not in resp:
                raise ConnectionError(f"Echec auth Tor :
                {resp.decode().strip()}")
            writer.write(b"SIGNAL NEWNYM\r\n")
            await writer.drain()
            resp = await reader.readline()
            writer.close()
            await writer.wait_closed()
            if b"250" in resp:
                await asyncio.sleep(self._stochastic_delay())
```

```
                self._request_count = 0
```

Code 1 – Rotation automatique des circuits Tor via le signal NEWNYM

A.0.2 Module de prétraitement et de déduplication

Le prétraitement supprime les éléments HTML non informatifs avant de calculer une empreinte SHA-256 sur le texte nettoyé. Cette étape évite l'indexation répétée de contenus identiques et fiabilise la constitution du corpus.

```
import hashlib
from bs4 import BeautifulSoup

class ContentDeduplicationMiddleware:
    def __init__(self):
        self._seen_hashes: set[str] = set()

    def process_response(self, request, response, spider):
        soup = BeautifulSoup(response.text, "html.parser")

        for tag in soup(["script", "style", "noscript", "nav",
         "footer", "header"]):
            tag.decompose()

        clean_text = soup.get_text(separator="\n", strip=True)

        content_hash = hashlib.sha256(
            clean_text.encode("utf-8", errors="ignore")
        ).hexdigest()

        if content_hash in self._seen_hashes:
            from scrapy.exceptions import IgnoreRequest
            raise IgnoreRequest("Contenu duplique")

```

```
25          self._seen_hashes.add(content_hash)
26          response.meta["content_hash"] = content_hash
27
28          return response
```

Code 2 – Intergiciel de déduplication par hachage SHA-256

A.0.3 Normalisation et structuration STIX 2.1

Les indicateurs extraits sont convertis vers le format STIX 2.1. Les champs standards assurent l'interopérabilité, tandis que les attributs `x_onyx_` conservent les métadonnées propres à la plateforme.

```
{
  "type": "indicator",
  "spec_version": "2.1",
  "id": "indicator--a1b2c3d4-e5f6-7890-abcd-ef1234567890",
  "name": "ipv4: 185.220.101.45",
  "description": "Serveur C2 detecte par le pipeline ONYX",
  "pattern": "[ipv4-addr:value = '185.220.101.45']",
  "pattern_type": "stix",
  "confidence": 97,
  "x_onyx_source": "abuse.ch Feodo Tracker",
  "x_onyx_mitre_techniques": ["T1071", "T1568"],
  "x_onyx_decay_score": 1.0,
  "x_onyx_decay_state": "valid"
}
```

Code 3 – Exemple d'objet STIX 2.1 généré par le pipeline ONYX

A.0.4 Génération automatique de règles de détection

À partir d'un indicateur validé, la plateforme produit une règle Sigma simple et directement exploitable par des chaînes de détection compatibles. La règle conserve les références MITRE ATT&CK utiles au suivi analytique.

```
title: Connexion C2 detectee - ONYX
status: experimental

description: >
  Connexion sortante vers un serveur C2 identifie
  par la plateforme ONYX.

logsource:
  category: network_connection

detection:
  selection:
    DestinationIp: '185.220.101.45'
  condition: selection

level: high

tags:
  - attack.command_and_control
  - attack.t1071
```

Code 4 – Exemple de règle Sigma générée automatiquement

A.0.5 Corrélation des entités dans Neo4j

La requête suivante illustre la traversée du graphe de renseignement depuis un indicateur jusqu'aux entités de plus haut niveau : malware, campagne et acteur de menace.

```
MATCH (ioc:Indicator {value: '185.220.101.45'})
MATCH path = (ioc)-[:INDICATES]->(m:Malware)-[:USED_BY]->(c:Campaign)-
 [:ATTRIBUTED_TO]->(a:ThreatActor)
RETURN
    a.name AS acteur,
    c.name AS campagne,
    m.name AS malware,
    length(path) AS profondeur
```

Code 5 – Exemple de requête Cypher pour la corrélation d'un IoC

A.0.6 Interface d'interopérabilité GraphQL

La persistance à long terme des indicateurs de compromission impose un mécanisme de cycle de vie afin d'éviter l'accumulation de faux positifs obsolètes. La plateforme ONYX s'appuie donc sur un score de vétusté (*Decay Score*) initialisé à 1.0 lors de la première détection d'un IoC.

Ce score décroît progressivement lorsqu'une vérification automatisée échoue ou lorsqu'aucune activité n'est recensée pendant une période définie. Sous le seuil critique de 0.50, l'indicateur passe automatiquement de `VALID` à `REVOKED`, ce qui maintient des flux de renseignement actualisés et exploitables par les analystes.

```
query {
  indicators(
    filters: { decay_state: "VALID", min_score: 0.80 }
    limit: 50
  ) {
    value
    type
    confidence
    decay_score
    mitre_techniques
    source
```

```
    }
}
```

Code 6 – Exemple de requête GraphQL pour la récupération ciblée des indicateurs

« Conception et Développement d'une Plateforme de Renseignement sur les Cybermenaces (CTI) avec Surveillance Automatisée du Dark Web »

الملخص : إن تزايد التهديدات السيبرانية وتطورها، إلى جانب الاستغلال المتزايد للويب المظلم، يجعل اكتشاف الهجمات أمراً معقداً للمؤسسات. لمواجهة هذا التحدي، تقترح هذه المذكرة منصة **CTI ONYX**، وهي منصة لاستخبارات التهديدات السيبرانية. تعمل المنصة بشكل عام على الجمع المستمر لمؤشرات الاختراق (IOC) من المصادر المفتوحة (OSINT) والشبكات السرية، ليتم بعد ذلك توحيدها، تحليلها بواسطة الذكاء الاصطناعي، وربطها لرسم خرائط التهديدات. تتمثل المساهمة الرئيسية لهذا العمل في تزويد مراكز العمليات الأمنية (SOC) برؤية مركزية وقابلة للتنفيذ. فمن خلال أتمتة التحليل وتصفية الإنذارات الخاطئة، تتيح المنصة تحديد المخاطر الناشئة وتسريع الاستجابة للحوادث.

الكلمات المفتاحية : استخبارات التهديدات السيبرانية ،(CTI) الويب المظلم (Dark Web)، مؤشر الاختراق ،(IOC) ،OSINT الذكاء الاصطناعي، .SOC

Résumé : L'augmentation et la sophistication des cybermenaces, ainsi que l'exploitation croissante du Dark Web, rendent la détection des attaques complexe pour les organisations. Pour répondre à ce défi, ce mémoire propose **ONYX CTI**, une plateforme de renseignement sur les cybermenaces. Globalement, la solution collecte en continu des indicateurs de compromission (IOC) depuis des sources ouvertes (OSINT) et des réseaux clandestins. Ces données sont ensuite normalisées, analysées par intelligence artificielle et corrélées pour cartographier les menaces. L'apport principal de cette plateforme est d'offrir aux Centres Opérationnels de Sécurité (SOC) une visibilité centralisée et exploitable. En automatisant l'analyse et en filtrant les fausses alertes, ONYX CTI permet d'identifier les risques émergents et d'accélérer la réponse aux incidents.

Mots clés : Cyber Threat Intelligence (CTI), Dark Web, Indicateur de Compromission (IOC), OSINT, Intelligence Artificielle, SOC.

Abstract: The increase and sophistication of cyber threats, along with the growing exploitation of the Dark Web, make threat detection complex for organizations. To address this challenge, this thesis proposes **ONYX CTI**, a Cyber Threat Intelligence platform. Globally, the solution continuously collects Indicators of Compromise (IoCs) from open sources (OSINT) and underground networks. This data is then normalized, analyzed by artificial intelligence, and correlated to map threats. The main contribution of this platform is providing Security Operations Centers (SOC) with centralized and actionable visibility. By automating analysis and filtering false alerts, ONYX CTI enables the identification of emerging risks and accelerates incident response.

Keywords: Cyber Threat Intelligence, Dark Web, Indicator of Compromise (IOC), OSINT, Artificial Intelligence, SOC.